



Information Security Baseline

Security Measure Plan for Red Hat Enterprise Linux 8

Current release

Authors	Cornelius Moucha
Owner	CT CYS GOV POL
Version Number	1.0
Approved By	Jose Antonio Rubio Tora
Status	Release
Document Release Date	2020-08-07
Classification	Restricted
Document ID	BL512
Reference Source	https://sfera.siemens.com

Document History

Version	Author	Date	Description
1.0		2020-08-07	Initial version

Change Log in the Current Version

This is the initial version of the *Security Measure Plan*.

Following changes have been submitted during review:

- **Created** note in chapter *Scope and Applicability* that this *Security Measure Plan* primarily focus on server systems.
- **Created** section *System Users and Interactive Users* in chapter *Scope and Applicability*.
- **Deleted** BL512-1952 (**Ensure separate partition is used for /var**): Removed according feedback from review meeting due to only limited security benefit for expected maintenance effort.
- **Deleted** BL512-6587 (**Ensure separate partition is used for /var/log/audit**): Removed according feedback from review meeting due to only limited security benefit for expected maintenance effort (and /var/log/ rule is still required).
- **Deleted** BL512-5429 (**Ensure firewall is configured to all new outbound and established connections**): Removed: outbound direction is more a topic of external world, not the system's task.
- **Deleted** BL512-4317 (**Ensure file deletion events by users are collected**): Only limited security benefit for very high logging overhead.
- **Deleted** BL512-2728 (**Ensure the audit configuration is immutable**): Removed according feedback from review meetings, impractical to allow this only on reboot on server systems and config changes are monitored by other means.
- **Deleted** BL512-8678 (**Ensure SSH warning banner is configured**): Removed: banner is more legal topic and can raise issues for SSH automated environments.

- Deleted **BL512-4028 (Ensure shadow group is empty)**: RHEL8 does not have or use shadow group.
- Modified **[BL512-1000](#) (Install a BIOS/UEFI setup password)**: Added exemption 01 according feedback from review meetings.
- Modified **[BL512-3200](#) (Configure boot sequence to primary hard disk first)**: Modified exemption 01 in alignment with rule BL512-1000.
- Modified **[BL512-8962](#) (Disable Built-in Remote Management Interface)**: Minor rephrasing of rule (added 'existing' ... interfaces) and exemption.
- Modified **[BL512-4919](#) (Disable biometric authentication devices)**: Rephrased to 'existing' biometric devices.
- Modified **[BL512-2876](#) (Ensure permissions on bootloader config are configured)**: Changed required permission to 644 to be vendor default compliant.
- Modified **[BL512-9180](#) (Ensure bootloader password is set)**: Added exemption 01 according feedback from review meetings. Added password change requirement note.
- Modified **[BL512-4358](#) (Ensure /tmp is configured to use tmpfs or separate partition)**: Reworked according feedback from review meeting to also allow separate partition. Added note for /etc/fstab entry removal.
- Modified **[BL512-7719](#) (Ensure /var/tmp is configured)**: Added second option without dedicated partition using sticky bit.
- Modified **[BL512-8758](#) (Ensure nodev option set on /var/tmp)**: Added exemption according feedback from review meetings.
- Modified **[BL512-9671](#) (Ensure nosuid option set on /var/tmp)**: Added exemption according feedback from review meetings.
- Modified **[BL512-9900](#) (Ensure noexec option set on /var/tmp)**: Added exemption according feedback from review meetings.
- Modified **[BL512-9228](#) (Ensure separate partition is used for /var/log)**: Added exemption 01 according feedback from review meetings.
- Modified **[BL512-9270](#) (Ensure separate partition is used for main user home directory)**: Added exemption 02 for non-local home directories.
- Modified **[BL512-9960](#) (Ensure nodev option set on /home partition)**: Added the Note in the Rule section as an exemption.
- Modified **[BL512-2440](#) (Disable Automounting for removable media devices)**: Rephrased title to only disallow removable media automount; added notes for different techniques of implementing automounting.
- Modified **[BL512-3717](#) (Ensure gpgcheck is globally activated)**: Added exemption according feedback from review meetings.
- Modified **[BL512-6874](#) (Ensure all configured GPG keys are correctly signed by package provider or distribution vendor)**: Rephrased rule according feedback from review meetings allowing distribution vendors as well.
- Modified **[BL512-4233](#) (Ensure AIDE is installed and configured)**: Rephrased rationale to focus forensic investigations according feedback from review meetings.
- Modified **[BL512-8250](#) (Ensure filesystem integrity is regularly checked)**: Rephrased rule and rationale to focus forensic investigations according feedback from review meetings.
- Modified **[BL512-4165](#) (Install a virus scanner)**: Aligned exemption 01 according feedback from review.
- Modified **[BL512-3937](#) (Enable the Corporate Scan Service Software Agent)**:

Rephrased exemption to clarify standalone systems with SNX access.

- **Modified [BL512-3891](#) (Ensure the SELinux state is enforcing):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-1792](#) (Ensure SELinux is not disabled in bootloader configuration):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-2898](#) (Ensure SELinux policy is configured):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-9195](#) (Ensure SETroubleshoot is not installed):** Added exemption 01, 02 according feedback from review meetings.
- **Modified [BL512-4980](#) (Ensure the MCS Translation Service (mcstrans) is not installed):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-8964](#) (Ensure no unconfined daemons exist):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-3889](#) (Ensure SELinux is installed):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-9945](#) (Ensure recent updates and patches are installed):** Added note and rephrased according to feedback from review meeting.
- **Modified [BL512-0990](#) (Ensure volumes are encrypted):** Changed rule such that operating system volumes can be excluded.
- **Modified [BL512-5500](#) (Ensure X Window System is not installed):** Added exemption for non-server system.
- **Modified [BL512-7333](#) (Ensure CUPS is not enabled):** Added exemption 02 according feedback from review meetings.
- **Modified [BL512-2528](#) (Ensure IP forwarding is disabled):** Added exemption for VM/Docker-Hosts according received feedback.
- **Modified [BL512-3212](#) (Ensure IPv6 router advertisements are not accepted):** Added exemption 01 according feedback from review meetings: Can lead to errors, if IPv6 is disabled.
- **Modified [BL512-8891](#) (Ensure IPv6 is disabled):** Fixed old implementation way. Fixed sometimes invalid grep value in check.
- **Modified [BL512-0996](#) (Ensure firewall rules are permanent):** Generalized wording to firewall rules, not just nftables rules.
- **Modified [BL512-4800](#) (Ensure default deny firewall policy is active):** Reworked to default deny only on input chain; added exemption for external firewall; added note that port-based allow-rules are permitted.
- **Modified [BL512-9036](#) (Ensure at least notice mail is sent to an active mail account when audit log storage is full):** Added 'admin_space_left_action' according feedback from review meetings. Fixed missing grep-output in check. Aligned rationale and description to relaxed rule text.
- **Modified [BL512-8755](#) (Ensure audit logs are not automatically deleted):** Relaxed to CIA23, added exemption 01 according feedback from review meetings.
- **Modified [BL512-4188](#) (Ensure events that modify date and time information are collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-2129](#) (Ensure events that modify user/group information are collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-3300](#) (Ensure events that modify the system's network environment are collected):** Fixed wrong path for implementation and checks. Fixed wrong value with slash in implementation and checks.

- **Modified [BL512-3122](#) (Ensure events that modify the system's Mandatory Access Controls are collected):** Added exemption 01 according feedback from review meetings. Fixed wrong path for implementation and checks.
- **Modified [BL512-9024](#) (Ensure login and logout events are collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-3329](#) (Ensure session initiation information is collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-6000](#) (Ensure discretionary access control permission modification events are collected):** Added exemption 01 according feedback from review meetings. Fixed wrong path for implementation and checks.
- **Modified [BL512-8834](#) (Ensure use of privileged commands is collected):** Added exemption 01 according feedback from review meetings. Fixed wrong path for implementation and checks.
- **Modified [BL512-6052](#) (Ensure successful file system mounts are collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-2122](#) (Ensure changes to system administration scope (sudoers) is collected):** Fixed wrong path for implementation and checks. Fixed wrong value with slash in implementation and checks.
- **Modified [BL512-8216](#) (Ensure system administrator actions (sudolog) are collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-3376](#) (Ensure kernel module loading and unloading is collected):** Fixed wrong path for implementation and checks.
- **Modified [BL512-9045](#) (Ensure logging system is installed):** Generalized to 'logging system' without forcing rsyslog.
- **Modified [BL512-4269](#) (Ensure permissions on all logfiles are configured):** Fixed implementation to exclude bttmp, wttmp, lastlog which have different permission level.
- **Modified [BL512-5686](#) (Ensure logging system is enabled):** Generalized to 'logging system' without forcing rsyslog.
- **Modified [BL512-1878](#) (Ensure log file default file permissions are configured):** Generalized to 'logging system' without forcing rsyslog.
- **Modified [BL512-4792](#) (Ensure remote logging messages are only accepted on designated log hosts):** Generalized to 'logging system' without forcing rsyslog.
- **Modified [BL512-5158](#) (Ensure journald is configured to send logs to syslog logging service):** Generalized to 'logging system' without forcing rsyslog.
- **Modified [BL512-2788](#) (Ensure permissions on /etc/crontab are configured):** Changed required permission to 644 to be vendor default compliant.
- **Modified [BL512-3881](#) (Ensure permissions on /etc/cron.hourly are configured):** Changed required permission to 755 to be vendor default compliant.
- **Modified [BL512-1566](#) (Ensure permissions on /etc/cron.daily are configured):** Changed required permission to 755 to be vendor default compliant.
- **Modified [BL512-2883](#) (Ensure permissions on /etc/cron.weekly are configured):** Changed required permission to 755 to be vendor default compliant.
- **Modified [BL512-2025](#) (Ensure permissions on /etc/cron.monthly are configured):** Changed required permission to 755 to be vendor default compliant.
- **Modified [BL512-8787](#) (Ensure permissions on /etc/cron.d are configured):** Changed required permission to 755 to be vendor default compliant.
- **Modified [BL512-8275](#) (Ensure at/cron is restricted to authorized users):** Permissions

aligned to vendor default state; Note added.

- **Modified [BL512-9189](#) (Ensure permissions on `/etc/ssh/sshd_config` are configured):** Changed required permission to 640 to be vendor default compliant of RHEL-8.
- **Modified [BL512-3262](#) (Ensure SSH root login is disabled):** Added note for alternative privilege elevation before disabling root login via ssh.
- **Modified [BL512-0801](#) (Secure SSH login):** Added exemption 01 for domain user accounts according feedback from the review.
- **Modified [BL512-4831](#) (Ensure password creation requirements are configured):** Added values for service accounts.
- **Modified [BL512-1111](#) (Ensure password reuse is limited):** Fixed wrong implementation script value of `pam_pwhistory` and added note for custom profile.
- **Modified [BL512-1997](#) (Ensure password expiration is 180 days or less):** Added values for service accounts.
- **Modified [BL512-9681](#) (Ensure minimum days between password changes is 1 or more):** Relaxed to 1 day or more in alignment with Windows Server MP.
- **Modified [BL512-4279](#) (Ensure system user accounts are non-login):** Added note for dedicated applications as login shell. rephrased according system user definition.
- **Modified [BL512-1755](#) (Ensure default user umask is 027 or more restrictive):** Added note for overwriting umask in `/etc/profile` instead of using `/etc/login.defs`.
- **Modified [BL512-6213](#) (Ensure default user shell timeout is 900 seconds or less):** Corrected value in Implementation and Check section.
- **Modified [BL512-8910](#) (Ensure root login is restricted to system console):** Added note for default disabled state of `securetty` in RHEL8.
- **Modified [BL512-2718](#) (Restrict sudo to dedicated users):** Rephrased note for interactive user accounts according definition.
- **Modified [BL512-8083](#) (Password-protected screensavers):** Added exemption 01 according feedback from review meetings.
- **Modified [BL512-6200](#) (Audit system file permissions):** Removed irrelevant 'dpkg' explanation in description.
- **Modified [BL512-7749](#) (Ensure no unowned files or directories exist):** Text in rationale, description adjusted to not talk about groups.
- **Modified [BL512-4346](#) (Ensure no ungrouped files or directories exist):** Text in rationale, description adjusted to not talk about users.
- **Modified [BL512-3093](#) (Audit SUID executables):** Text in description adjusted to not talk about SGID.
- **Modified [BL512-2294](#) (Audit SGID executables):** Text in description adjusted to not talk about SUID.
- **Modified [BL512-9227](#) (Ensure all users' home directories exist):** Added note for limiting rule to interactive users.
- **Modified [BL512-3452](#) (Ensure users' home directories permissions are 750 or more restrictive):** Added note for limiting rule to interactive users.
- **Modified [BL512-4388](#) (Ensure users own their home directories):** Added note for limiting rule to interactive users.
- **Modified [BL512-9700](#) (Ensure users' dot files are not group or world writable):** Added note for limiting rule to interactive users.

Table of Contents

Current release	2
Document History	2
Change Log in the Current Version	2
Table of Contents	7
Introduction	14
Objectives	14
Scope and Applicability	14
Roles and Responsibilities	15
Information Security Policy Framework	15
Readability	15
Initial Setup	18
Physical Security and secure boot settings	18
BL512-1000 - Install a BIOS/UEFI setup password	18
BL512-3200 - Configure boot sequence to primary hard disk first	20
BL512-8962 - Disable Built-in Remote Management Interface	21
BL512-4919 - Disable biometric authentication devices	23
BL512-2876 - Ensure permissions on bootloader config are configured	24
BL512-9180 - Ensure bootloader password is set	26
BL512-3551 - Ensure authentication required for single user mode	28
Filesystem Configuration	30
BL512-4358 - Ensure /tmp is configured to use tmpfs or separate partition	30
BL512-3700 - Ensure nodev option set on /tmp partition	32
BL512-3432 - Ensure nosuid option set on /tmp partition	33
BL512-7722 - Ensure noexec option set on /tmp partition	34
BL512-7719 - Ensure /var/tmp is configured	35
BL512-8758 - Ensure nodev option set on /var/tmp	37
BL512-9671 - Ensure nosuid option set on /var/tmp	39
BL512-9900 - Ensure noexec option set on /var/tmp	41
BL512-9228 - Ensure separate partition is used for /var/log	43
BL512-9270 - Ensure separate partition is used for main user home directory	44
BL512-9960 - Ensure nodev option set on /home partition	46
BL512-4920 - Ensure nodev option set on /dev/shm	47
BL512-4000 - Ensure nosuid option set on /dev/shm	48
BL512-2123 - Ensure noexec option set on /dev/shm	49
BL512-8000 - Ensure nodev option set on removable media partitions	50
BL512-3849 - Ensure nosuid option set on removable media partitions	51
BL512-1183 - Ensure noexec option set on removable media partitions	52
BL512-8516 - Ensure sticky bit is set on all world-writable directories	53
BL512-2440 - Disable Automounting for removable media devices	54
Configure Software Updates	56

Released: 2020-08-07

BL512-3717 - Ensure gpgcheck is globally activated	56
BL512-6874 - Ensure all configured GPG keys are correctly signed by package provider or distribution vendor	58
BL512-9759 - Ensure system is properly subscribed to Red Hat	59
BL512-3129 - Disable the rhnsd daemon	60
Filesystem Integrity Checking	61
BL512-4233 - Ensure AIDE is installed and configured	61
BL512-8250 - Ensure filesystem integrity is regularly checked	63
Malware Protection	65
BL512-4165 - Install a virus scanner	65
BL512-9000 - Enable an Endpoint Detection and Response Agent	67
BL512-3937 - Enable the Corporate Scan Service Software Agent	69
Additional Process Hardening	71
BL512-3987 - Ensure core dumps are restricted	71
BL512-9851 - Ensure address space layout randomization (ASLR) is enabled	73
Mandatory Access Control	75
Configure SELinux	75
BL512-3891 - Ensure the SELinux state is enforcing	76
BL512-1792 - Ensure SELinux is not disabled in bootloader configuration	78
BL512-2898 - Ensure SELinux policy is configured	80
BL512-9195 - Ensure SETroubleshoot is not installed	82
BL512-4980 - Ensure the MCS Translation Service (mcstrans) is not installed	84
BL512-8964 - Ensure no unconfined daemons exist	85
BL512-3889 - Ensure SELinux is installed	88
Configure sudo	88
BL512-0997 - Ensure sudo is installed	88
BL512-0998 - Ensure sudo commands use pty	90
BL512-0999 - Ensure sudo log file exists	91
Warning Banners	92
Command Line Warning Banners	92
BL512-1950 - Ensure local login warning banner is configured properly	92
BL512-4180 - Ensure remote login warning banner is configured properly	94
BL512-5191 - Ensure permissions on /etc/motd are configured	96
BL512-6629 - Ensure permissions on /etc/issue are configured	97
BL512-8820 - Ensure permissions on /etc/issue.net are configured	99
BL512-9945 - Ensure recent updates and patches are installed	99
BL512-8949 - Prevent shutdown without authorization	101
BL512-8869 - Configure system crypto policy to at least FUTURE	102

BL512-7387 - Enable link protection	104
BL512-0990 - Ensure volumes are encrypted	106
Services	107
Special Purpose Services	107
Time Synchronization	107
BL512-1020 - Ensure time synchronization is configured and in use	
BL512-5500 - Ensure X Window System is not installed	107
BL512-9229 - Ensure Avahi Server is not enabled	109
BL512-7333 - Ensure CUPS is not enabled	111
BL512-2222 - Ensure mail transfer agent is configured for local-only mode	113
BL512-3572 - Ensure NIS Server is not enabled	115
BL512-2458 - Ensure telnet server is not enabled	117
BL512-6968 - Ensure tftp server is not enabled	119
Service Clients	121
BL512-4680 - Ensure NIS Client is not installed	123
BL512-9589 - Ensure xinetd is not installed	123
	124
Network Configuration	126
Network Parameters (Host Only)	126
BL512-2528 - Ensure IP forwarding is disabled	126
BL512-4639 - Ensure packet redirect sending is disabled	128
Network Parameters (Host and Router)	130
BL512-1811 - Ensure source routed packets are not accepted	130
BL512-5100 - Ensure ICMP redirects are not accepted	132
BL512-8363 - Ensure secure ICMP redirects are not accepted	134
BL512-9811 - Ensure suspicious packets are logged	136
BL512-9068 - Ensure broadcast ICMP requests are ignored	138
BL512-6421 - Ensure bogus ICMP responses are ignored	140
BL512-3714 - Ensure Reverse Path Filtering is enabled	142
BL512-4457 - Ensure TCP SYN Cookies is enabled	144
IPv6	146
BL512-3212 - Ensure IPv6 router advertisements are not accepted	146
BL512-8891 - Ensure IPv6 is disabled	148
Firewall Configuration	150
BL512-2029 - Ensure firewall system is installed and enabled	150
BL512-8373 - Ensure loopback traffic is restricted to the loopback interface	153
BL512-0996 - Ensure firewall rules are permanent	155
BL512-4800 - Ensure default deny firewall policy is active	158
BL512-1120 - Disable Bluetooth	159
Logging and Auditing	161
Configure System Accounting (auditd)	161
Configure Data Retention	161
BL512-4017 - Ensure audit log storage size is configured	
	162

BL512-9036 - Ensure at least notice mail is sent to an active mail account when audit log storage is full	164
BL512-8755 - Ensure audit logs are not automatically deleted	166
BL512-3171 - Ensure auditd service is installed and enabled	167
BL512-3000 - Ensure auditing for processes that start prior to auditd is enabled	169
BL512-4188 - Ensure events that modify date and time information are collected	170
BL512-2129 - Ensure events that modify user/group information are collected	172
BL512-3300 - Ensure events that modify the system's network environment are collected	174
BL512-3122 - Ensure events that modify the system's Mandatory Access Controls are collected	176
BL512-9024 - Ensure login and logout events are collected	178
BL512-3329 - Ensure session initiation information is collected	179
BL512-6000 - Ensure discretionary access control permission modification events are collected	181
BL512-8834 - Ensure use of privileged commands is collected	183
BL512-6052 - Ensure successful file system mounts are collected	185
BL512-2122 - Ensure changes to system administration scope (sudoers) is collected	187
BL512-8216 - Ensure system administrator actions (sudolog) are collected	189
BL512-3376 - Ensure kernel module loading and unloading is collected	191
BL512-0995 - Ensure audit_backlog_limit is sufficient	193
Configure Logging	195
BL512-9045 - Ensure logging system is installed	195
BL512-4269 - Ensure permissions on all logfiles are configured	197
Configure rsyslog	199
BL512-5686 - Ensure logging system is enabled	199
BL512-9918 - Ensure logging is configured	200
BL512-1878 - Ensure log file default file permissions are configured	202
BL512-4792 - Ensure remote logging messages are only accepted on designated log hosts	203
Configure journald	205
BL512-5158 - Ensure journald is configured to send logs to syslog logging service	205
BL512-8372 - Ensure logrotate is configured	206
Access, Authentication and Authorization	208
Configure cron	208
BL512-4700 - Ensure cron daemon is enabled	209
BL512-2788 - Ensure permissions on /etc/crontab are configured	211
BL512-3881 - Ensure permissions on /etc/cron.hourly are configured	213
BL512-1566 - Ensure permissions on /etc/cron.daily are configured	

Released: 2020-08-07

BL512-2883 - Ensure permissions on /etc/cron.weekly are configured	215
BL512-2025 - Ensure permissions on /etc/cron.monthly are configured	217
BL512-8787 - Ensure permissions on /etc/cron.d are configured	219
BL512-8275 - Ensure at/cron is restricted to authorized users	221
SSH Server Configuration	223
BL512-9189 - Ensure permissions on /etc/ssh/sshd_config are configured	223
BL512-8997 - Ensure SSH LogLevel is set to INFO	225
BL512-5115 - Ensure SSH X11 forwarding is disabled	226
BL512-6573 - Ensure SSH MaxAuthTries is set to 6 or less	227
BL512-7248 - Ensure SSH IgnoreRhosts is enabled	228
BL512-3226 - Ensure SSH HostbasedAuthentication is disabled	229
BL512-3262 - Ensure SSH root login is disabled	230
BL512-9831 - Ensure SSH PermitEmptyPasswords is disabled	232
BL512-9789 - Ensure SSH PermitUserEnvironment is disabled	233
BL512-4854 - Ensure SSH Idle Timeout Interval is configured	234
BL512-8070 - Ensure SSH LoginGraceTime is set to one minute or less	236
BL512-1400 - Ensure permissions on SSH public host key files are configured	237
BL512-2792 - Ensure permissions on SSH private host key files are configured	239
BL512-4319 - Ensure SSH PAM is enabled	241
BL512-8127 - Ensure SSH AllowTcpForwarding is disabled	242
BL512-6295 - Ensure SSH MaxStartups is configured	244
BL512-5539 - Ensure SSH MaxSessions is set to 4 or less	246
BL512-0801 - Secure SSH login	248
BL512-0994 - Ensure system-wide crypto policy is not over-written	250
Configure PAM	251
BL512-4831 - Ensure password creation requirements are configured	251
BL512-8617 - Ensure lockout for failed password attempts is configured	254
BL512-1111 - Ensure password reuse is limited	256
BL512-2991 - Ensure password hashing algorithm is SHA-512	258
User Accounts and Environment	260
Set Shadow Password Suite Parameters	260
BL512-1997 - Ensure password expiration is 180 days or less	260
BL512-9681 - Ensure minimum days between password changes is 1 or more	262
BL512-9200 - Ensure password expiration warning days is 7 or more	264
BL512-1429 - Ensure inactive password lock is 30 days or less	266
BL512-3616 - Ensure all users last password change date is in the past	268
BL512-4279 - Ensure system user accounts are non-login	269
BL512-4613 - Ensure default group for the root account is GID 0	271
BL512-1755 - Ensure default user umask is 027 or more restrictive	272
BL512-6213 - Ensure default user shell timeout is 900 seconds or less	274
Configure authselect	274
BL512-0993 - Create custom authselect profile	275

BL512-0992 - Select default authselect profile for user log in	275
BL512-0991 - Ensure authselect includes with-faillock	277
BL512-8910 - Ensure root login is restricted to system console	279
BL512-8911 - Ensure access to the su command is restricted	280
BL512-2718 - Restrict sudo to dedicated users	281
BL512-5593 - Automatic logon must not be enabled	283
BL512-8083 - Password-protected screensavers	286
	287
System Maintenance	288
System File Permissions	288
BL512-6200 - Audit system file permissions	288
BL512-2492 - Ensure permissions on /etc/passwd are configured	290
BL512-1728 - Ensure permissions on /etc/shadow are configured	292
BL512-4776 - Ensure permissions on /etc/group are configured	294
BL512-3770 - Ensure permissions on /etc/gshadow are configured	295
BL512-2600 - Ensure permissions on /etc/passwd- are configured	297
BL512-4016 - Ensure permissions on /etc/shadow- are configured	299
BL512-2070 - Ensure permissions on /etc/group- are configured	301
BL512-1476 - Ensure permissions on /etc/gshadow- are configured	303
BL512-9732 - Ensure no world writable files exist	305
BL512-7749 - Ensure no unowned files or directories exist	306
BL512-4346 - Ensure no ungrouped files or directories exist	308
BL512-3093 - Audit SUID executables	310
BL512-2294 - Audit SGID executables	312
User and Group Settings	314
BL512-4722 - Ensure password fields are not empty	314
BL512-5671 - Ensure no legacy "+" entries exist in /etc/passwd	316
BL512-2810 - Ensure no legacy "+" entries exist in /etc/shadow	317
BL512-2361 - Ensure no legacy "+" entries exist in /etc/group	318
BL512-3582 - Ensure root is the only UID 0 account	319
BL512-3597 - Ensure root PATH Integrity	320
BL512-9227 - Ensure all users' home directories exist	322
BL512-3452 - Ensure users' home directories permissions are 750 or more restrictive	324
BL512-4388 - Ensure users own their home directories	326
BL512-9700 - Ensure users' dot files are not group or world writable	328
BL512-4619 - Ensure no users have .forward files	330
BL512-5819 - Ensure no users have .netrc files	332
BL512-1498 - Ensure users' .netrc Files are not group or world accessible	334
BL512-4051 - Ensure no users have .rhosts files	336
BL512-8019 - Ensure all groups in /etc/passwd exist in /etc/group	338
BL512-3100 - Ensure no duplicate UIDs exist	340
BL512-1741 - Ensure no duplicate GIDs exist	342
BL512-3259 - Ensure no duplicate user names exist	344
BL512-4027 - Ensure no duplicate group names exist	346
Definitions	348

Glossary	349
References	350

Introduction

Objectives

The objective of this document is to define the rules which provide a secure configuration, increase the overall security level, and reduce the attack surface and vulnerability exposure of platforms, systems and applications.

The Security Measure Plan for Red Hat Enterprise Linux 8 is an *Information Security Baseline* that is part of the *Siemens Information Security Policy Framework* [1].

Scope and Applicability

This Security Measure Plan sets the mandatory hardening rules for Red Hat Enterprise Linux systems. In particular, it is limited to the following versions:

- Red Hat Enterprise Linux 8 systems running on x64 platforms.

The focus of this *Security Measure Plan* is primarily on server systems, i.e., systems providing one or more services, but without direct graphical user interaction. For client purposes, dedicated notes or exemptions are stated in the appropriate rules where mandatory.

The *Security Measure Plan* is binding for all units of Siemens AG and applies to Siemens' Affiliated Companies in accordance with Siemens Circular No. 105 "Implementation of Siemens-internal regulations in Affiliated Companies" [2], whereas separate agreements apply to listed Strategic Companies.

The *Security Measure Plan* is based on the Center of Internet Security (CIS) benchmarks

- CIS Red Hat Enterprise Linux 8 Benchmark, v1.0.0 - 12-28-2017,
- CIS Distribution Independent Linux Benchmark, v2.0.0 - 09-30-2019,

as well as it contains security rules from the Siemens *Security Measure Plan for UNIX and Linux Operating Systems, version 3.7*, which are not covered by the CIS benchmarks. Divergent rules from the CIS benchmarks have been adapted to the needs of Siemens. You can find the source of the information in the *Cross-references* section as well as in the *Version History* which additionally lists substantial changes to the source.

Although the CIS benchmark uses the term *Recommendation* in some rules, the rule itself remains mandatory.

Notes:

- The rules in this document were tested against Red Hat Enterprise Linux 8.0 (Ootpa).
- The guidance within broadly assumes that operations are being performed as the root user. Non-root users may not be able to access certain areas of the system, especially after remediation has been performed. It is advisable to verify root users path integrity and the integrity of any programs being run prior to execution of commands and scripts included in this baseline.

System Users and Interactive Users

In common Linux distributions, user/group identifiers are differentiated for system users, e.g., `bin` or `systemd-*`, and interactive users, e.g., user identifiers used by humans. By convention, system users are assigned a UID between `SYS_UID_MIN` and `SYS_UID_MAX` as defined in `/etc/login.defs`, typically between 100 or 200 and 999 (inclusively).

Additionally, some applications, or services use dedicated user identifiers for executing binaries and providing their operations, e.g., the user `www-data` for the Apache HTTPd or Nginx webserver. For vendor provided applications and services, the appropriate UIDs are pre-defined by the vendor to assure the same identifiers on different systems and across re-installation of the underlying operating system.

Third-party applications and services not necessarily adhere to given conventions and use manually defined UIDs of their choice to achieve the same intention, i.e., same UIDs on different systems and across re-installations.

Therefore, throughout this *Security Measure Plan*, the following two user categories are used:

- *System Users*: user identifiers for non-interactively used accounts for operating system internal operations, applications or services; this includes both: vendor/distribution provided identifiers as well as identifiers created by additionally installed third-party applications or services (e.g., SAP),
- *Interactive Users*: user identifiers for interactively used accounts, e.g., by humans or applications/services providing user interaction capabilities for the underlying system (e.g., management front ends such as Cockpit/Webmin providing login capabilities to end-users).

Roles and Responsibilities

Throughout this document, the following roles are used to assign responsibilities for the implementation of the rules:

- [Asset Manager](#).

If a system is managed by an end user (e.g., owner of an unmanaged client *[uDWP]*) the end user becomes the [Asset Manager](#) of this system and must implement the rules accordingly.

Information Security Policy Framework

All Information Security rules and regulations at Siemens are documented and further detailed in the Information Security Policy Framework. It lays down the roles and responsibilities, and the set of rules and practices that regulate how Siemens and its affiliated companies protect the company information and business processes.

Details regarding the Policy Framework can be found on the [Cybersecurity Governance Website](#).

Readability

The rules in this document are structured as follows:

- **Header** Each rule starts with a header containing the following information:
 - **Rule ID**: The left-hand side of the header displays the unique identifier of the rule to be used for referencing the rule from other documents. The identifier *BLxxx-yyy* is divided in two parts, of which the first part *BLxxx* represents the document identifier, and the second part *yyy* constitutes a unique rule identifier within the document.
 - **Target Audience**: Directly under the Rule ID, one or more roles (as defined in the Siemens

Information Security Framework) are displayed. These roles are responsible for implementing the rule.

- **EVAL flag and date:** If a rule is under evaluation, an EVAL flag and the end date of the evaluation period is displayed to the right of the Rule ID. The evaluation period shall be used to:

- Communicate the new version of the Security Measure Plan to the relevant teams,
- Identify the rules applicable to your area of responsibility,
- Evaluate and plan all necessary changes to the contractual agreements with involved Service providers (e.g., SLAs, contract changes),
- Plan and define a strategy to implement the rules (e.g., identify possible issues, allocate proper resources),
- Update all related existing documents, processes, and procedures,
- Deploy all necessary changes to all affected systems within your area of responsibility.

The rule will become binding after the end of the evaluation period. An expired EVAL flag will only be removed from the rule once an update to the document is available.

- **ACP Level:** The **ACP** level is indicated on the right-hand side of the header; the rule is applicable to those systems whose **ACP** rating falls into levels as displayed in the rule header. The semantics is as follows: if at least one of the **ACP** levels *Confidentiality* (C), *Integrity* (I), or *Availability* (A) of a system match with the **ACP** level displayed in the rule's header, then the rule must be implemented for the system in question. In case of conflicting rules, the rule with the higher **ACP** rating shall be implemented.
- **Rule:** This Section describes the essence of the rule and is to be considered as normative *binding part of the rule*.
- **Additional normative sections (apart from 'Rule' Section of the header) :**
 - **Exemption (if applicable):** This Section indicates under which circumstances a rule may not apply. If the conditions of the exemption are met, no Information Security exception for this rule deviation is required. Each exemption has a relative id, e.g. E01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:E01.
- **Informative Sections:**
 - **Description:** The description provides information which helps the readers to understand the rule.
 - **Rationale:** This Section provides information about the rationale behind the rule. It should, for example, help Asset Managers to evaluate requests for rule exceptions.
 - **Implementation Example:** This Section provides descriptions and examples on how to implement the rule. Please note that this is only an example on how to implement, the demand stated in the Rule Section may also be implemented by other means. Each implementation has a relative id, e.g. I01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:I01.
 - **Check Example (optional):** This Section provides descriptions and examples on how to check the rule implementation. Please note that this is only an example on how to check the implementation. Each check has a relative id, e.g., C01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:C01.
 - **Cross references (optional):** This Section provides cross references to other rules (inside or outside the Siemens Information Security Framework). Cross references may, for example, inform about the rules the rule in question is based upon.
- **Additional Metadata**
 - **Version History:** This Section provides version history information of the rule: In a PDF export, only the latest entry is shown, contrary to the **SFeRA** website which holds the

complete version history.

Initial Setup

Items in this section are advised for all systems, but may require additional preparation after the initial setup of the system.

Physical Security and secure boot settings

BL512-1000

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Install a BIOS/UEFI setup password

Rule Set a password for accessing BIOS/UEFI setup.

Note: The BIOS/UEFI password to access the setup is exempt from the password change requirements of the Specific Information Security Policy: Access Control [Rule ID: 09.4.3-04](#).

E01 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities such as cloud instances in AWS / Azure or with only virtualized, emulated BIOS/UEFI such as virtual machines.

Description

The BIOS/UEFI setup contains some settings that are security relevant, e.g. boot sequence, boot password, wake-on LAN, system time, etc. Changes to these settings should only be made by the administrator of the system.

This can be achieved by securing physical access to the system, securing management networks or – depending on the system – by setting a BIOS/UEFI access password.

Rationale

Attackers with physical access to a host can change settings in the BIOS which could affect the confidentiality, integrity and availability of the host, if the BIOS is not properly protected with an adequate password.

Empty or default BIOS passwords must be changed, or a local attacker could access the BIOS settings easily. Default BIOS passwords for various vendors are available on the Internet.

I01 - Implementation

The implementation depends on the specific BIOS/UEFI version of the particular system. For details on BIOS/UEFI settings please refer to the manual of the computer or mainboard.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.1.1-07](#)

[Based on Siemens Information Security Policy Framework Rule 09.4.3-04](#)

Based on superseded measure M680620

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-3200

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Configure boot sequence to primary hard disk first

Rule

1. It must be ensured that the boot sequence is not adjustable to allow boot from third party mediums (e.g., USB sticks).
2. Adjust the boot sequence of the computer so that the system boots from your local hard disk first.
3. In the BIOS/UEFI, the shortcut (depending on vendor e.g., by pressing F12) for one-time selection of boot medium must be disabled.

E01 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities such as cloud instances in AWS / Azure or with only virtualized, emulated BIOS/UEFI such as virtual machines.

Description

Only authorized personnel are allowed to change the boot sequence, or the host can be booted from an external interface which can introduce security issues on the host.

Rationale

In most cases, the security settings of the operating system (OS) can be easily bypassed by starting the computer with a second operating system. Most importantly, it is not possible to control access to files on a system when a second OS is running.

Attackers could also possibly load a compromised image or operating system onto the host.

I01 - Implementation

The implementation depends on the specific BIOS/UEFI firmware of the particular computer system. For details on BIOS/UEFI settings please refer to the manual of the computer system or mainboard.

Crossreferences

Based on superseded measure M201280

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Modified exemption 01 in alignment with rule BL512-1000.

BL512-8962

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Disable Built-in Remote Management Interface

Rule

Ensure that existing remote management interfaces are either disabled or not connected to any network.

E01 - Server which require a Built-in Remote Management Interface

This rule is not mandatory, if a remote management interface to the server is required imperatively. In such a case the remote management interface must be secured by following these generic rules:

- Remote management interfaces must only be connected to a separated, isolated management network (at least a separate VLAN). Especially, the interface must never be directly reachable from the Siemens Intranet.
- Passwords for accounts on the remote management interface must follow the Siemens password policy for Administrators. Especially, replace well-known or default passwords.
- If the remote management interface offers the possibilities of security auditing and sending security events to a SIEM, then logging must be additionally configured.
Minimal monitoring encompasses checking if reboots and successful connections to the system match authorized actions taken by administrators, and examining failed login attempts (e.g., unusual sources or number of failed attempts).
- Always apply the manufacturer's up-to-date security patches for the firmware of the remote management interface.
- Make sure that only secured protocols are allowed for access. Protocols that use plain text transmission of passwords like telnet, snmp, http forms etc. must be disabled.

Description

Modern server systems are often equipped with a built-in remote management interface. This interface can typically be used to access (e.g., view screen) and manage (e.g., restart, boot from external media, change configuration settings, monitor status of parameters) the system without the need for the main operating system to be running. While this can be very useful for maintenance, these interfaces can allow an attacker to easily take over the system. Therefore, such interfaces have to be sufficiently secured.

Rationale

Remote management interfaces which are not protected can be used by unauthorized personnel to change security settings on an OS, read and modify data, reboot the host, and wipe all data on a disk.

Vendors use many different names for these interfaces, including Intel Active Management Technology (AMT) web management interface, Integrated Remote Management Controller (iRMC – Fujitsu), Integrated Dell Remote Access Controller (iDRAC), HP Integrated Lights Out (iLO), IBM Integrated Management Module etc. More generic names are Server Management Board or Intelligent Platform Management Interface (IPMI).

These interfaces are implemented as embedded systems with the operating system, web server, user administration and alarm management etc. and are operational even when the server system itself is in standby mode. Communication is carried out via a LAN connection, which can be shared with the server system or used exclusively for system management.

Such built-in remote management interfaces typically come with default passwords for the main administrative user account. There is a high risk that an attacker who has access to the Siemens Intranet can easily gain full control over a server if default security configuration has not been adjusted.

I01 - Implementation

The implementation depends on the specific remote management interface of the particular system and the environment. For further details, please refer to the corresponding vendor documentation.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 13.1.3-06](#)

Based on superseded measure M700351

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Minor rephrasing of rule (added 'existing' ... interfaces) and exemption.

BL512-4919

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Disable biometric authentication devices

Rule

Authentication in the Siemens corporate environment must not rely solely on biometric authentication devices. Therefore, any existing biometric devices must be disabled. Instead, Siemens PKI based smart cards are the preferred mechanism for strong authentication. However, biometric devices that complement the use of smart cards are permitted, e.g., a fingerprint sensor on a smart card (reader) for granting access to the smart card.

Description

Some hardware vendors offer authentication with fingerprint sensors or face recognition technology.

Rationale

Biometric authentication has many known deficiencies and must not be used as the sole method of authentication.

Many published methods are known to bypass biometric authentication. Biometric authentication might well be suitable for home applications, but the potential risks prohibit using biometric authentication as the sole authentication method in a corporate environment.

I01 - Implementation

Do not install or use any biometric devices that do not complement smart card authentication.

If PAM is used for authentication, ensure that biometric modules (e.g., pam-fprint, pam-bioapi) are not used, i.e. disable or remove those modules in any configuration file in `/etc/pam.d`.

Crossreferences

Based on superseded measure M950630

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased to 'existing' biometric devices.

BL512-2876

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on bootloader config are configured

Rule Ensure permissions on bootloader config are configured:

- All involved grub configuration files (e.g., /etc/grub2/grub.cfg, /etc/grub2/user.cfg, /boot/grub2/grub.cfg, /boot/grub2/user.cfg) must be owned and group-owned by root,
- Permissions on all involved grub configuration files (e.g., /etc/grub2/grub.cfg, /etc/grub2/user.cfg, /boot/grub2/grub.cfg, /boot/grub2/user.cfg) must be set to 0644 or more restrictive.

Description

The grub configuration file contains information on boot settings and passwords for unlocking boot options. The grub configuration is usually located at /boot/grub2/grub.cfg and linked as /etc/grub2.cfg. Additional settings can be found in the /boot/grub2/user.cfg file.

Rationale

Setting the permissions to read and write for root only prevents non-root users from seeing the boot parameters or changing them. Non-root users who read the boot parameters may be able to identify weaknesses in security upon boot and be able to exploit them.

I01 - Implementation Example

Run the following commands to set permissions on your grub configuration:

```
# chown root:root /boot/grub2/grub.cfg
# chmod og-wx /boot/grub2/grub.cfg
# chown root:root /boot/grub2/user.cfg
# chmod og-wx /boot/grub2/user.cfg
```

C01 - Example Check

Run the following commands and verify Uid and Gid are both 0/root and Access does not grant write or execute permissions to group or other:

```
# stat /boot/grub2/grub.cfg
Access: (0644/-rw-r--r--)  Uid: (   0/   root)   Gid: (   0/   root)
# stat /boot/grub2/user.cfg
Access: (0644/-rw-r--r--)  Uid: (   0/   root)   Gid: (   0/   root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.5.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.4.1

Based on superseded measure M112800

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 644 to be vendor default compliant.

BL512-9180

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure bootloader password is set

Rule Ensure bootloader password is set to prevent configuration changes at boot time.

Note: The bootloader password is exempt from the password change requirements of the *Specific Information Security Policy: Access Control* [Rule ID: 09.4.3-04](#).

E01 - Exemption

This rule is not mandatory for systems with no pre-boot access to the bootloader such as cloud instances in AWS / Azure.

Description

Setting the boot loader password will require that anyone booting the system must enter a password before being able to set command line boot parameters

Rationale

Requiring a boot password upon execution of the boot loader will prevent an unauthorized user from entering boot parameters or changing the boot partition. This prevents users from weakening security (e.g., turning off SELinux at boot time).

I01 - Implementation Example

Create an encrypted password with `grub2-setpassword`:

```
# grub2-setpassword
Enter password: <password>
Confirm password: <password>
```

Run the following command to update the `grub2` configuration:

```
# grub2-mkconfig -o /boot/grub2/grub.cfg
```

Impact:

If password protection is enabled, only the designated superuser can edit a Grub 2 menu item by pressing "e" or access the GRUB 2 command line by pressing "c"

If GRUB 2 is set up to boot automatically to a password-protected menu entry the user has no option to back out of the password prompt to select another menu entry. Holding the SHIFT key will not display the menu in this case. The user must enter the correct username and password. If unable, the configuration files will have to be edited via the LiveCD or other means to fix the problem

You can add --unrestricted to the menu entries to allow the system to boot without entering a password. Password will still be required to edit menu items.

C01 - Example Check

Run the following commands and verify, GRUB2_PASSWORD line is present and contains a value:

```
# grep "^GRUB2_PASSWORD" /boot/grub2/grub.cfg /boot/grub2/user.cfg
GRUB2_PASSWORD=
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.5.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.4.2

Based on superseded measure M112800

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings. Added password change requirement note.

BL512-3551

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure authentication required for single user mode

Rule

Ensure authentication is required for booting into single user mode.

Description

Single user mode or rescue mode is used for recovery when the system detects an issue during boot or by manual selection from the bootloader.

Rationale

Requiring authentication in single user mode or rescue mode prevents an unauthorized user from rebooting the system into single user to gain root privileges without credentials.

I01 - Implementation Example

Edit `/usr/lib/systemd/system/rescue.service` and add/modify the following line:

```
ExecStart=-/usr/lib/systemd/systemd-sulogin-shell rescue
```

Edit `/usr/lib/systemd/system/emergency.service` and add/modify the following line:

```
ExecStart=-/usr/lib/systemd/systemd-sulogin-shell emergency
```

C01 - Example Check

Run the following commands and verify that `/sbin/sulogin` or `/usr/sbin/sulogin` is used as shown:

```
# grep /systemd-sulogin-shell /usr/lib/systemd/system/rescue.service
ExecStart=-/usr/lib/systemd/systemd-sulogin-shell rescue
```

```
# grep /systemd-sulogin-shell /usr/lib/systemd/system/emergency.service
ExecStart=-/usr/lib/systemd/systemd-sulogin-shell emergency
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.5.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.4.3

Based on superseded measure M200587

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, changed implementation and check to systemd from CIS-RHEL-8.

Filesystem Configuration

Directories that are used for system-wide functionality can be further protected by placing them on separate partitions or using dedicated filesystems for their purpose. This provides protection for resource exhaustion and enables the use of mounting options that are applicable to the directory's intended use. Users' data can be stored on separate partitions and have stricter mount options. A user partition is a filesystem that has been established for use by the users and does not contain software for system operations.

The recommendations in this section are easier to perform during initial system installation. If the system is already installed, it is recommended that a full backup is performed before repartitioning the system.

Note: If you are repartitioning a system that has already been installed, make sure the data has been copied over to the new partition, unmount it and then remove the data from the directory that was in the old partition. Otherwise it will still consume space in the old partition, that will be masked when the new filesystem is mounted. For example, if a system is in single-user mode with no filesystems mounted and the administrator adds a lot of data to the `/tmp` directory, this data will still consume space in `/` once the `/tmp` filesystem is mounted unless it is removed first.

BL512-4358

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure /tmp is configured to use tmpfs or separate partition

Rule

Ensure `/tmp` is configured to use tmpfs or separate partition.

Description

The `/tmp` directory is a world-writable directory used for temporary storage by all users and applications and therefore must have specific security options enabled.

Rationale

Since the `/tmp` directory is required to be world-writable, there is a risk of resource exhaustion, if it is not bound to a separate partition or configured to use tmpfs. In addition, making `/tmp` its own filesystem allows an administrator to set specific filesystem options, such as `noexec` flag on the mount, making `/tmp` useless for an attacker to install executable code. It would also prevent an attacker from establishing a hardlink to a system `setuid` program and wait for it to be updated: Once the program was updated, the hardlink would be broken and the attacker would have his own copy of the program. If the program happened to have a security vulnerability, the attacker could continue to exploit the known flaw.

I01 - Implementation Example

For using tmpfs for `/tmp`, run the following commands to enable systemd `/tmp` mounting:

```
# systemctl unmask tmp.mount
# systemctl enable tmp.mount
```

Edit `/etc/systemd/system/local-fs.target.wants/tmp.mount` to configure the `/tmp` mount options:

```
[Mount]
What=tmpfs
Where=/tmp
Type=tmpfs
Options=mode=1777,strictatime,noexec,nodev,nosuid
```

Note: When using the `systemd` unit for `tmp.mount`, existing entries in `/etc/fstab` must be removed.

C01 - Example Check

If using `tmpfs`, run the following command and verify output shows `/tmp` is mounted using `tmpfs`:

```
# mount | grep -E 'tmpfs on /tmp type tmpfs\s'
tmpfs on /tmp type tmpfs (rw,nosuid,nodev,seclabel)
```

If using dedicated partition, run the following command and verify output shows `/tmp` is mounted on a dedicated partition:

```
# mount | grep -E '\s/tmp\s'
/dev/xvdgl on /var type xfs (rw,relatime,data=ordered)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Reworked according feedback from review meeting to also allow separate partition. Added note for `/etc/fstab` entry removal.

BL512-3700

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure nodev option set on /tmp partition

Rule

Ensure nodev option set on /tmp filesystem mount point.

Description

The `nodev` mount option ensures that character or block special devices are not interpreted on the filesystem.

Rationale

Since the `/tmp` filesystem is not intended to support devices, set this option to ensure that users cannot attempt to create block or character special devices in `/tmp`.

I01 - Implementation Example

Edit `/etc/systemd/system/local-fs.target.wants/tmp.mount` to add `nodev` to the `/tmp` mount options:

```
[Mount]
Options=mode=1777,strictatime,noexec,nodev,nosuid
```

Run the following command to remount `/tmp`:

```
# mount -o remount,nodev /tmp
```

C01 - Example Check

Run the following command and verify that nothing is returned:

```
# mount | grep -E '\s/tmp\s' | grep -v nodev
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3432

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure nosuid option set on /tmp partition

Rule

Ensure nosuid option set on /tmp filesystem mount point.

Description

The `nosuid` mount option ensures that set-user-identifier or set-group-identifier executable bits take no effect.

Rationale

Since the `/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot create `setuid` files in `/tmp`.

I01 - Implementation Example

Edit `/etc/systemd/system/local-fs.target.wants/tmp.mount` to add `nosuid` to the `/tmp` mount options:

```
[Mount]
Options=mode=1777,strictatime,noexec,nodev,nosuid
```

Run the following command to remount `/tmp`:

```
# mount -o remount,nosuid /tmp
```

C01 - Example Check

Run the following command and verify that nothing is returned:

```
# mount | grep -E '\s/tmp\s' | grep -v nosuid
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-7722

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure noexec option set on /tmp partition

Rule

Ensure noexec option set on /tmp filesystem mount point.

Description

The `noexec` mount option ensures that direct execution is prohibited for files in this filesystem.

Rationale

Since the `/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot run executable binaries from `/tmp`.

I01 - Implementation Example

Edit `/etc/systemd/system/local-fs.target.wants/tmp.mount` to add `noexec` to the `/tmp` mount options:

```
[Mount]
Options=mode=1777,strictatime,noexec,nodev,nosuid
```

Run the following command to remount `/tmp`:

```
# mount -o remount,noexec /tmp
```

C01 - Example Check

Run the following command and verify that nothing is returned:

```
# mount | grep -E '\s/tmp\s' | grep -v noexec
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-7719

EVAL until 2020-12-31

Asset Manager

C	I	A
23	23	23

Ensure /var/tmp is configured

Rule Ensure /var/tmp is configured using one of the following options:

- Separate partition is used for /var/tmp.
- If no dedicated partition is possible, the sticky bit must be set on /var/tmp.

Description

The /var/tmp directory is a world-writable directory used for temporary storage by all users and some applications, but preserved across system reboots. As this directory is not cleared on reboot, in first place the creator of files/directories is responsible for clearing its temporary files.

Rationale

Since the /var/tmp directory is intended to be world-writable, there is a risk of resource exhaustion if it is not bound to a separate partition. In addition, making /var/tmp its own file system allows an administrator to set the noexec option on the mount, making /var/tmp useless for an attacker to install executable code. It would also prevent an attacker from establishing a hardlink to a system setuid program and wait for it to be updated. Once the program was updated, the hardlink would be broken and the attacker would have his own copy of the program. If the program happened to have a security vulnerability, the attacker could continue to exploit the known flaw.

I01 - Implementation Example

For new installations, during installation create a custom partition setup and specify a separate partition for /var/tmp.

For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate.

C01 - Example Check

Run the following command and verify output shows /var/tmp is mounted on a dedicated partition:

```
# mount | grep /var/tmp  
/dev/xvdgl on /var/tmp type xfs (rw,nosuid,nodev,noexec,relatime)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added second option without dedicated partition using sticky bit.

BL512-8758

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure nodev option set on /var/tmp

Rule

Ensure nodev option set on /var/tmp partition or filesystem mount point.

E01 - Exemption

This rule is only mandatory, if rule [BL512-7719 - Ensure /var/tmp is configured](#) is applied using dedicated partition for /var/tmp.

Description

The `nodev` mount option ensures that character or block special devices are not interpreted on the filesystem.

Rationale

Since the `/var/tmp` filesystem is not intended to support devices, set this option to ensure that users cannot attempt to create block or character special devices in `/var/tmp`.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/var/tmp` partition. See the `fstab(5)` manual page for more information.

Run the following command to remount `/var/tmp`:

```
# mount -o remount,nodev /var/tmp
```

C01 - Example Check

Verify that the `nodev` option is set.

Run the following command and verify that nothing is returned:

```
# mount | grep -E '\s/var/tmp\s' | grep -v nodev
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.8

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption according feedback from review meetings.

BL512-9671

EVAL until 2020-12-31

Asset Manager

C	I	A
23	23	23

Ensure nosuid option set on /var/tmp

Rule

Ensure nosuid option set on /var/tmp partition or filesystem mount point.

E01 - Exemption

This rule is only mandatory, if rule [BL512-7719 - Ensure /var/tmp is configured](#) is applied using dedicated partition for /var/tmp.

Description

The `nosuid` mount option ensures that set-user-identifier or set-group-identifier executable bits take no effect.

Rationale

Since the `/var/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot create `setuid` files in `/var/tmp`.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/var/tmp` partition. See the `fstab(5)` manual page for more information.

Run the following command to remount `/var/tmp`:

```
# mount -o remount,nosuid /var/tmp
```

C01 - Example Check

If a `/var/tmp` partition exists run the following command and verify that the `nosuid` option is set on `/var/tmp`.

```
# mount | grep -E '\s/var/tmp\s' | grep -v nosuid
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.9

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption according feedback from review meetings.

BL512-9900

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure noexec option set on /var/tmp

Rule

Ensure noexec option set on /var/tmp partition or filesystem mount point.

E01 - Exemption

This rule is only mandatory, if rule [BL512-7719 - Ensure /var/tmp is configured](#) is applied using dedicated partition for /var/tmp.

Description

The `noexec` mount option ensures that direct execution is prohibited for files in this filesystem.

Rationale

Since the `/var/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot run executable binaries from `/var/tmp`.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/var/tmp` partition. See the `fstab(5)` manual page for more information.

Run the following command to remount `/var/tmp`:

```
# mount -o remount,noexec /var/tmp
```

C01 - Example Check

Run the following command and verify that nothing is returned:

```
# mount | grep -E '\s/var/tmp\s' | grep -v noexec
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.10

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.10

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption according feedback from review meetings.

BL512-9228

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure separate partition is used for /var/log

Rule Ensure separate partition is used for /var/log.

E01 - Exemption

This rule is not mandatory, if all logs and audit logs are sent to a central, remote logging server.

Description

The `/var/log` directory is used by system services to store log data .

Rationale

There are two important reasons to ensure that system logs are stored on a separate partition: protection against resource exhaustion (since logs can grow quite large) and protection of audit data.

I01 - Implementation Example

For new installations, during installation create a custom partition setup and specify a separate partition for `/var/log` .

For systems that were previously installed, create a new partition and configure `/etc/fstab` as appropriate.

C01 - Example Check

Run the following command and verify output shows `/var/log` is mounted on dedicated partition:

```
# mount | grep /var/log  
/dev/xvhd1 on /var/log type xfs (rw,relatime,data=ordered)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.11

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.11

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-9270

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure separate partition is used for main user home directory

Rule Ensure separate partition is used for the main user home directory, usually /home.

Note: If another directory is used as top level home directory, such as /export/home, this rule applies to that folder.

E01 - Exemption

This rule is not mandatory, if no local users are intended for the system's operational usage beside for logging in, i.e. not for user specific storage or operation.

E02 - Exemption

This rule is not mandatory, if no local storage/partition is used for user home directories, e.g., when using mounted network location for home directories.

Description

The /home directory is used to support disk storage needs of local users.

Rationale

If the system is intended to support local users, create a separate partition for the /home directory to protect against resource exhaustion and restrict the type of files that can be stored under /home .

I01 - Implementation Example

For new installations, during installation create a custom partition setup and specify a separate partition for /home .

For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate.

C01 - Example Check

Run the following command and verify output shows /home is mounted on dedicated partition:

```
# mount | grep /home  
/dev/xvdf1 on /home type xfs (rw,nodev,relatime,data=ordered)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.13

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.13

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 02 for non-local home directories.

BL512-9960

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure nodev option set on /home partition

Rule Ensure nodev option set on /home partition.

E01 - Exemption

This rule is only mandatory, if rule [BL512-9270 - Ensure separate partition is used for main user home directory](#) is applied.

Description

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale

Since the user partitions are not intended to support devices, set this option to ensure that users cannot attempt to create block or character special devices.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/home` partition. See the `fstab(5)` manual page for more information.

```
# mount -o remount,nodev /home
```

C01 - Example Check

If a dedicated `/home` partition is used run the following command and verify that the `nodev` option is set on `/home`.

```
# mount | grep -E '\s/home\s' | grep -v nodev
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.14

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.14

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added the Note in the Rule section as an exemption.

BL512-4920

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure nodev option set on /dev/shm

Rule

Ensure nodev option set on /dev/shm mount point.

Description

The `nodev` mount option ensures that character or block special devices are not interpreted on the filesystem.

Rationale

Since the `/dev/shm` filesystem is not intended to support devices, set this option to ensure that users cannot attempt to create special devices in `/dev/shm` partitions.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/dev/shm` partition. If no entry exists for `/dev/shm`, create an appropriate entry using `tmpfs`. See the `fstab(5)` manual page for more information.

Run the following command to remount `/dev/shm`:

```
# mount -o remount,nodev /dev/shm
```

C01 - Example Check

Run the following command and verify that the `nodev` option is set on `/dev/shm`.

```
# mount | grep -E '\s/dev/shm\s' | grep -v nodev
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.15

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.15

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4000

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure nosuid option set on /dev/shm

Rule

Ensure nosuid option set on /dev/shm mount point.

Description

The `nosuid` mount option ensures that set-user-identifier or set-group-identifier executable bits take no effect

Rationale

Setting this option on a file system prevents users from introducing privileged programs onto the system and allowing non-root users to execute them.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/dev/shm` partition. See the `fstab(5)` manual page for more information.

Run the following command to remount `/dev/shm` :

```
# mount -o remount,nosuid /dev/shm
```

C01 - Example Check

Run the following command and verify that the `no suid` option is set on `/dev/shm`.

```
# mount | grep -E '\s/dev/shm\s' | grep -v nosuid
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.16

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.16

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2123

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure noexec option set on /dev/shm

Rule

Ensure noexec option set on /dev/shm mount point.

Description

The `noexec` mount option ensures that direct execution is prohibited for files in this filesystem.

Rationale

Setting this option on a file system prevents users from executing programs from shared memory. This deters users from introducing potentially malicious software on the system.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/dev/shm` partition. See the `fstab(5)` manual page for more information.

Run the following command to remount `/dev/shm`:

```
# mount -o remount,noexec /dev/shm
```

C01 - Example Check

Run the following command and verify that the `noexec` option is set on `/dev/shm`.

```
# mount | grep -E '\s/dev/shm\s' | grep -v noexec
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.17

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.17

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8000

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure nodev option set on removable media partitions

Rule

Ensure nodev option is set on removable media partitions.

Description

The `nodev` mount option ensures that character or block special devices are not interpreted on the filesystem.

Rationale

Removable media containing character and block special devices could be used to circumvent security controls by allowing non-root users to access sensitive device files such as `/dev/kmem` or the raw disk partitions.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) of all removable media partitions. Look for entries that have mount points that contain words such as `floppy` or `cdrom`. See the `fstab (5)` manual page for more information.

C01 - Example Check

Run the following command and verify that the `nodev` option is set on all removable media partitions.

```
# mount
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.18

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.18

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3849

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure nosuid option set on removable media partitions

Rule

Ensure nosuid option is set on removable media partitions.

Description

The `nosuid` mount option ensures that set-user-identifier or set-group-identifier executable bits take no effect.

Rationale

Setting this option on a file system prevents users from introducing privileged programs onto the system and allowing non-root users to execute them.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) of all removable media partitions. Look for entries that have mount points that contain words such as `floppy` or `cdrom`. See the `fstab(5)` manual page for more information.

C01 - Example Check

Run the following command and verify that the `nosuid` option is set on all removable media partitions.

```
# mount
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.19

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.19

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1183

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure noexec option set on removable media partitions

Rule

Ensure noexec option is set on removable media partitions.

Description

The `noexec` mount option ensures that direct execution is prohibited for files in this filesystem.

Rationale

Setting this option on a file system prevents users from executing programs from the removable media. This deters users from being able to introduce potentially malicious software on the system.

I01 - Implementation Example

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) of all removable media partitions. Look for entries that have mount points that contain words such as `floppy` or `cdrom`. See the `fstab(5)` manual page for more information.

C01 - Example Check

Run the following command and verify that the `noexec` option is set on all removable media partitions.

```
# mount
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.20

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.20

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8516

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure sticky bit is set on all world-writable directories

Rule

Ensure sticky bit is set on all world-writable directories.

Description

Setting the sticky bit on world writable directories prevents users from deleting or renaming files in that directory that are not owned by them.

Rationale

This feature prevents the ability to delete or rename files in world writable directories (such as /tmp) that are owned by another user.

I01 - Implementation Example

Run the following command to set the sticky bit on all world writable directories:

```
# df --local -P | awk '{if (NR!=1) print $6}' | xargs -I '{}' find '{}' -xdev -type d \( -perm -0002 -a ! -perm -1000 \) 2>/dev/null | xargs -I '{}' chmod a+t '{}'
```

C01 - Example Check

Run the following command to verify no world writable directories exist without the sticky bit set:

```
# df --local -P | awk '{if (NR!=1) print $6}' | xargs -I '{}' find '{}' -xdev -type d \( -perm -0002 -a ! -perm -1000 \) 2>/dev/null
```

No output should be returned.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.21

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.21

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2440

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Disable Automounting for removable media devices

Rule

Disable Automounting for removable media devices, such as USB drives or optical discs.

Description

`autofs` allows automatic mounting of devices, typically including CD/DVDs and USB drives.

Rationale

With automounting enabled anyone with physical access could attach a USB drive or disc and have its contents available in system even if they lacked permissions to mount it themselves.

I01 - Implementation Example

Run the following command to disable `autofs` :

```
# systemctl disable autofs
```

Depending on the installation scheme, the `autofs` service might not be installed at all and the shown command may return the following message:

```
Failed to disable unit: Unit file autofs.service does not exist.
```

Note: Automounting can be realized using different implementations: `autofs.service`, `udisk2.service`, dedicated mount options in `/etc/fstab`, `udev` rules and others, partly depending or referring to each other. Therefore, this implementation gives an exemplary way using the deactivation of the `autofs` service unit. If `autofs` is used, e.g., for mounting network shares, this way will result in unexpected behavior.

C01 - Example Check

Run the following command and verify result is not "enabled":

```
# systemctl is-enabled autofs  
disabled
```

Depending on the installation scheme, the `autofs` service might not be installed at all and the shown command may return the following message, also meaning compliance to this rule:

```
Failed to get unit file state for autofs.service: No such file or directory
```

Note: Automounting can be realized using different implementations: `autofs.service`, `udisk2.service`, dedicated mount options in `/etc/fstab`, `udev` rules and others, partly depending or referring to each other. If `autofs` is used, e.g., for mounting network shares, but automounting removable media devices is prevented by other means, the `autofs` service unit is allowed to be enabled, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.1.22

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.1.22

Based on superseded measure M809740

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased title to only disallow removable media automount; added notes for different techniques of implementing automounting.

Configure Software Updates

Red Hat Enterprise Linux 8 uses `dnf` to install and update software packages. Patch management procedures may vary widely between enterprises. Large enterprises may choose to install a local updates server that can be used in place of Red Hats servers, whereas a single deployment of a system may prefer to get updates directly. Updates can be performed automatically or manually, depending on the site's policy for patch management. Many large enterprises prefer to test patches on a non-production system before rolling out to production.

The requirement is to ensure that a patch management system is configured and maintained.

BL512-3717

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure gpgcheck is globally activated

Rule

Ensure gpgcheck is globally activated for all configured repositories.

E01 - Exemption

This rule is not mandatory for dedicated repositories using an external, but self-managed central repository mirror solution, which already performs integrity checks of packages from external sources in this central place.

Description

The `gpgcheck` option, found in the main section of the `/etc/yum.conf` and individual `/etc/yum/repos.d/*` files determines if an RPM package's signature is checked prior to its installation.

Rationale

It is important to ensure that an RPM's package signature is always checked prior to installation to ensure that the software is obtained from a trusted source.

I01 - Implementation Example

Edit `/etc/yum.conf` and set `gpgcheck=1` in the `[main]` section.

Edit any repository configuration files in `/etc/yum/repos.d/*` and set all instances of `gpgcheck` to 1.

C01 - Example Check

Run the following command and verify `gpgcheck` is set to 1:

```
# grep ^gpgcheck /etc/yum.conf  
gpgcheck=1
```

Run the following command and verify that all instances of `gpgcheck` returned are set to 1:

```
# grep ^gpgcheck /etc/yum.repos.d/*
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.2.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption according feedback from review meetings.

BL512-6874

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure all configured GPG keys are correctly signed by package provider or distribution vendor

Rule

Ensure all configured GPG keys are correctly signed by package provider or distribution vendor.

Description

Most packages managers implement GPG key signing to verify package integrity during installation.

Rationale

It is important to ensure that updates are obtained from a valid source to protect against spoofing that could lead to the inadvertent installation of malware on the system.

I01 - Implementation Example

Update all package manager GPG keys.

C01 - Example Check

Run the following command and verify GPG keys are configured correctly and signed officially by package provider or distribution vendor:

```
# rpm -q gpg-pubkey --qf '%{name}-%{version}-%{release} --> %{summary}\n'
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.2.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.2.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased rule according feedback from review meetings allowing distribution vendors as well.

BL512-9759

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure system is properly subscribed to Red Hat

Rule Ensure system is properly subscribed to Red Hat, either using Red Hat Subscription Manager or using centralized subscription management.

Description

Systems need to be registered with the Red Hat Subscription Manager (RHSM) to receive patch updates. This is usually configured during initial installation.

Rationale

It is important to register with the Red Hat Subscription Manager to make sure that patches are updated on a regular basis. This helps to reduce the exposure time as new vulnerabilities are discovered.

I01 - Implementation Example

Run the following command to connect to the Red Hat Subscription Manager:

```
# subscription-manager register
```

C01 - Example Check

Verify your system is connected to the Red Hat Subscription Manager.

If connected to RHSM your `system identity` must be returned from the following command:

```
# subscription-manager identity
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.2.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, opened for centralized/aggregated subscription management

BL512-3129

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Disable the rhnsd daemon

Rule

Disable the rhnsd daemon.

Description

The `rhnsd` daemon polls the Red Hat Network website for scheduled actions and, if there are, executes those actions.

Rationale

Patch management policies may require that organizations test the impact of a patch before it is deployed in a production environment. Having patches automatically deployed could have a negative impact on the environment. It is best to not allow an action by default but only after appropriate consideration has been made. It is recommended that the service be disabled unless the risk is understood and accepted or you are running your own satellite . This item is not scored because organizations may have addressed the risk.

I01 - Implementation Example

Run the following command to disable `rhnsd` :

```
# systemctl disable rhnsd
```

C01 - Example Check

Run the following command and verify that the service unit state is disabled:

```
# systemctl is-enabled rhnsd
disabled
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.2.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

Filesystem Integrity Checking

AIDE is a file integrity checking tool, similar in nature to Tripwire. While it cannot prevent intrusions, it can detect unauthorized changes to configuration files by alerting when the files are changed. Review the AIDE quick start guide and AIDE documentation before configuration.

BL512-4233

EVAL until 2020-12-31

Asset Manager

C	I	A
23	23	23

Ensure AIDE is installed and configured

Rule Ensure the Advanced Intrusion Detection Environment AIDE is installed and configured:

1. At least system and configuration directories must be included in the configuration:
 - /boot
 - /bin
 - /sbin
 - /lib
 - /lib64
 - /usr
 - /etc
2. The initial run was executed.

E01 - Exemption

Directories with high volatility and data directories can be excluded from the configuration depending on the workload and performance impact.

The reason for this exemption and the excluded directories must be documented.

Description

AIDE takes a snapshot of filesystem state including modification times, permissions, and file hashes which can then be used to compare against the current state of the filesystem to detect modifications to the system.

Rationale

By monitoring the filesystem state compromised files can be detected to prevent or limit the exposure of accidental or malicious misconfigurations or modified binaries. Regular integrity checks and periodic modification reports can also provide additional insights in case of a security incident for a forensic investigation.

I01 - Implementation Example

Run the following command to install `aide` :

```
# dnf install aide
```

Configure AIDE as appropriate for system environment. Consult the AIDE documentation for options.

Initial AIDE execution run:

```
# aide --init  
# mv /var/lib/aide/aide.db.new.gz /var/lib/aide/aide.db.gz
```

C01 - Example Check

Run the following command and verify `aide` is contained in command output:

```
# dnf list installed | grep aide  
aide.x86_64
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.4.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.3.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased rationale to focus forensic investigations according feedback from review meetings.

BL512-8250

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure filesystem integrity is regularly checked

Rule Ensure filesystem integrity is regularly checked and report is stored for potential forensic investigations:

- Interval must be once a week at minimum.

Description

Periodic checking of the filesystem integrity is needed to detect changes to the filesystem.

Rationale

Periodic file checking allows the system administrator to determine on a regular basis if critical files have been changed in an unauthorized fashion. These integrity change reports can also provide additional insights in case of a security incident for a forensic investigation.

I01 - Implementation Example

Run the following command:

```
# crontab -u root -e
```

Add the following line to the crontab:

```
0 5 * * * /usr/sbin/aide --check
```

C01 - Example Check

Run the following commands to determine if there is a `cron` job scheduled to run the aide check.

```
# crontab -u root -l | grep aide
# grep -r aide /etc/cron.* /etc/crontab
```

Ensure a cron job entry is contained in command output.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.4.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.3.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased rule and rationale to focus forensic investigations according feedback from review meetings.

Malware Protection

BL512-4165

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Install a virus scanner

Rule A virus scanner must be installed on the system according to the following rules:

1. The virus scanner must be activated at all times,
2. The virus signatures and the scanner itself must be kept up-to-date,
3. All files must be scanned "on-access".

E01 - Exemption

On systems, for which the implementation of this rule leads to *significant* availability issues or in case of losing vendor support when applying "on-access" scanning techniques (e.g., due to tainted kernel), it is allowed to:

- Scan all files "on-demand" in regular time intervals, but at least weekly.

The reason for this exemption, and the implemented time interval must be documented.

Description

Malware, viruses, ransomware and backdoors are significant problems in today's network environments. Every day, hundreds of thousands of new malware and virus instances are released and pose a threat to users via email or files downloaded from the Internet.

Rationale

Install a virus scanner and keep signatures up-to-date to protect the system against known malware, viruses and ransomware which in the worst case scenario, could lead to a system compromise.

Although most malware attacks are against Windows based systems, all networked systems can be used for distribution via common protocols and interfaces (mail, file shares, upload/download areas on FTP/HTTP servers). Moreover, there are platform independent backdoors which target systems at application level such as malicious PHP scripts or Java applications.

I01 - Implementation

It is recommended to have clearly defined responsibilities between OS operations and the application / service owner for virus scanning.

Installation

The Virus Competence Center (VCC) offers a virus scan engine for various Linux flavors. Please visit <https://vcc.siemens.com> for installation guidelines. See the section **Deep Security Agent** for Linux platforms. Make sure to check the integrity of the downloaded file **before**.

Update

All supported VCC virus scan engines are updated in a central way. This fact holds true for virus signatures as well as the actual virus scan engines. No manual task is required as all updates are triggered by VCC. For further information please refer to the VCC website at <https://vcc.siemens.com>.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.2.1-01

Based on superseded measure M250305

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Aligned exemption 01 according feedback from review.

BL512-9000

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Enable an Endpoint Detection and Response Agent

Rule

Enable an *Endpoint Detection and Response* Agent for every system (clients and servers) connected to and/or operated within the Siemens Corporate Network (SCN):

- **Default agent for all systems (which do not have specific legal, regulatory or security requirements):**
For all systems **which do not have specific legal, regulatory or security requirements** , the cloud based *CrowdStrike* agent shall be installed.
- **For systems with specific legal, regulatory or security requirements:**
For systems that have a legal, regulatory or security requirement not to have a cloud-based agent installed and where data cannot be processed by a third-party, the *Carbon Black* agent shall be installed instead of the *CrowdStrike* agent.
The approved environments in scope for the installation of the *Carbon Black* agent can be found at *Siemens-Intranet: Endpoint Detection and Response* [3].

Description

Advanced persistent threats and customized targeted malware attack toolkits are intentionally bypassing traditional signature-based antivirus solutions. *Endpoint Detection and Response* solutions supplement traditional signature-based technologies for richer behavior-based anomaly detection and visibility across endpoints. *Endpoint Detection and Response* tools offer greater visibility into endpoint data that is relevant for detecting and mitigating advanced threats, limiting sensitive data loss, and reducing the risk of devastating data breaches occurring on endpoints.

Rationale

The *Endpoint Detection and Response* (EDR) agent at Siemens allows our Cyber Defense Centers (CDC) to continuously detect threats on all Siemens endpoints (e.g., clients, servers) based on advanced threat detection capabilities and up-to-date threat intelligence. The standard solutions and concepts of the Cyber Defense Center (CDC) for threat detection & analysis on hosts (endpoints) shall be used in any endpoint connected to the Siemens Intranet. If an incident is detected in an endpoint through the EDR agent, the normal security incident handling process is followed.

I01 - Implementation

The installation instructions for the respective *Endpoint Detection and Response* Agent can be found at *Siemens-Intranet: Endpoint Detection and Response* [3], which is in the responsibility of the Cyber Defense Center (CDC).

Any questions regarding the *Endpoint Detection and Response* agents shall be sent to the Cyber Defense Center (CDC) via the email endpoint-detection.infosec@siemens.com.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.4.2-02](#)

[Based on Siemens Information Security Policy Framework Rule 12.2.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-03](#)

[Based on Siemens Information Security Policy Framework Rule 12.6.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.6.1-02](#)

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Enabling of an EDR agent has been requested with Governance Announcement GA-2018-010.

BL512-3937

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Enable the Corporate Scan Service Software Agent

Rule

Enable the *Corporate Scan Service* Agent for every system (clients and servers) connected to and/or operated within the Siemens network (SNX).

Note: To address detected vulnerabilities, the IT system must be registered correctly in the respective corporate repositories and the data must be kept up-to-date.

E01 - Stand-alone systems

This rule does not apply to stand-alone systems not connected to Siemens Intranet (SNX), where the central scanning application is not reachable.

Description

The *Vulnerability Scanning* team provides the *Corporate Scan Service* to analyze Siemens IT systems connected to the Intranet or the Internet, monitoring for known vulnerabilities. To that end, the *Corporate Scan Service* uses a local software agent on each IT system to provide better and more accurate results than a normal external network scan.

After installation, the software agent connects to the central scanning application, scans the server periodically for known vulnerabilities, and reports back the scan results.

Rationale

The *Corporate Scan Service* monitors that rules from the *Siemens Information Security Baselines* are implemented and checks if known vulnerabilities exist on the system. This is necessary to ensure that the required Siemens policy and patches are implemented to deter attackers exploiting security issues against Siemens systems and networks.

I01 - Implementation

The installation instructions for the respective *Corporate Scan Service* Agent can be found at [Siemens-Intranet: IPINSplus Home](#), which is in the responsibility of the *Vulnerability Scanning* team.

Any questions regarding the *Corporate Scan Service* software agent shall be sent to the *Vulnerability Scanning* team via the email support.ipinsplus@siemens.com.

Crossreferences

Based on superseded measure M447301

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased exemption to clarify standalone systems with SNX access.

Additional Process Hardening

BL512-3987

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure core dumps are restricted

Rule Ensure core dumps are restricted:

- Set hard limit on core dumps,
- Prevent setuid applications from dumping core.

Description

A core dump is the memory of an executable program. It is generally used to determine why a program aborted. It can also be used to glean confidential information from a core file. The system provides the ability to set a soft limit for core dumps, but this can be overridden by the user.

Rationale

Setting a hard limit on core dumps prevents users from overriding the soft variable. If core dumps are required, consider setting limits for user groups (see `limits.conf` (5)). In addition, setting the `fs.suid_dumpable` variable to 0 will prevent setuid programs from dumping core. The intention is to only allow the root user to read or process the produced core dumps for debugging purposes.

I01 - Implementation Example

Add the following line to `/etc/security/limits.conf` or a `/etc/security/limits.d/*` file:

```
* hard core 0
```

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
fs.suid_dumpable = 0
```

Run the following command to set the active kernel parameter:

```
# sysctl -w fs.suid_dumpable=0
```

If `systemd-coredump` is installed, edit `/etc/systemd/coredump.conf` and add/modify the following lines:

```
Storage=none  
ProcessSizeMax=0
```

Run the command:

```
# systemctl daemon-reload
```

C01 - Example Check

Run the following commands and verify output matches:

```
# grep "hard core" /etc/security/limits.conf /etc/security/limits.d/*  
* hard core 0  
  
# sysctl fs.suid_dumpable  
fs.suid_dumpable = 0  
  
# grep "fs\suid_dumpable" /etc/sysctl.conf /etc/sysctl.d/*  
fs.suid_dumpable = 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.6.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.5.1

Based on superseded measure M604007

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9851

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure address space layout randomization (ASLR) is enabled

Rule

Ensure kernel address space layout randomization (ASLR) is enabled in system kernel configuration:

- Set kernel configuration `randomize_va_space` to value of 2.

Description

Address space layout randomization (ASLR) is an exploit mitigation technique which randomly arranges the address space of key data areas of a process.

Rationale

Randomly placing virtual memory regions will make it difficult to write memory page exploits as the memory placement will be consistently shifting. A value of 2 for this kernel configuration setting not only randomizes the positions of the stack, pages for virtual dynamic shared objects and shared memory regions (which would be value of 1), but additionally also the base address of the data segment. The value of 2 is nowadays a default setting and recommended and should be preferred over the old value of 1.

I01 - Implementation Example

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
kernel.randomize_va_space = 2
```

Run the following command to set the active kernel parameter:

```
# sysctl -w kernel.randomize_va_space=2
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl kernel.randomize_va_space
kernel.randomize_va_space = 2
# grep "kernel\.randomize_va_space" /etc/sysctl.conf /etc/sysctl.d/*
kernel.randomize_va_space = 2
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.6.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.5.3

Based on superseded measure M505607

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8

Mandatory Access Control

Mandatory Access Control (MAC) provides an additional layer of access restrictions to processes on top of the basic Discretionary Access Controls. By restricting how processes can access files and resources on a system the potential impact from vulnerabilities in the processes can be reduced.

Impact: Mandatory Access Control limits the capabilities of applications and daemons on a system, while this can prevent unauthorized access, the configuration of MAC can be complex and difficult to implement correctly preventing legitimate access from occurring.

Configure SELinux

SELinux provides a Mandatory Access Control (MAC) system that greatly augments the default Discretionary Access Control (DAC) model. Under SELinux, every process and every object (files, sockets, pipes) on the system is assigned a security context, a label that includes detailed type information about the object. The kernel allows processes to access objects only if that access is explicitly allowed by the policy in effect. The policy defines transitions, so that a user can be allowed to run software, but the software can run under a different context than the user's default. This automatically limits the damage that the software can do to files accessible by the calling user. The user does not need to take any action to gain this benefit. For an action to occur, both the traditional DAC permissions must be satisfied as well as the SELinux MAC rules. The action will not be allowed if either one of these models does not permit the action. In this way, SELinux rules can only make a system's permissions more restrictive and secure. SELinux requires a complex policy to allow all the actions required of a system under normal operation. Three such policies have been designed for use with RHEL7 and are included with the system: `targeted`, `strict`, and `mls`. These are described as follows:

- `targeted`: consists mostly of Type Enforcement (TE) rules, and a small number of Role-Based Access Control (RBAC) rules. Targeted restricts the actions of many types of programs, but leaves interactive users largely unaffected.
- `strict`: also uses TE and RBAC rules, but on more programs and more aggressively.
- `mls`: implements Multi-Level Security (MLS), which introduces even more kinds of labels (sensitivity and category) and rules that govern access based on these.

This section provides guidance for the configuration of the `targeted` policy.

References:

1. NSA SELinux resources:
 1. <https://www.nsa.gov/research/selinux>
 2. <https://www.nsa.gov/research/selinux/list.shtml>
2. Fedora SELinux resources:
 1. FAQ: <https://docs.fedoraproject.org/selinux-faq>
 2. User Guide: <https://docs.fedoraproject.org/selinux-user-guide>
 3. Managing Services Guide: <https://docs.fedoraproject.org/selinux-managing-confined-services-guide>
3. SELinux Project web page and wiki:
 1. <https://www.selinuxproject.org>
4. Chapters 43-45 of Red Hat Enterprise Linux 5: Deployment Guide (Frank Mayer, Karl MacMillan and David Caplan),
5. SELinux by Example: Using Security Enhanced Linux (Prentice Hall, August 6, 2006)

BL512-3891

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure the SELinux state is enforcing

Rule

Ensure the SELinux state is enforcing.

E01 - Exemption

This rule is not mandatory, if just one single application or service is operated in the system, beside default management and monitoring services, such as SSH daemon, Antivirus or Corporate Scan Service Agent. If a vendor specification exists, that two services cannot be separated due to operational issues, e.g., SAP requirements, those are also included in the single service per system intention.

Description

Set SELinux to enable when the system is booted.

Rationale

SELinux must be enabled at boot time in to ensure that the controls it provides are in effect at all times.

I01 - Implementation Example

Edit the `/etc/selinux/config` file to set the SELINUX parameter:

```
SELINUX=enforcing
```

C01 - Example Check

Run the following commands and ensure output matches:

```
# grep SELINUX=enforcing /etc/selinux/config
SELINUX=enforcing

# sestatus
SELinux status: enabled
Current mode: enforcing
Mode from config file: enforcing
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.2.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-1792

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SELinux is not disabled in bootloader configuration

Rule

Ensure SELinux is not disabled in all relevant bootloader configuration options.

E01 - Exemption

This rule is only mandatory, if rule [BL512-3891 - Ensure the SELinux state is enforcing](#) is applied.

Description

Configure SELINUX to be enabled at boot time and verify that it has not been overwritten by the grub boot parameters.

Rationale

SELinux must be enabled at boot time in your grub configuration to ensure that the controls it provides are not overridden.

I01 - Implementation Example

Edit `/etc/default/grub` and remove all instances of `selinux=0` and `enforcing=0` from all `CMDLINE_LINUX` parameters. The following lines show valid, minimal example values:

```
GRUB_CMDLINE_LINUX_DEFAULT="quiet"  
GRUB_CMDLINE_LINUX=""
```

Run the following command to update the `grub2` configuration:

```
# grub2-mkconfig -o /boot/grub2/grub.cfg
```

C01 - Example Check

Run the following command and verify that no `linux` line has the `selinux=0` or `enforcing=0` parameters set:

```
# grep "^s*linux" /boot/grub2/grub.cfg
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.2.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-2898

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SELinux policy is configured

Rule

Ensure SELinux policy is configured to `targeted` or `mls`.

E01 - Exemption

This rule is only mandatory, if rule [BL512-3891 - Ensure the SELinux state is enforcing](#) is applied.

Description

Configure SELinux to meet or exceed the default `targeted` policy, which constrains daemons and system software only. The `targeted` policy applies MAC to dedicated processes which are believed to be most likely the targets of an attacker to the system. The Multilevel Security Policy `mls` applies MAC to multiple levels of processes each with different rules for user access.

Rationale

Security configuration requirements vary from site to site. Some sites may mandate a policy that is stricter than the default policy, which is perfectly acceptable. This item is intended to ensure that at least the default recommendations are met.

I01 - Implementation Example

Edit the `/etc/selinux/config` file to set the `SELINUXTYPE` parameter:

```
SELINUXTYPE=targeted
```

C01 - Example Check

Run the following commands and ensure output matches either `targeted` or `mls`:

```
# grep SELINUXTYPE=targeted /etc/selinux/config
SELINUXTYPE=targeted

# sestatus
Loaded policy name: targeted
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.2.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-9195

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure SETroubleshoot is not installed

Rule

Ensure SETroubleshoot is not installed.

E01 - Exemption

This rule is only mandatory, if rule [BL512-3891 - Ensure the SELinux state is enforcing](#) is applied.

E02 - Exemption

This rule is only mandatory, if rule [BL512-5500 - Ensure X Window System is not installed](#) is applied.

Description

The SETroubleshoot service notifies desktop users of SELinux denials through a user-friendly interface. The service provides important information around configuration errors, unauthorized intrusions, and other potential errors, but is not required for server systems.

Rationale

The SETroubleshoot service is an unnecessary daemon to have running on a server, especially if X Windows is disabled.

I01 - Implementation Example

Run the following command to uninstall `setroubleshoot` :

```
# dnf remove setroubleshoot
```

C01 - Example Check

Run the following command and verify `setroubleshoot` is not installed:

```
# rpm -q setroubleshoot  
package setroubleshoot is not installed
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.2.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01, 02 according feedback from review meetings.

BL512-4980

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure the MCS Translation Service (mcstrans) is not installed

Rule

Ensure the MCS Translation Service (mcstrans) is not installed.

E01 - Exemption

This rule is only mandatory, if rule [BL512-3891 - Ensure the SELinux state is enforcing](#) is applied.

Description

The `mcstransd` daemon provides category label information to client processes requesting information. The label translations are defined in `/etc/selinux/targeted/setrans.conf`

Rationale

Since this service is not used by default and only provides user defined category translations, remove it to reduce the amount of potentially vulnerable code running on the system.

I01 - Implementation Example

Run the following command to uninstall mcstrans:

```
# dnf remove mcstrans
```

C01 - Example Check

Run the following command and verify `mcstrans` is not installed:

```
# rpm -q mcstrans  
package mcstrans is not installed
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.2.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-8964

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no unconfined daemons exist

Rule

Ensure no unconfined system service and daemons exist.

E01 - Exemption

This rule is only mandatory, if rule [BL512-3891 - Ensure the SELinux state is enforcing](#) is applied.

Description

Daemons that are not defined in SELinux policy will inherit the security context of their parent process.

Rationale

For unconfined processes, SELinux policy rules are applied, but policy rules exist that allow processes running in unconfined domains almost all access. Processes running in unconfined domains fall back to using DAC rules exclusively. If an unconfined process is compromised, SELinux does not prevent an attacker from gaining access to system resources and data, but of course, DAC rules are still used. SELinux is a security enhancement on top of DAC rules – it does not replace them

I01 - Implementation Example

Investigate any unconfined daemons listed as result from the following command:

```
# ps -eZ | grep unconfined_service_t
```

They need to have an existing security context assigned to them or a policy built for them.

C01 - Example Check

Run the following command and verify no output is produced:

```
# ps -eZ | grep unconfined_service_t
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.2.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

BL512-3889

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SELinux is installed

Rule

Ensure SELinux is installed.

E01 - Exemption

This rule is not mandatory, if just one single application or service is operated in the system, beside default management and monitoring services, such as SSH daemon, Antivirus or Corporate Scan Service Agent. If a vendor specification exists, that two services cannot be separated due to operational issues, e.g., SAP requirements, those are also included in the single service per system intention.

Description

SELinux provides Mandatory Access Controls.

Rationale

Without a Mandatory Access Control system installed only the default Discretionary Access Control system will be available.

I01 - Implementation Example

Run the following command to install `libselinux` :

```
# dnf install libselinux
```

C01 - Example Check

Run the following command and verify `libselinux` is installed:

```
# rpm -q libselinux  
libselinux-<version>
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.7.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.6.1.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

Configure sudo

sudo allows a permitted user to execute a command as the superuser or another user, as specified by the security policy. The invoking user's real (not effective) user ID is used to determine the user name with which to query the security policy.

sudo supports a plugin architecture for security policies and input/output logging. Third parties can develop and distribute their own policy and I/O logging plugins to work seamlessly with the sudo front end. The default security policy is sudoers, which is configured via the file `/etc/sudoers`.

BL512-0997

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure sudo is installed

Rule

Ensure sudo is installed.

Description

sudo allows a permitted user to execute a command as the superuser or another user, as specified by the security policy. The invoking user's real (not effective) user ID is used to determine the user name with which to query the security policy.

Rationale

sudo supports a plugin architecture for security policies and input/output logging. Third parties can develop and distribute their own policy and I/O logging plugins to work seamlessly with the sudo front end. The default security policy is sudoers, which is configured via the file `/etc/sudoers`.

The security policy determines what privileges, if any, a user has to run sudo. The policy may require that users authenticate themselves with a password or another authentication mechanism. If authentication is required, sudo will exit if the user's password is not entered within a configurable time limit. This limit is policy-specific.

I01 - Implementation Example

Run the following command to install sudo

```
# dnf install sudo
```

C01 - Example Check

Verify that sudo is installed.

Run the following command:

```
# rpm -q sudo  
sudo-<version>
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.3.1

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

BL512-0998

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure sudo commands use pty

Rule

Ensure sudo is configured that sudo commands use pty.

Description

sudo can be configured to run only from a pseudo-pty.

Rationale

Attackers can run a malicious program using sudo which would fork a background process that remains even when the main program has finished executing.

I01 - Implementation Example

Edit the file `/etc/sudoers` or a file in `/etc/sudoers.d/` with `visudo -f` and add the following line:

```
Defaults use_pty
```

Impact:

Editing the sudo configuration incorrectly can cause sudo to stop functioning.

C01 - Example Check

Verify that sudo can only run other commands from a pseudo-pty

Run the following command:

```
# grep -Ei '^s*Defaults\s+(\[^\#\]+,\s*)?use_pty' /etc/sudoers /etc/sudoers.d/*
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.3.2

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

BL512-0999

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure sudo log file exists

Rule

Ensure dedicated log file is used for sudo command.

Description

The sudo command can be configured to use a custom log file, which enables appropriate monitoring of sudo specific aspects.

Rationale

A sudo log file simplifies auditing of sudo commands.

I01 - Implementation Example

Edit the file `/etc/sudoers` or a file in `/etc/sudoers.d/` with `visudo -f` and add the following line:

```
Defaults logfile="<PATH TO CUSTOM LOG FILE>"
```

Example:

```
Defaults logfile="/var/log/sudo.log"
```

C01 - Example Check

Verify that sudo has a custom log file configured

Run the following command:

```
# grep -Ei '^s*Defaults\s+([\^#]+,\s*)?logfile=' /etc/sudoers /etc/sudoers.d/*
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.3.3

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

Warning Banners

Presenting a warning message prior to the normal user login may assist in the prosecution of trespassers on the computer system. Changing some of these login banners also has the side effect of hiding OS version information and other detailed system information from attackers attempting to target specific exploits at a system.

Guidelines published by the US Department of Defense require that warning messages include at least the name of the organization that owns the system, the fact that the system is subject to monitoring and that such monitoring is in compliance with local statutes, and that use of the system implies consent to such monitoring. It is important that the organization's legal counsel review the content of all messages before any system modifications are made, as these warning messages are inherently site-specific. More information (including citations of relevant case law) can be found at <https://www.justice.gov/criminal/cybercrime/>

Command Line Warning Banners

The `/etc/motd`, `/etc/issue`, and `/etc/issue.net` files govern warning banners for standard command line logins for both local and remote users.

BL512-1950

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure local login warning banner is configured properly

Rule

Ensure local login warning banner is configured properly:

- Remove any instances of `\m`, `\r`, `\s`, or `\v`.

Description

The contents of the `/etc/issue` file are displayed to users prior to login for local terminals.

Unix-based systems have typically displayed information about the OS release and patch level upon logging in to the system. This information can be useful to developers who are developing software for a particular OS platform. If `mingetty` (8) supports the following options, they display operating system information: `\m` - machine architecture `\r` - operating system release `\s` - operating system name `\v` - operating system version

Rationale

Warning messages inform users who are attempting to login to the system of their legal status regarding the system and must include the name of the organization that owns the system and any monitoring policies that are in place. Displaying OS and patch level information in login banners also has the side effect of providing detailed system information to attackers attempting to target specific exploits of a system. Authorized users can easily get this information by running the `uname -a` command once they have logged in.

I01 - Implementation Example

Edit the `/etc/issue` file with the appropriate contents according to your site policy, remove any instances of `\m`, `\r`, `\s`, or `\v`:

```
# echo "Authorized uses only. All activity may be monitored and reported." > /etc/issue
```

C01 - Example Check

Run the following command and verify that the contents match site policy:

```
# cat /etc/issue
```

Run the following command and verify no results are returned:

```
# egrep '(\v|\r|\m|\s)' /etc/issue
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.8.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.7.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4180

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure remote login warning banner is configured properly

Rule Ensure remote login warning banner is configured properly:

- Remove any instances of `\m`, `\r`, `\s`, or `\v`.

Description

The contents of the `/etc/issue.net` file are displayed to users prior to login for remote connections from configured services.

Unix-based systems have typically displayed information about the OS release and patch level upon logging in to the system. This information can be useful to developers who are developing software for a particular OS platform. If `mingetty` (8) supports the following options, they display operating system information: `\m` - machine architecture `\r` - operating system release `\s` - operating system name `\v` - operating system version

Rationale

Warning messages inform users who are attempting to login to the system of their legal status regarding the system and must include the name of the organization that owns the system and any monitoring policies that are in place. Displaying OS and patch level information in login banners also has the side effect of providing detailed system information to attackers attempting to target specific exploits of a system. Authorized users can easily get this information by running the `uname -a` command once they have logged in.

I01 - Implementation Example

Edit the `/etc/issue.net` file with the appropriate contents according to your site policy, remove any instances of `\m`, `\r`, `\s`, or `\v`:

```
# echo "Authorized uses only. All activity may be monitored and reported." > /etc/issue.net
```

C01 - Example Check

Run the following command and verify that the contents match site policy:

```
# cat /etc/issue.net
```

Run the following command and verify no results are returned:

```
# egrep '(\v|\r|\m|\s)' /etc/issue.net
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.8.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.7.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-5191

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/motd are configured

Rule Ensure permissions on /etc/motd are configured:

- Owned by user and group root,
- Permissions set to 644 or more restrictive.

Description

The contents of the `/etc/motd` file are displayed to users after login and function as a message of the day for authenticated users.

Rationale

If the `/etc/motd` file does not have the correct ownership it could be modified by unauthorized users with incorrect or misleading information.

I01 - Implementation Example

Run the following commands to set permissions on `/etc/motd`:

```
# chown root:root /etc/motd
# chmod 644 /etc/motd
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` is `644`:

```
# stat /etc/motd
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.8.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.7.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-6629

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/issue are configured

Rule Ensure permissions on /etc/issue are configured:

- Owned by user and group root,
- Permissions set to 644 or more restrictive.

Description

The contents of the `/etc/issue` file are displayed to users prior to login for local terminals.

Rationale

If the `/etc/issue` file does not have the correct ownership it could be modified by unauthorized users with incorrect or misleading information.

I01 - Implementation Example

Run the following commands to set permissions on `/etc/issue`:

```
# chown root:root /etc/issue
# chmod 644 /etc/issue
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` is `644`:

```
# stat /etc/issue
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.8.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.7.1.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8820

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/issue.net are configured

Rule

Ensure permissions on /etc/issue.net are configured:

- Owned by user and group root,
- Permissions set to 644 or more restrictive.

Description

The contents of the `/etc/issue.net` file are displayed to users prior to login for remote connections from configured services.

Rationale

If the `/etc/issue.net` file does not have the correct ownership it could be modified by unauthorized users with incorrect or misleading information.

I01 - Implementation Example

Run the following commands to set permissions on `/etc/issue.net` :

```
# chown root:root /etc/issue.net
# chmod 644 /etc/issue.net
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` is `644` :

```
# stat /etc/issue.net
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.8.1.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.7.1.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9945

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure recent updates and patches are installed

Rule

Ensure recent updates and patches are installed and ensure operating system is still in maintenance by vendor.

Description

Periodically patches are released for included software either due to security flaws or to include additional functionality.

Rationale

Newer patches may contain security enhancements that would not be available through the latest full update. As a result, it is recommended that the latest software patches are used to take advantage of the latest functionality. As with any software installation, organizations need to determine if a given update meets their requirements and verify the compatibility and supportability of any additional software against the update revision that is selected.

I01 - Implementation Example

Use the package manager to update all packages on the system according to site policy. The following command will install all available security updates, which have been installed using system's package manager:

```
# dnf update --security
```

Note: Manually installed software not using package manager has to be updated using software specific techniques.

C01 - Example Check

Run the following command and verify there are no updates or patches listed as available for software installed using package manager:

```
# dnf check-update --security
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 1.8

Based on superseded measure M497003

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note and rephrased according to feedback from review meeting.

BL512-8949

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Prevent shutdown without authorization

Rule

Prevent shutting down the system without authorization.

Description

Some manufacturers deliver their systems with IDs (shutdown, stop, etc.) that allow the system to be shut down without prior authorization.

Rationale

A local user could reboot the system without authorization.

I01 - Implementation

Run the following command to disable shutting down with **<Ctrl><Alt>**:

```
# systemctl mask ctrl-alt-del.target
```

C01 - Example Check

Run the following command and verify that output is "masked":

```
# systemctl is-enabled ctrl-alt-del.target  
masked
```

Crossreferences

Based on superseded measure M700784

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs.

BL512-8869

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Configure system crypto policy to at least FUTURE

Rule

Configure system crypto policy at least to the FUTURE policy.

Description

Red Hat Enterprise Linux provide a system-wide enforcement of crypto settings. This includes for instance allowed cipher suites, hashing algorithm, TLS protocols and other settings for multiple services such as OpenSSH, applications using the GnuTLS or OpenSSL library, OpenJDK and others.

The FUTURE policy, implemented in Red Hat Enterprise Linux 8 package `crypto-policies` with version `20181217-6.git9a35207`, provides a reasonable policy for the current state, allowing for instance TLS 1.2 and 1.3, IKEv2 and SSH2. In contrast to the `DEFAULT` policy, SHA-1 is prohibited in signature algorithms and the minimal length for RSA keys and Diffie-Hellman parameters is increased to minimal 3072 bits.

Rationale

Crypto settings such as used cipher suites are essential for secure operation of services.

If the Legacy system-wide crypto policy is selected, it includes support for TLS 1.0, TLS 1.1, and SSH2 protocols or later. The algorithms DSA, 3DES, and RC4 are allowed, while RSA and Diffie-Hellman parameters are accepted if larger than 1023-bits.

These legacy protocols and algorithms can make the system vulnerable to attacks, including those listed in RFC 7457.

I01 - Implementation Example

Run the following command to set the crypto policy to the FUTURE policy:

```
# update-crypto-policies --set FUTURE
```

Run the following command to make the updated system-wide crypto policy active:

```
# update-crypto-policies
```

C01 - Example Check

Run the following command and verify policy is set to the FUTURE policy:

```
# update-crypto-policies --show  
FUTURE
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 1.10

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, included CIS-RHEL8.

BL512-7387

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Enable link protection

Rule

Enable *protected symlinks* and *protected hardlinks* in system kernel configuration:

- fs.protected_hardlinks is set to 1,
- fs.protected_symlinks is set to 1.

Description

The Linux kernel offers a protection mechanism for some of the attack scenarios:

- **hardlink protection** restricts users from creating hard links to files they do not own, or do not have read/write access to it.
- **symlink protection** allows following of symbolic links only when outside a sticky world-writeable directory, or when the uid of the symlink and follow match, or when the directory owner matches the symlink's owner.

Rationale

The hard link and symbolic link mechanism can be used by attackers to redirect the file operations of a victim's process to a destination defined by the attacker.

I01 - Implementation

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
fs.protected_hardlinks = 1 fs.protected_symlinks = 1
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w fs.protected_symlinks=1  
# sysctl -w fs.protected_hardlinks=1
```

C01 - Example Check

Run the following commands and verify the output is as shown:

```
# sysctl fs.protected_symlinks  
fs.protected_symlinks = 1  
# sysctl fs.protected_hardlinks  
fs.protected_hardlinks = 1
```

Crossreferences

Based on superseded measure M447734

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs.

BL512-0990

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure volumes are encrypted

Rule Ensure all volumes are encrypted:

- An encryption algorithm using AES encryption (such as "aes-xts-plain64" or higher) must be used,
- The hashing algorithm "sha256" or higher must be used,
- The chosen passphrase must be in compliance with the rules from *Specific Information Security Policy: Access Control* [4].

Note: The operating system volume, containing, e.g., core binaries and libraries, but neither user or customer data nor (temporary) application data, can be excluded from encryption, if it is completely separated from any other stored data.

Description

Red Hat Enterprise Linux performs filesystem encryption using LUKS (Linux Unified Key Setup-on-disk-format).

Rationale

Encrypting hard drives of your computer prevents the risk of information disclosure in case the computer is lost or stolen (data-at-rest). A malicious user who gets access to the computer could remove the unencrypted hard drive from the computer and connect it to another computer as an external drive, and thus, get access to the data without the need of providing credentials. Furthermore, the process of decommissioning is simplified if the hard disk is encrypted.

I01 - Implementation

It is recommended to initiate the filesystem encryption using LUKS during the installation process. By default, the encryption option is unchecked during the installation. Therefore, enable the encryption option during the system installation process and choose a passphrase in compliance with the rules from *Specific Information Security Policy: Access Control* [4].

I02 - Implementation

Local system and data volumes can be encrypted intrinsically by using an encrypted storage system.

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed rule such that operating system volumes can be excluded.

Services

While applying system updates and patches helps correct known vulnerabilities, one of the best ways to protect the system against as yet unreported vulnerabilities is to disable all services that are not mandatory for anticipated operation of the concerned system. This prevents the exploitation of vulnerabilities discovered at a later date. If a service is not enabled, it cannot be exploited. The actions in this section of the document provide guidance on some services which can be safely disabled and under which circumstances, greatly reducing the number of possible threats to the resulting system. Additionally some services which should remain enabled but with secure configuration are covered as well as insecure service clients.

Special Purpose Services

This section describes services that are installed on systems that specifically need to run these services. If any of these services are not required, it is highly recommended that they are disabled or deleted from the system to reduce the potential attack surface. As there is a high number of various services and, furthermore, various implementation of those services, this list is not intended complete, but only gives recommendations.

Time Synchronization

It is mandatory that physical systems and virtual guests lacking direct access to the physical host's clock are configured to synchronize their time using a service chrony.

BL512-1020

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure time synchronization is configured and in use

Rule

Ensure time synchronization service is configured and in use:

- On physical systems or virtual systems where host based time synchronization is not available, a time synchronization daemon must be used.

Description

System time should be synchronized between all systems in an environment. This is typically done by establishing an authoritative time server or set of servers and having all systems synchronize their clocks to them.

chrony is a daemon which implements the Network Time Protocol (NTP) is designed to synchronize system clocks across a variety of systems and use a source that is highly accurate. More information on chrony can be found at <https://chrony.tuxfamily.org/>. chrony can be configured to be a client and/or a server.

Rationale

Time synchronization is important to support time sensitive security mechanisms like Kerberos and also ensures log files have consistent time records across the enterprise, which aids in forensic investigations.

Chrony is the successor of the ntpd time synchronization daemon on Red Hat Enterprise Linux systems.

I01 - Implementation Example

On physical systems or virtual systems where host based time synchronization is not available, the time synchronization daemon `chrony` must be used:

```
# dnf install chrony
```

Add or edit server or pool lines to `/etc/chrony.conf` as appropriate:

```
server <remote-server>
```

Add or edit the `OPTIONS` in `/etc/sysconfig/chronyd` to include `'-u chrony'`:

```
OPTIONS="-u chrony"
```

On virtual systems where host based time synchronization is available consult your virtualization software documentation and setup host based synchronization.

C01 - Example Check

On physical systems or virtual systems where host based time synchronization is not available run the following commands and verify either `chrony` is installed and configured:

```
# rpm -q chrony
```

Run the following command and verify remote server is configured properly:

```
# grep -E "^(server|pool)" /etc/chrony.conf  
server
```

Multiple servers can be configured.

Run the following command and verify `OPTIONS` includes `-u chrony`:

```
# grep ^OPTIONS /etc/sysconfig/chronyd  
OPTIONS="-u chrony"
```

Additional options may be present.

Run the following command and verify the first field for the `chronyd` process is `chrony`:

```
# ps -ef | grep chronyd  
  
chronyd 491 1 0 20:32 ? 00:00:00 /usr/sbin/chronyd
```

On virtual systems where host based time synchronization is available consult your virtualization software documentation and verify that host based synchronization is in use.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.2.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.2.1.1

Based on superseded measure M140306

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-5500

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure X Window System is not installed

Rule Ensure the X.Org X server (X Windows System) is not installed.

Note: This considers only the X server: If some dedicated X libraries or utils, such as xauth, are required, this rule does not prohibit this.

E01 - Exemption

This rule is not mandatory, if the system's purpose specifically requires a graphical environment using X Windows System, i.e., is intended as client system, not as server system.

Description

The X Window System provides a Graphical User Interface (GUI) where users can have multiple windows in which to run programs and various add on. The X Windows system is typically used on workstations where users login, but not on servers where users typically do not login.

Rationale

Graphical login access is typically not needed for server systems. Unless your organization specifically requires graphical login access via X Windows, remove it to reduce the potential attack surface.

I01 - Implementation Example

Run the following command to remove the X Windows System packages:

```
# dnf remove xorg-x11*
```

C01 - Example Check

Run the following command and verify no output is returned:

```
# rpm -qa xorg-x11*
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.2.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.2.2

Based on superseded measure M420460

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption for non-server system.

BL512-9229

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure Avahi Server is not enabled

Rule

Ensure Avahi Server is not enabled.

Description

Avahi is a free zeroconf implementation, including a system for multicast DNS/DNS-SD service discovery. Avahi allows programs to publish and discover services and hosts running on a local network with no specific configuration. For example, a user can plug a computer into a network and Avahi automatically finds printers to print to, files to look at and people to talk to, as well as network services running on the machine.

Rationale

Automatic discovery of network services is not normally required for system functionality, especially in server environments. It is recommended to disable the service to reduce the potential attack surface.

I01 - Implementation Example

Run the following command to disable `avahi-daemon` :

```
# systemctl disable avahi-daemon
```

C01 - Example Check

Run the following command and verify result is not "enabled":

```
# systemctl is-enabled avahi-daemon
disabled
```

Depending on the installation scheme, the `avahi-daemon` service might not be installed at all and the shown command may return the following message, also meaning compliance to this rule:

```
Failed to get unit file state for avahi-daemon.service: No such file or
directory
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.2.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.2.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-7333

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure CUPS is not enabled

Rule Ensure CUPS is not enabled.

E01 - Exemption

This rule is not mandatory, if the system is acting as print server.

E02 - Exemption

This rule is only mandatory, if rule [BL512-5500 - Ensure X Window System is not installed](#) is applied.

Description

The Common Unix Print System (CUPS) provides the ability to print to both local and network printers. A system running CUPS can also accept print jobs from remote systems and print them to local printers. It also provides a web based remote administration capability.

Rationale

In server environments other than print servers, it is typically not required to provide print services. If the system does not need to print jobs or accept print jobs from other systems, it is recommended that CUPS is disabled to reduce the potential attack surface.

I01 - Implementation Example

Run the following command to disable cups :

```
# systemctl disable cups
```

C01 - Example Check

Run the following command and verify result is not "enabled":

```
# systemctl is-enabled cups  
disabled
```

Depending on the installation scheme, the cups service might not be installed at all and the shown command may return the following message, also meaning compliance to this rule:

```
Failed to get unit file state for cups.service: No such file or directory
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.2.16

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.2.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 02 according feedback from review meetings.

BL512-2222

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure mail transfer agent is configured for local-only mode

Rule

Ensure mail transfer agent is configured for local-only mode.

Description

Mail Transfer Agents (MTA), such as sendmail and Postfix, are used to listen for incoming mail and transfer the messages to the appropriate user or mail server. If the system is not intended to be a mail server, it is recommended that the MTA be configured to only process local mail.

Rationale

The software for all Mail Transfer Agents is complex and most have a long history of security issues. While it is important to ensure that the system can process local mail messages, it is not necessary to have the MTA's daemon listening on a port unless the server is intended to be a mail server that receives and processes mail from other systems.

I01 - Implementation Example

In case of Postfix usage, edit `/etc/postfix/main.cf` and add the following line to the RECEIVING MAIL section. If the line already exists, change it to look like the line below:

```
inet_interfaces = loopback-only
```

Restart postfix:

```
# systemctl restart postfix
```

C01 - Example Check

Run the following command and verify that the MTA is not listening on any non-loopback address (127.0.0.1 or ::1):

```
# ss -an | grep LIST | grep ":25[[:space:]]"
tcp 0 0 127.0.0.1:25 0.0.0.0:* LISTEN
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.2.18

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.2.15

Based on superseded measure M402440

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3572

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure NIS Server is not enabled

Rule Ensure NIS Server is not enabled.

Description

The Network Information Service (NIS) (formally known as Yellow Pages) is a client-server directory service protocol for distributing system configuration files. The NIS server is a collection of programs that allow for the distribution of configuration files.

Rationale

The NIS service is inherently an insecure system that has been vulnerable to DOS attacks, buffer overflows and has poor authentication for querying NIS maps. NIS generally been replaced by such protocols as Lightweight Directory Access Protocol (LDAP). It is recommended that the service be disabled and other, more secure services be used

I01 - Implementation Example

Run the following command to disable `ypserv` :

```
# systemctl disable ypserv
```

C01 - Example Check

Run the following command and verify result is not "enabled":

```
# systemctl is-enabled ypserv
disabled
```

Depending on the installation scheme, the `ypserv` service might not be installed at all and the shown command may return the following message, also meaning compliance to this rule:

```
Failed to get unit file state for ypserv.service: No such file or directory
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.2.17

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.2.17

Based on superseded measure M607590

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2458

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure telnet server is not enabled

Rule

Ensure telnet server is not enabled.

Description

The `telnet-server` package contains the `telnet` daemon, which accepts connections from users from other systems via the `telnet` protocol.

Rationale

The `telnet` protocol is insecure and unencrypted. The use of an unencrypted transmission medium could allow a user with access to sniff network traffic the ability to steal credentials. The `ssh` package provides an encrypted session and stronger security.

I01 - Implementation Example

Run the following command to disable telnet:

```
# systemctl disable telnet.socket
```

C01 - Example Check

Run the following command and verify result is not "enabled":

```
# systemctl is-enabled telnet.socket  
disabled
```

Depending on the installation scheme, the `telnet` service might not be installed at all and the shown command may return the following message, also meaning compliance to this rule:

Failed to get unit file state for `telnet.socket`: No such file or directory

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 7' (v2.2.0.1): 2.2.19

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.1.8

Based on superseded measure M300279

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-6968

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure tftp server is not enabled

Rule

Ensure tftp server is not enabled.

Description

Trivial File Transfer Protocol (TFTP) is a simple file transfer protocol, typically used to automatically transfer configuration or boot machines from a boot server. The package `tftp-server` is used to define and support a TFTP server.

Rationale

TFTP does not support authentication nor does it ensure the confidentiality or integrity of data. It is recommended that TFTP be removed, unless there is a specific need for TFTP. In that case, extreme caution must be used when configuring the services.

I01 - Implementation Example

Run the following command to disable tftp:

```
# systemctl disable tftp.socket
```

C01 - Example Check

Run the following command and verify result is not "enabled":

```
# systemctl is-enabled tftp.socket  
disabled
```

Depending on the installation scheme, the `tftp` service might not be installed at all and the shown command may return the following message, also meaning compliance to this rule:

Failed to get unit file state for `tftp.socket`: No such file or directory

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 7' (v2.2.0.1): 2.2.20

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.1.9

Based on superseded measure M300279

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

Service Clients

A number of insecure services exist. While disabling the servers prevents a local attack against these services, it is advised to remove their client applications unless they are mandatorily required.

Note: This should not be considered a comprehensive list of insecure service clients. You may wish to consider additions to those listed here for your environment.

BL512-4680

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure NIS Client is not installed

Rule Ensure NIS Client is not installed.

Description

The Network Information Service (NIS), formerly known as Yellow Pages, is a client-server directory service protocol used to distribute system configuration files. The NIS client (`ypbind`) was used to bind a machine to an NIS server and receive the distributed configuration files.

Rationale

The NIS service is inherently an insecure system that has been vulnerable to DOS attacks, buffer overflows and has poor authentication for querying NIS maps. NIS generally has been replaced by such protocols as Lightweight Directory Access Protocol (LDAP). It is recommended that the service be removed.

I01 - Implementation Example

Run the following command to uninstall `ypbind`:

```
# dnf remove ypbind
```

Impact:

Many insecure service clients are used as troubleshooting tools and in testing environments. Uninstalling them can inhibit capability to test and troubleshoot. If they are required it is advisable to remove the clients after use to prevent accidental or intentional misuse.

C01 - Example Check

Run the following command and verify `ypbind` is not installed:

```
# rpm -q ypbind
package ypbind is not installed
```


Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.3.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.3.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9589

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure xinetd is not installed

Rule

Ensure xinetd is not installed.

Description

The eXtended InterNET Daemon (`xinetd`) is an open source super daemon that replaced the original `inetd` daemon. The `xinetd` daemon listens for well-known services and dispatches the appropriate daemon to properly respond to service requests.

Rationale

`xinetd` was formerly intended as collection service for many commonly hosted services on one machine. Nowadays, given a more hostile Internet and a greater awareness of potential for misusing older services to launch, e.g., DDOS attacks, it is highly recommended to configure and manage services in dedicated manner.

I01 - Implementation Example

Run the following command to remove `xinetd`:

```
# dnf remove xinetd
```

C01 - Example Check

Run the following command to verify `xinetd` is not installed:

```
# rpm -q xinetd  
package xinetd is not installed
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 2.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 2.1.10

Based on superseded measure M230501

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

Network Configuration

This section provides guidance for securing the network configuration of the system through kernel parameters, access list control, and firewall settings.

Network Parameters (Host Only)

The following network parameters are intended for use if the system is to act as a host only. A system is considered host only if the system has a single interface, or has multiple interfaces but will not be configured as a router.

BL512-2528

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure IP forwarding is disabled

Rule

Ensure IP forwarding is disabled in kernel configuration parameters.

E01 - Exemption

This rule is not mandatory, if the system is operating as virtual machine or container-based host, such as Docker or Podman, for which network setup requires IP forwarding for proper operation.

Description

The `net.ipv4.ip_forward` flag is used to tell the system whether it can forward packets or not.

Rationale

Setting the flag to 0 ensures that a system with multiple interfaces (for example, a hard proxy), will never be able to forward packets, and therefore, never serve as a router.

I01 - Implementation Example

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.ip_forward = 0 net.ipv6.conf.all.forwarding = 0
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.ip_forward=0
# sysctl -w net.ipv6.conf.all.forwarding=0
# sysctl -w net.ipv4.route.flush=1
# sysctl -w net.ipv6.route.flush=1
```

C01 - Example Check

Run the following command and verify output matches:

```
# sysctl net.ipv4.ip_forward  
net.ipv4.ip_forward = 0  
# grep "net\.ipv4\.ip_forward" /etc/sysctl.conf /etc/sysctl.d/*  
net.ipv4.ip_forward = 0  
  
# sysctl net.ipv6.conf.all.forwarding  
net.ipv6.conf.all.forwarding = 0  
# grep "net\.ipv6\.conf\.all\.forwarding" /etc/sysctl.conf /etc/sysctl.d/*  
net.ipv6.conf.all.forwarding = 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.1.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption for VM/Docker-Hosts according received feedback.

BL512-4639

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure packet redirect sending is disabled

Rule

Ensure packet redirect sending is disabled.

Description

ICMP Redirects are used to send routing information to other hosts. As a host itself does not act as a router (in a host only configuration), there is no need to send redirects.

Rationale

An attacker could use a compromised host to send invalid ICMP redirects to other router devices in an attempt to corrupt routing and have users access a system set up by the attacker as opposed to a valid system.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.default.send_redirects = 0
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.conf.all.send_redirects=0
# sysctl -w net.ipv4.conf.default.send_redirects=0
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.conf.all.send_redirects
net.ipv4.conf.all.send_redirects = 0
# sysctl net.ipv4.conf.default.send_redirects
net.ipv4.conf.default.send_redirects = 0
# grep "net\.ipv4\.conf\.all\.send_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.all.send_redirects = 0
# grep "net\.ipv4\.conf\.default\.send_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.default.send_redirects= 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

Network Parameters (Host and Router)

The following network parameters are intended for use on both, host only and router systems. A system acts as a router if it has at least two interfaces and is configured to provide routing functionality.

BL512-1811

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure source routed packets are not accepted

Rule Ensure source routed packets are not accepted.

Description

In networking, source routing allows a sender to partially or fully specify the route packets take through a network. In contrast, non-source routed packets travel a path determined by routers in the network. In some cases, systems may not be routable or reachable from some locations (e.g., private addresses vs. Internet routable), and so source routed packets would need to be used.

Rationale

Setting `net.ipv4.conf.all.accept_source_route` and `net.ipv4.conf.default.accept_source_route` to 0 disables the system from accepting source routed packets. Assume this system was capable of routing packets to Internet routable addresses on one interface and private addresses on another interface. Assume that the private addresses were not routable to the Internet routable addresses and vice versa. Under normal routing circumstances, an attacker from the Internet routable addresses could not use the system as a way to reach the private address systems. If, however, source routed packets were allowed, they could be used to gain access to the private address systems as the route could be specified, rather than rely on routing protocols that did not allow this routing.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.default.accept_source_route = 0
net.ipv6.conf.all.accept_source_route = 0
net.ipv6.conf.default.accept_source_route = 0
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.conf.all.accept_source_route=0
# sysctl -w net.ipv4.conf.default.accept_source_route=0
# sysctl -w net.ipv4.route.flush=1

# sysctl -w net.ipv6.conf.all.accept_source_route=0
# sysctl -w net.ipv6.conf.default.accept_source_route=0
# sysctl -w net.ipv6.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.conf.all.accept_source_route
net.ipv4.conf.all.accept_source_route = 0
# sysctl net.ipv4.conf.default.accept_source_route
net.ipv4.conf.default.accept_source_route = 0
# grep "net\.ipv4\.conf\.all\.accept_source_route" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.all.accept_source_route= 0
# grep "net\.ipv4\.conf\.default\.accept_source_route" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.default.accept_source_route= 0

# sysctl net.ipv6.conf.all.accept_source_route
net.ipv6.conf.all.accept_source_route = 0
# sysctl net.ipv6.conf.default.accept_source_route
net.ipv6.conf.default.accept_source_route = 0
# grep "net\.ipv6\.conf\.all\.accept_source_route" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv6.conf.all.accept_source_route= 0
# grep "net\.ipv6\.conf\.default\.accept_source_route" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv6.conf.default.accept_source_route= 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-5100

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure ICMP redirects are not accepted

Rule

Ensure ICMP redirects are not accepted.

Description

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables. By setting `net.ipv4.conf.all.accept_redirects` to 0, the system will not accept any ICMP redirect messages, and therefore, won't allow outsiders to update the system's routing tables.

Rationale

Attackers could use bogus ICMP redirect messages to maliciously alter the system routing tables and get them to send packets to incorrect networks and allow your system packets to be captured.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.default.accept_redirects = 0
net.ipv6.conf.all.accept_redirects = 0
net.ipv6.conf.default.accept_redirects = 0
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.conf.all.accept_redirects=0
# sysctl -w net.ipv4.conf.default.accept_redirects=0
# sysctl -w net.ipv4.route.flush=1

# sysctl -w net.ipv6.conf.all.accept_redirects=0
# sysctl -w net.ipv6.conf.default.accept_redirects=0
# sysctl -w net.ipv6.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.conf.all.accept_redirects
net.ipv4.conf.all.accept_redirects = 0
# sysctl net.ipv4.conf.default.accept_redirects
net.ipv4.conf.default.accept_redirects = 0
# grep "net\.ipv4\.conf\.all\.accept_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.all.accept_redirects= 0
# grep "net\.ipv4\.conf\.default\.accept_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.default.accept_redirects= 0

# sysctl net.ipv6.conf.all.accept_redirects
net.ipv6.conf.all.accept_redirects = 0
# sysctl net.ipv6.conf.default.accept_redirects
net.ipv6.conf.default.accept_redirects = 0
# grep "net\.ipv6\.conf\.all\.accept_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv6.conf.all.accept_redirects= 0
# grep "net\.ipv6\.conf\.default\.accept_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv6.conf.default.accept_redirects= 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8363

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure secure ICMP redirects are not accepted

Rule

Ensure secure ICMP redirects are not accepted.

Description

Secure ICMP redirects are the same as ICMP redirects, except they come from gateways listed on the default gateway list. It is assumed that these gateways are known to your system, and that they are likely to be secure.

Rationale

It is still possible for even known gateways to be compromised. Setting `net.ipv4.conf.all.secure_redirects` to 0 protects the system from routing table updates by possibly compromised known gateways.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.conf.all.secure_redirects = 0
net.ipv4.conf.default.secure_redirects = 0
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.conf.all.secure_redirects=0
# sysctl -w net.ipv4.conf.default.secure_redirects=0
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.conf.all.secure_redirects
net.ipv4.conf.all.secure_redirects = 0
# sysctl net.ipv4.conf.default.secure_redirects
net.ipv4.conf.default.secure_redirects = 0
# grep "net\.ipv4\.conf\.all\.secure_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.all.secure_redirects= 0
# grep "net\.ipv4\.conf\.default\.secure_redirects" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.default.secure_redirects= 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9811

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure suspicious packets are logged

Rule

Ensure suspicious packets are logged.

Description

When enabled, this feature logs packets with un-routable source addresses to the kernel log.

Rationale

Enabling this feature and logging these packets allows an administrator to investigate the possibility that an attacker is sending spoofed packets to their system.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.conf.all.log_martians = 1
net.ipv4.conf.default.log_martians = 1
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.conf.all.log_martians=1
# sysctl -w net.ipv4.conf.default.log_martians=1
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.conf.all.log_martians
net.ipv4.conf.all.log_martians = 1
# sysctl net.ipv4.conf.default.log_martians
net.ipv4.conf.default.log_martians = 1
# grep "net\.ipv4\.conf\.all\.log_martians" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.all.log_martians = 1
# grep "net\.ipv4\.conf\.default\.log_martians" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.default.log_martians = 1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9068

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure broadcast ICMP requests are ignored

Rule

Ensure broadcast ICMP requests are ignored.

Description

Setting `net.ipv4.icmp_echo_ignore_broadcasts` to 1 will cause the system to ignore all ICMP echo and timestamp requests to broadcast and multicast addresses.

Rationale

Accepting ICMP echo and timestamp requests with broadcast or multicast destinations for your network could be used to trick your host into starting (or participating) in a Smurf attack. A Smurf attack relies on an attacker sending large amounts of ICMP broadcast messages with a spoofed source address. All hosts receiving this message and responding would send echo-reply messages back to the spoofed address, which is probably not routable. If many hosts respond to the packets, the amount of traffic on the network could be significantly multiplied.

I01 - Implementation Example

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.icmp_echo_ignore_broadcasts = 1
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.icmp_echo_ignore_broadcasts=1
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.icmp_echo_ignore_broadcasts
net.ipv4.icmp_echo_ignore_broadcasts = 1
# grep "net\.ipv4\.icmp_echo_ignore_broadcasts" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.icmp_echo_ignore_broadcasts = 1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-6421

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure bogus ICMP responses are ignored

Rule Ensure bogus ICMP responses are ignored.

Description

Setting `icmp_ignore_bogus_error_responses` to 1 prevents the kernel from logging bogus responses (RFC-1122 non-compliant) from broadcast reframes, keeping file systems from filling up with useless log messages.

Rationale

Some routers (and some attackers) will send responses that violate RFC-1122 and attempt to fill up a log file system with many useless error messages.

I01 - Implementation Example

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.icmp_ignore_bogus_error_responses = 1
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.icmp_ignore_bogus_error_responses=1
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.icmp_ignore_bogus_error_responses
net.ipv4.icmp_ignore_bogus_error_responses = 1
# grep "net\.ipv4\.icmp_ignore_bogus_error_responses" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.icmp_ignore_bogus_error_responses = 1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3714

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure Reverse Path Filtering is enabled

Rule

Ensure Reverse Path Filtering is enabled.

Description

Setting `net.ipv4.conf.all.rp_filter` and `net.ipv4.conf.default.rp_filter` to 1 forces the Linux kernel to utilize reverse path filtering on a received packet to determine if the packet was valid. Essentially, with reverse path filtering, if the return packet does not go out the same interface that the corresponding source packet came from, the packet is dropped (and logged if `log_martians` is set).

Rationale

Setting these flags is a good way to deter attackers from sending your system bogus packets that cannot be responded to. One instance where this feature breaks down is if asymmetrical routing is employed. This would occur when using dynamic routing protocols (bgp, ospf, etc.) on your system.

If you are using asymmetrical routing on your system, you will not be able to enable this feature without breaking the routing.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.default.rp_filter = 1
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.conf.all.rp_filter=1
# sysctl -w net.ipv4.conf.default.rp_filter=1
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.conf.all.rp_filter
net.ipv4.conf.all.rp_filter = 1
# sysctl net.ipv4.conf.default.rp_filter
net.ipv4.conf.default.rp_filter = 1
# grep "net\.ipv4\.conf\.all\.rp_filter" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.all.rp_filter = 1
# grep "net\.ipv4\.conf\.default\.rp_filter" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.conf.default.rp_filter = 1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4457

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure TCP SYN Cookies is enabled

Rule

Ensure TCP SYN Cookies is enabled.

Description

When `tcp_syncookies` is set, the kernel will handle TCP SYN packets normally until the half-open connection queue is full, at which time, the SYN cookie functionality kicks in. SYN cookies work by not using the SYN queue at all. Instead, the kernel simply replies to the SYN with a SYN|ACK, but will include a specially crafted TCP sequence number that encodes the source and destination IP address and port number and the time the packet was sent. A legitimate connection would send the ACK packet of the three way handshake with the specially crafted sequence number. This allows the system to verify that it has received a valid response to a SYN cookie and allow the connection, even though there is no corresponding SYN in the queue.

Rationale

Attackers use SYN flood attacks to perform a denial of service attacked on a system by sending many SYN packets without completing the three way handshake. This will quickly use up slots in the kernel's half-open connection queue and prevent legitimate connections from succeeding. SYN cookies allow the system to keep accepting valid connections, even if under a denial of service attack.

I01 - Implementation Example

Set the following parameter in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv4.tcp_syncookies = 1
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv4.tcp_syncookies=1
# sysctl -w net.ipv4.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv4.tcp_syncookies
net.ipv4.tcp_syncookies = 1
# grep "net\.ipv4\.tcp_syncookies" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv4.tcp_syncookies = 1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.8

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

IPv6

IPv6 is a networking protocol that supersedes IPv4. It has more routable addresses and has some built-in security functionality. If IPv6 is to be used, follow this section of the benchmark to configure IPv6, otherwise disable IPv6 to avoid issues with using unintended or unconfigured default values.

BL512-3212

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure IPv6 router advertisements are not accepted

Rule

Ensure IPv6 router advertisements are not accepted.

E01 - Exemption

This rule is not mandatory, if IPv6 is completely disabled due to rule [BL512-8891 - Ensure IPv6 is disabled](#) is applied.

Description

This setting disables the system's ability to accept IPv6 router advertisements.

Rationale

It is recommended that systems not accept router advertisements as they could be tricked into routing traffic to compromised machines. Setting hard routes within the system (usually a single default route to a trusted router) protects the system from bad routes.

I01 - Implementation Example

Set the following parameters in `/etc/sysctl.conf` or a `/etc/sysctl.d/*` file:

```
net.ipv6.conf.all.accept_ra = 0
net.ipv6.conf.default.accept_ra = 0
```

Run the following commands to set the active kernel parameters:

```
# sysctl -w net.ipv6.conf.all.accept_ra=0
# sysctl -w net.ipv6.conf.default.accept_ra=0
# sysctl -w net.ipv6.route.flush=1
```

C01 - Example Check

Run the following commands and verify output matches:

```
# sysctl net.ipv6.conf.all.accept_ra
net.ipv6.conf.all.accept_ra = 0
# sysctl net.ipv6.conf.default.accept_ra
net.ipv6.conf.default.accept_ra = 0
# grep "net\.ipv6\.conf\.all\.accept_ra" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv6.conf.all.accept_ra = 0
# grep "net\.ipv6\.conf\.default\.accept_ra" /etc/sysctl.conf /etc/sysctl.d/*
net.ipv6.conf.default.accept_ra = 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.2.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.2.9

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings: Can lead to errors, if IPv6 is disabled.

BL512-8891

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure IPv6 is disabled

Rule

Ensure IPv6 is disabled.

E01 - Exemption

This rule is not mandatory, if IPv6 is used productively in system's network environment.

Description

Although IPv6 has many advantages over IPv4, few organizations have implemented IPv6.

Rationale

If IPv6 is not to be used, it is recommended that it be disabled to reduce the attack surface of the system.

I01 - Implementation Example

Edit `/etc/default/grub` and remove add `ipv6.disable=1` to the `GRUB_CMDLINE_LINUX` parameters:

```
GRUB_CMDLINE_LINUX="ipv6.disable=1"
```

Run the following command to update the `grub2` configuration:

```
# grub2-mkconfig -o /boot/grub2/grub.cfg
```

C01 - Example Check

Run the following command and verify that all linux lines have the `ipv6.disable=1` parameter set:

```
# grep "^s*ipv6.disable" /boot/grub2/grub.cfg
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed old implementation way. Fixed sometimes invalid grep value in check.

Firewall Configuration

A firewall provides defense against external and internal threats by refusing unauthorized connections, to stop intrusion and provide a strong method of access control policy.

Red Hat Enterprise Linux 8 uses `nftables` instead of `iptables` as firewall backend. Although configuration of `nftables` can be done using tools from the `firewalld` suite, the examples given in this chapter are focusing `nftables` direct configuration.

Note: Although `firewalld` internally also configures `nftables`, using both is not advisable for understandability and maintainability reasons. Therefore only one configuration way should be used.

BL512-2029

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure firewall system is installed and enabled

Rule Ensure one firewall system is installed, enabled and configured:

- Ensure either `nftables`, `firewalld` or `iptables` is installed. `nftables` or `firewalld` is highly recommended.
- Basic configuration providing at least IPv4 and IPv6 firewall tables each with INPUT, FORWARD and OUTPUT chain is set up.

Description

`nftables` allows configuration of the IPv4 and IPv6 tables in the linux kernel and the rules stored within them.

Red Hat Enterprise Linux 8 uses `nftables` instead of `iptables` as firewall backend. Although configuration of `nftables` can be done using tools from the `firewalld` suite and mixed between both firewall systems (and even with `iptables`), the examples given in this chapter are focusing `nftables` direct and only configuration. Therefore `firewall` should be disabled and all potential existing `iptables` rules should be flushed.

`nftables` uses tables as starting point. These tables hold chains, which are containers for rules. They exist in two kinds, base chains and regular chains. A base chain is an entry point for packets from the networking stack, a regular chain may be used as jump target and is used for better rule organization.

For basic configuration, tables for at least `ip` and `ip6`, or `inet` containing both ip-variants, each with chains for INPUT, FILTER and OUTPUT must exist.

Without a table being build, `nftables` will not filter network traffic. If a base chain doesn't exist with a hook for input, forward, and delete, packets that would flow through those chains will not be touched by `nftables`.

Rationale

A firewall system such as `nftables` is required for firewall management and configuration.

For basic setup, tables for at least `ip` and `ip6`, or `inet` containing both `ip`-variants, each with chains for `INPUT`, `FILTER` and `OUTPUT` must exist. Without a table being build, `nftables` will not filter network traffic. If a base chain doesn't exist with a hook for input, forward, and delete, packets that would flow through those chains will not be touched by `nftables`.

I01 - Implementation Example

Run the following command to install `nftables` :

```
# dnf install nftables
```

It is possible to mix `iptables` and `nftables`. However, this increases complexity and also the chance to introduce errors. For simplicity and maintainability reasons, flush out all `iptables` rules, and ensure it is not loaded

Run the following command to flush existing `iptables` rules:

```
# iptables -F
# ip6tables -F
```

Run the following command to enable `nftables` and disable `firewalld`:

```
# systemctl disable firewalld.service
# systemctl stop firewalld.service
# systemctl enable nftables
# systemctl start nftables
```

The basic installation of `nftables` already creates default tables for `ip`, `ipv6` and `bridge`. If those are not present, create at least a table for the `inet` family, using the following command by replacing the placeholder `<tableName>` with an appropriate table name, e.g., `filter`:

```
# nft create table inet <tableName>
```

If base chains for at least the `inet` family table doesn't exist, create the mandatory base chains using the following commands:

```
# nft create chain inet <tableName> input { type filter hook input priority 0 \; }
# nft create chain inet <tableName> forward { type filter hook forward priority 0 \; }
# nft create chain inet <tableName> output { type filter hook output priority 0 \; }
```

C01 - Example Check

Run the following command and verify `ntfables` is installed:

```
# rpm -q nftables
nftables-<version>
```

Run the following commands and verify that no ip(6)tables rules exist:

```
# iptables -nL
Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

# ip6tables -nL
Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

Chain 1 (0 references)
target     prot opt source                destination
```

Run the following commands and verify that nftables is enabled and firewalld is disabled:

```
# systemctl is-enabled firewalld
# systemctl is-enabled nftables
```

Run the following commands and verify that a basic table for the `inet` family exist:

```
# nft list tables
table inet filter
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.5.3

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.3.1

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.3.2

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.3.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8373

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure loopback traffic is restricted to the loopback interface

Rule

Ensure loopback traffic is restricted to the loopback interface.

Description

Configure the loopback interface to accept traffic. Configure all other interfaces to deny traffic to the loopback network (127.0.0.0/8).

Rationale

Loopback traffic is generated between processes on machine and is typically critical to operation of the system. The loopback interface is the only place that loopback network (127.0.0.0/8) traffic should be seen, all other interfaces should ignore traffic on this network as an anti-spoofing measure.

I01 - Implementation Example

Run the following commands to implement the loopback rules, assuming the default table for the `inet` family exists with the name `filter`:

```
# nft add rule inet filter input iif lo accept
# nft add rule inet filter input ip saddr 127.0.0.0/8 counter drop
# nft add rule inet filter input ip6 saddr ::1 counter drop
```

C01 - Example Check

Run the following commands and verify output includes the listed rules in order (packet and byte counts may differ), assuming the default table for the `inet` family exists with the name `filter`:

```
# nft list ruleset | awk '/hook input/,/}/' | grep 'iif "lo" accept'
iif "lo" accept

# nft list ruleset | awk '/hook input/,/}/' | grep 'ip saddr'
ip saddr 127.0.0.0/8 counter packets 0 bytes 0 drop

# nft list ruleset | awk '/hook input/,/}/' | grep 'ip6 saddr'
ip6 saddr ::1 counter packets 0 bytes 0 drop
```

Crossreferences

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.5.2.2

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.3.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-0996

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure firewall rules are permanent

Rule

Ensure firewall rules are permanent and applied during system boots.

Description

nftables is a subsystem of the Linux kernel providing filtering and classification of network packets/datagrams/frames.

The nftables service reads the `/etc/sysconfig/nftables.conf` file for a nftables file or files to include in the nftables ruleset.

A nftables ruleset containing the input, forward, and output base chains allow network traffic to be filtered.

Rationale

Changes made to nftables ruleset only affect the live system, you will also need to configure the nftables ruleset to apply on boot.

I01 - Implementation Example

Edit the `/etc/sysconfig/nftables.conf` file and un-comment or add a line with `include <Absolute path to nftables rules file>` for each nftables file you want included in the nftables ruleset on boot.

example:

```
# vi /etc/sysconfig/nftables.conf
```

Add the line:

```
include "/etc/nftables/nftables.rules"
```

C01 - Example Check

Run the following command to verify input base chain is configured to be applied to a nftables ruleset on boot:

```
# awk '/hook input/,/}/' $(awk '$1 ~ /^s*include/ { gsub("\"", "", $2); print $2 }' /etc/sysconfig/nftables.conf)
```

Output should be similar to:


```
type filter hook input priority 0; policy drop;

# Ensure loopback traffic is configured
iif "lo" accept
ip saddr 127.0.0.0/8 counter packets 0 bytes 0 drop
ip6 saddr ::1 counter packets 0 bytes 0 drop

# Ensure established connections are configured
ip protocol tcp ct state established accept
ip protocol udp ct state established accept
ip protocol icmp ct state established accept

# Accept port 22 (SSH) traffic from anywhere
tcp dport ssh accept

# Accept ICMP and IGMP from anywhere
icmpv6 type { destination-unreachable, packet-too-big, time-exceeded, parameter-problem, mld-listener-
query, mld-listener-report, mld-listener-done, nd-router-solicit, nd-router-advert, nd-neighbor-solicit,
nd-neighbor-advert, ind-neighbor-solicit, ind-neighbor-advert, mld2-listener-report } accept
```

Note: Review the input base chain to ensure that it follows local site policy

Run the following command to verify the forward base chain configured to be applied to a nftables ruleset on boot:

```
# awk '/hook forward/,/}/' $(awk '$1 ~ /^s*include/ { gsub("\"", "", $2); print $2 }'
/etc/sysconfig/nftables.conf)
```

Output should be similar to:

```
# Base chain for hook forward named forward (Filters forwarded network packets)
chain forward {
type filter hook forward priority 0; policy drop;
}
```

Note: Review the forward base chain to ensure that it follows local site policy.

Run the following command to verify the output base chain configured to be applied to a nftables ruleset on boot:

```
# awk '/hook output/,/}/' $(awk '$1 ~ /^s*include/ { gsub("\"", "", $2); print $2 }'
/etc/sysconfig/nftables.conf)
```

Output should be similar to:

```
# Base chain for hook output named output (Filters outbound network packets)
chain output {
type filter hook output priority 0; policy drop;
# Ensure outbound and established connections are configured
ip protocol tcp ct state established,related,new accept
ip protocol tcp ct state established,related,new accept
ip protocol udp ct state established,related,new accept
ip protocol icmp ct state established,related,new accept
}
```

Note: Review the output base chain to ensure that it follows local site policy.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.3.8

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Generalized wording to firewall rules, not just nftables rules.

BL512-4800

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure default deny firewall policy is active

Rule Ensure default deny firewall policy for the input chain is active.

Note: This only configures the default policy used for packages, which are not handled by dedicated filter rules allowing packets on dedicated ports. Ports used by services operated in the system are permitted to be configured to be accepted on a dedicated port base.

Note: Before enabling DROP-policy, it is recommended to create an allow rule for already established connections, otherwise networking may not work as expected.

Note: If working on remote systems, configure port-based allow rule for involved management port for new packets, such as SSH, before enabling DROP-policy.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a listening service.

Description

Base chain policy is the default verdict that will be applied to packets reaching the end of the chain. A default deny all policy on connections ensures that any unconfigured network usage will be rejected.

Rationale

With a default accept policy the firewall will accept any packet that is not configured to be denied. It is easier to white list acceptable usage than to blacklist unacceptable usage.

I01 - Implementation Example

Run the following commands to implement a default DROP policy, assuming the default table for the `inet` family exists with the name `filter`:

```
# nft chain inet filter input { policy drop \; }
```

It is recommended to allow already established connections in input direction, otherwise networking may not work as expected:

```
# nft add rule ip filter INPUT ct state established accept
```

C01 - Example Check

Run the following command and verify that the policy for the `input` chain is `DROP` or `REJECT`, assuming the default table for the `inet` family exists with the name `filter`:

```
# nft list ruleset | grep 'hook input'  
type filter hook input priority 0; policy drop;
```

Crossreferences

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 3.5.2.1

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 3.4.3.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Reworked to default deny only on input chain; added exemption for external firewall; added note that port-based allow-rules are permitted.

BL512-1120

Asset Manager

EVAL until 2020-12-31

C	I	A
3	3	3

Disable Bluetooth

Rule

Disable the bluetooth service and prevent loading of bluetooth kernel modules.

Description

The Bluetooth service supports discovery and association of remote Bluetooth devices.

Rationale

Bluetooth technology has inherent security risks - especially prior to the v2.1 standard. Wireless Bluetooth traffic is not well encrypted (if at all), so in a high-security environment, it should not be permitted, in spite of the added inconvenience of not being able to use Bluetooth devices.

I01 - Implementation

To prevent loading of bluetooth related kernel modules, edit or create the file `/etc/modprobe.d/disableBluetooth.conf` and add the following lines:

```
install bnep /bin/true
install bluetooth /bin/true
install btusb /bin/true
```

Run the following commands to unload already loaded kernel modules:

```
# rmmod bnep
# rmmod bluetooth
# rmmod btusb
```

Furthermore, disable the systemd service unit for bluetooth using the following commands:

```
# systemctl disable bluetooth.service
# systemctl mask bluetooth.service
# systemctl stop bluetooth.service
```

C01 - Example Check

Run the following commands and verify the output is as indicated:

```
# modprobe -n -v bnep
install /bin/true

# modprobe -n -v bluetooth
install /bin/true

# modprobe -n -v btusb
install /bin/true

# lsmod | grep bnep
# lsmod | grep bluetooth
# lsmod | grep btusb

# systemctl is-enabled bluetooth.service
inactive
```

Crossreferences

Based on superseded measure M740601

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs.

Logging and Auditing

The items in this section describe how to configure logging, log monitoring, and auditing, using standard tools included in Red Hat Enterprise Linux.

It is recommended that `rsyslog` be used for logging (with `logwatch` providing summarization) and `auditd` be used for auditing (with `aureport` providing summarization) to automatically monitor logs for intrusion attempts and other suspicious system behavior.

In addition to the local log files created by the steps in this section, it is also recommended that sites collect copies of their system logs on a secure, centralized log server via an encrypted connection. Not only does centralized logging help sites correlate events that may be occurring on multiple systems, but having a second copy of the system log information may be critical after a system compromise where the attacker has modified the local log files on the affected system(s). If a log correlation system is deployed, configure it to process the logs described in this section.

It is important that all logs described in this section be monitored on a regular basis and correlated to determine trends. A seemingly innocuous entry in one log could be more significant when compared to an entry in another log.

Note on log file permissions: There really isn't a "one size fits all" solution to the permissions on log files. Many sites utilize group permissions so that administrators who are in a defined security group, such as "wheel" do not have to elevate privileges to root in order to read log files. Also, if a third party log aggregation tool is used, it may need to have group permissions to read the log files, which is preferable to having it run setuid to root. Therefore, there are two remediation and audit steps for log file permissions. One is for systems that do not have a secured group method implemented that only permits root to read the log files (`root:root 600`). The other is for sites that do have such a setup and are designated as `root:securegrp 640` where `securegrp` is the defined security group (in some cases `wheel`).

Configure System Accounting (auditd)

System auditing, through `auditd`, allows system administrators to monitor their systems such that they can detect unauthorized access or modification of data. By default, `auditd` will audit SELinux AVC denials, system logins, account modifications, and authentication events. Events will be logged to `/var/log/audit/audit.log`. The recording of these events will use a modest amount of disk space on a system. If significantly more events are captured, additional on system or off system storage may need to be allocated.

The recommendations in this section implement an audit policy that produces large quantities of logged data. In some environments it can be challenging to store or process these logs and as such they are marked as Level 2 for both Servers and Workstations.

Note: Once all configuration changes have been made to `/etc/audit/rules.d/audit.rules`, the `auditd` configuration must be reloaded:

```
# service auditd reload
```

Configure Data Retention

When auditing, it is important to carefully configure the storage requirements for audit logs. By default, auditd will max out the log files at 5MB and retain only 4 copies of them. Older versions will be deleted. It is possible on a system that the 20 MBs of audit logs may fill up the system causing loss of audit data. While the recommendations here provide guidance, check your site policy for audit storage requirements and data retention regulations also with respect to data privacy.

BL512-4017

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure audit log storage size is configured

Rule Ensure audit log storage size is configured to reasonable size depending on system's usage.

Description

Configure the maximum size of the audit log file. Once the log reaches the maximum size, it will be rotated, and a new log file will be started.

Rationale

It is important that an appropriate size is determined for log files so that they do not impact the system and audit data is not lost.

I01 - Implementation Example

Set the following parameter in `/etc/audit/auditd.conf` in accordance with site policy by replacing the placeholder `<MB>` with an appropriate value:

```
max_log_file = <MB>
```

C01 - Example Check

Run the following command and ensure output is in compliance with site policy:

```
# grep max_log_file /etc/audit/auditd.conf
max_log_file =
```

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.4.1-04

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.2.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.1.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8; adjusted ACP level to CIA 1, 2, and 3.

BL512-9036

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure at least notice mail is sent to an active mail account when audit log storage is full

Rule Ensure at least notice mail is sent to an active mail account when audit log storage is full:

- Set space_left_action to email.

Description

The auditd daemon can be configured to halt or suspend the system or at least send a notification mail when the audit logs are full.

Rationale

In high security contexts, the risk of detecting unauthorized access or nonrepudiation can exceed the benefit of the system's availability. Depending on the availability requirements, the appropriate value to halt, suspend or at least send a notification mail should be configured.

I01 - Implementation Example

Set the following parameters in /etc/audit/auditd.conf:

```
space_left_action = email
admin_space_left_action = email
action_mail_acct = root
```

C01 - Example Check

Run the following commands and verify output matches:

```
# grep space_left_action /etc/audit/auditd.conf
space_left_action = email
# grep action_mail_acct /etc/audit/auditd.conf
action_mail_acct = root
# grep admin_space_left_action /etc/audit/auditd.conf
admin_space_left_action = email
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.2.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added 'admin_space_left_action' according feedback from review meetings. Fixed missing grep-output in check. Aligned rationale and description to relaxed rule text.

BL512-8755

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure audit logs are not automatically deleted

Rule

Ensure audit logs are not automatically deleted.

E01 - Exemption

This rule is not mandatory, if all logs and audit logs are sent to a central, remote logging server.

Description

The `max_log_file_action` setting determines how to handle the audit log file reaching the max file size. A value of `keep_logs` will rotate the logs but never delete old logs.

Rationale

In high security contexts, the benefits of maintaining a long audit history exceed the cost of storing the audit history.

I01 - Implementation Example

Set the following parameter in `/etc/audit/auditd.conf`:

```
max_log_file_action = keep_logs
```

C01 - Example Check

Run the following command and verify output matches:

```
# grep max_log_file_action /etc/audit/auditd.conf
max_log_file_action = keep_logs
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.2.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Relaxed to CIA23, added exemption 01 according feedback from review meetings.

BL512-3171

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure auditd service is installed and enabled

Rule Ensure auditd service is installed and enabled.

Description

Auditd is the userspace component to the Linux Auditing System. It's responsible for writing audit records to the disk. Turn on the auditd daemon to record system events.

Rationale

The capturing of system events provides system administrators with information to allow them to determine if unauthorized access to their system is occurring.

I01 - Implementation Example

Run the following command to Install auditd

```
# dnf install audit audit-libs
```

Run the following command to enable auditd :

```
# systemctl enable auditd
```

C01 - Example Check

Run the following command and verify auditd is installed:

```
# rpm -q audit audit-libs
```

Run the following command and verify result is "enabled":

```
# systemctl is-enabled auditd  
enabled
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.1.1

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8; adjusted ACP level to CIA 1, 2, and 3.

BL512-3000

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure auditing for processes that start prior to auditd is enabled

Rule

Ensure auditing for processes that start prior to auditd is enabled.

Description

Configure `grub` so that processes that are capable of being audited can be audited even if they start up prior to `auditd` startup.

Rationale

Audit events need to be captured on processes that start up prior to `auditd`, so that potential malicious activity cannot go undetected.

I01 - Implementation Example

Edit `/etc/default/grub` and add `audit=1` to `GRUB_CMDLINE_LINUX`:

```
GRUB_CMDLINE_LINUX="audit=1"
```

Run the following command to update the `grub2` configuration:

```
# grub2-mkconfig -o /boot/grub2/grub.cfg
```

C01 - Example Check

Run the following command and verify that each linux line has the `audit=1` parameter set:

```
# grep "^s*linux" /boot/grub2/grub.cfg
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8; adjusted ACP level to CIA 1, 2, and 3.

BL512-4188

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure events that modify date and time information are collected

Rule

Ensure events that modify date and time information are collected.

Description

Capture events where the system date and/or time has been modified. The parameters in this section are set to determine if the `adjtimex` (tune kernel clock), `settimeofday` (Set time, using `timeval` and `timezone` structures) `stime` (using seconds since 1/1/1970) or `clock_settime` (allows for the setting of several internal clocks and timers) system calls have been executed and always write an audit record to the `/var/log/audit.log` file upon exit, tagging the records with the identifier "time-change"

Rationale

Unexpected changes in system date and/or time could be a sign of malicious activity on the system.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-a always,exit -F arch=b64 -S adjtimex -S settimeofday -k time-change
-a always,exit -F arch=b64 -S clock_settime -k time-change
-w /etc/localtime -p wa -k time-change
```

C01 - Example Check

Run the following commands:

```
# grep time-change /etc/audit/rules.d/audit.rules
# auditctl -l | grep time-change
```

Verify output of both matches:

```
-a always,exit -F arch=b64 -S adjtimex -S settimeofday -k time-change
-a always,exit -F arch=b64 -S clock_settime -k time-change
-w /etc/localtime -p wa -k time-change
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-2129

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure events that modify user/group information are collected

Rule

Ensure events that modify user/group information are collected.

Description

Record events affecting the `group`, `passwd` (user IDs), `shadow` and `gshadow` (passwords) or `/etc/security/opasswd` (old passwords, based on remember parameter in the PAM configuration) files. The parameters in this section will watch the files to see if they have been opened for write or have had attribute changes (e.g., permissions) and tag them with the identifier "identity" in the audit log file.

Rationale

Unexpected changes to these files could be an indication that the system has been compromised and that an unauthorized user is attempting to hide their activities or compromise additional accounts.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-w /etc/group -p wa -k identity
-w /etc/passwd -p wa -k identity
-w /etc/gshadow -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/security/opasswd -p wa -k identity
```

C01 - Example Check

Run the following commands:

```
# grep identity /etc/audit/rules.d/audit.rules
# auditctl -l | grep identity
```

Verify output of both matches:

```
-w /etc/group -p wa -k identity
-w /etc/passwd -p wa -k identity
-w /etc/gshadow -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/security/opasswd -p wa -k identity
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.11

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-3300

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure events that modify the system's network environment are collected

Rule

Ensure events that modify the system's network environment are collected.

Description

Record changes to network environment files or system calls. The below parameters monitor the `sethostname` (set the systems host name) or `setdomainname` (set the systems domainname) system calls, and write an audit event on system call exit. The other parameters monitor the `/etc/issue` and `/etc/issue.net` files (messages displayed pre-login), `/etc/hosts` (file containing host names and associated IP addresses), `/etc/sysconfig/network` file and `/etc/sysconfig/network-scripts/` directory (containing network interface scripts and configurations).

Rationale

Monitoring `sethostname` and `setdomainname` will identify potential unauthorized changes to host and domainname of a system. The changing of these names could potentially break security parameters that are set based on those names. The `/etc/hosts` file is monitored for changes in the file that can indicate an unauthorized intruder is trying to change machine associations with IP addresses and trick users and processes into connecting to unintended machines. Monitoring `/etc/issue` and `/etc/issue.net` is important, as intruders could put disinformation into those files and trick users into providing information to the intruder. Monitoring `/etc/sysconfig/network` and `/etc/sysconfig/network-scripts/` is important as it can show if network interfaces or scripts are being modified in a way that can lead to the machine becoming unavailable or compromised. All audit records will be tagged with the identifier "system-locale."

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-a always,exit -F arch=b64 -S sethostname -S setdomainname -k system-locale
-w /etc/issue -p wa -k system-locale
-w /etc/issue.net -p wa -k system-locale
-w /etc/hosts -p wa -k system-locale
-w /etc/sysconfig/network -p wa -k system-locale
-w /etc/sysconfig/network-scripts -p wa -k system-locale
```

C01 - Example Check

Run the following commands:

```
# grep system-locale /etc/audit/rules.d/audit.rules
# auditctl -l | grep system-locale
```

Verify output of both matches:

```
-a always,exit -F arch=b64 -S sethostname -S setdomainname -k system-locale  
-w /etc/issue -p wa -k system-locale  
-w /etc/issue.net -p wa -k system-locale  
-w /etc/hosts -p wa -k system-locale  
-w /etc/sysconfig/network -p wa -k system-locale  
-w /etc/sysconfig/network-scripts -p wa -k system-locale
```

Note: The output of auditctl slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks. Fixed wrong value with slash in implementation and checks.

BL512-3122

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure events that modify the system's Mandatory Access Controls are collected

Rule

Ensure events that modify the system's Mandatory Access Controls are collected.

E01 - Exemption

This rule is only mandatory, if rule [BL512-3891 - Ensure the SELinux state is enforcing](#) is applied.

Description

Monitor SELinux mandatory access controls. The parameters below monitor any write access (potential additional, deletion or modification of files in the directory) or attribute changes to the `/etc/selinux` directory.

Rationale

Changes to files in these directories could indicate that an unauthorized user is attempting to modify access controls and change security contexts, leading to a compromise of the system.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-w /etc/selinux/ -p wa -k MAC-policy  
-w /usr/share/selinux/ -p wa -k MAC-policy
```

C01 - Example Check

Run the following command and verify output matches:

```
# grep MAC-policy /etc/audit/rules.d/audit.rules  
-w /etc/selinux/ -p wa -k MAC-policy  
-w /usr/share/selinux/ -p wa -k MAC-policy
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.8

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings. Fixed wrong path for implementation and checks.

BL512-9024

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure login and logout events are collected

Rule

Ensure login and logout events are collected.

Description

Monitor login and logout events. The parameters below track changes to files associated with login/logout events. The file `/var/log/lastlog` maintain records of the last time a user successfully logged in. The `/var/run/faillock` directory maintains records of login failures via the `pam_faillock` module.

Rationale

Monitoring login/logout events could provide a system administrator with information associated with brute force attacks against user logins.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-w /var/log/lastlog -p wa -k logins  
-w /var/run/faillock/ -p wa -k logins
```

C01 - Example Check

Run the following command and verify output matches:

```
# grep logins /etc/audit/rules.d/audit.rules  
-w /var/log/lastlog -p wa -k logins  
-w /var/run/faillock/ -p wa -k logins
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.9

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-3329

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure session initiation information is collected

Rule Ensure session initiation information is collected.

Description

Monitor session initiation events. The parameters in this section track changes to the files associated with session events. The file `/var/run/utmp` file tracks all currently logged in users. All audit records will be tagged with the identifier "session." The `/var/log/wtmp` file tracks logins, logouts, shutdown, and reboot events. The file `/var/log/btmp` keeps track of failed login attempts and can be read by entering the command `/usr/bin/last -f /var/log/btmp`. All audit records will be tagged with the identifier "logins."

Rationale

Monitoring these files for changes could alert a system administrator to logins occurring at unusual hours, which could indicate intruder activity (i.e. a user logging in at a time when they do not normally log in).

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-w /var/run/utmp -p wa -k session
-w /var/log/wtmp -p wa -k logins
-w /var/log/btmp -p wa -k logins
```

C01 - Example Check

Run the following commands:

```
# grep session /etc/audit/rules.d/audit.rules
# auditctl -l | grep session
```

Verify output of both matches:

```
-w /var/run/utmp -p wa -k session
```

Run the following commands:

```
# grep logins /etc/audit/rules.d/audit.rules
# auditctl -l | grep logins
```

Verify output of both matches:


```
-w /var/log/wtmp -p wa -k logins  
-w /var/log/btmp -p wa -k logins
```

Note: The output of auditctl slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.10

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-6000

Asset Manager

EVAL until 2020-12-31

C	I	A
23	23	23

Ensure discretionary access control permission modification events are collected

Rule

Ensure discretionary access control permission modification events are collected.

E01 - Exemption

This rule is not mandatory, if a third-party solution, such as CyberArk, is used, already capable of providing information for these modification events.

Description

Monitor changes to file permissions, attributes, ownership and group. The parameters in this section track changes for system calls that affect file permissions and attributes. The `chmod`, `fchmod` and `fchmodat` system calls affect the permissions associated with a file. The `chown`, `fchown`, `fchownat` and `lchown` system calls affect owner and group attributes on a file. The `setxattr`, `lsetxattr`, `fsetxattr` (set extended file attributes) and `removexattr`, `lremovexattr`, `fremovexattr` (remove extended file attributes) control extended file attributes. In all cases, an audit record will only be written for interactive user ids (`audit >= 1000`) and will ignore Daemon events (`audit = 4294967295`). All audit records will be tagged with the identifier "perm_mod."

Rationale

Monitoring for changes in file attributes could alert a system administrator to activity that could indicate intruder activity or policy violation.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-a always,exit -F arch=b64 -S chmod -S fchmod -S fchmodat -F audit>=1000 -F audit!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S chown -S fchown -S fchownat -S lchown -F audit>=1000 -F audit!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S setxattr -S lsetxattr -S fsetxattr -S removexattr -S lremovexattr -S fremovexattr -F audit>=1000 -F audit!=4294967295 -k perm_mod
```

C01 - Example Check

Run the following commands:

```
# grep perm_mod /etc/audit/rules.d/audit.rules
# auditctl -l | grep perm_mod
```

Verify output of both matches:

```
-a always,exit -F arch=b64 -S chmod -S fchmod -S fchmodat -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S chown -S fchown -S fchownat -S lchown -F auid>=1000 -F auid!=4294967295 -k
perm_mod
-a always,exit -F arch=b64 -S setxattr -S lsetxattr -S fsetxattr -S removexattr -S lremovexattr -S
fremovexattr -F auid>=1000 -F auid!=4294967295 -k perm_mod
```

Note: The output of auditctl slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.11

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings. Fixed wrong path for implementation and checks.

BL512-8834

EVAL until 2020-12-31

Asset Manager

C	I	A
23	23	23

Ensure use of privileged commands is collected

Rule

Ensure use of privileged commands is collected.

E01 - Exemption

This rule is not mandatory, if a third-party solution, such as CyberArk, is used, already capable of providing information for these modification events.

Description

Monitor privileged programs (those that have the setuid and/or setgid bit set on execution) to determine if unprivileged users are running these commands.

Rationale

Execution of privileged commands by non-privileged users could be an indication of someone trying to gain unauthorized access to the system.

I01 - Implementation Example

To remediate this issue, the system administrator will have to execute a find command to locate all the privileged programs and then add an audit line for each one of them. The audit parameters associated with this are as follows: `-F path=" $1 "` - will populate each file name found through the find command and processed by awk. `-F perm=x` - will write an audit record if the file is executed. `-F auid>=1000` - will write a record if the user executing the command is not a privileged user. `-F auid!= 4294967295` - will ignore Daemon events

All audit records should be tagged with the identifier "privileged".

Run the following command replacing `<partition>` with a list of partitions where programs can be executed from on your system:

```
# find <partition> -xdev \( -perm -4000 -o -perm -2000 \) -type f | awk '{print \
"-a always,exit -F path=" $1 " -F perm=x -F auid>=1000 -F auid!=4294967295 \
-k privileged" }'
```

Add all resulting lines to the `/etc/audit/rules.d/audit.rules` file.

C01 - Example Check

Run the following command replacing `<partition>` with a list of partitions where programs can be executed from on your system:

```
# find <partition> -xdev \( -perm -4000 -o -perm -2000 \) -type f | awk '{print \
"-a always,exit -F path=" $1 " -F perm=x -F auid>=1000 -F auid!=4294967295 \
-k privileged" }'
```

Verify all resulting lines are in the `/etc/audit/rules.d/audit.rules` file and the output of `auditctl -l`.

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.13

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.13

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings. Fixed wrong path for implementation and checks.

BL512-6052

EVAL until 2020-12-31

Asset Manager

C	I	A
23	23	23

Ensure successful file system mounts are collected

Rule

Ensure successful file system mounts are collected.

Description

Monitor the use of the `mount` system call. The `mount` (and `umount`) system call controls the mounting and unmounting of file systems. The parameters below configure the system to create an audit record when the `mount` system call is used by a non-privileged user

Rationale

It is highly unusual for a non-privileged user to `mount` file systems to the system. While tracking `mount` commands gives the system administrator evidence that external media may have been mounted (based on a review of the source of the `mount` and confirming it's an external media type), it does not conclusively indicate that data was exported to the media. System administrators who wish to determine if data were exported, would also have to track successful `open`, `create` and `truncate` system calls requiring write access to a file under the `mount` point of the external media file system. This could give a fair indication that a write occurred. The only way to truly prove it, would be to track successful writes to the external media. Tracking write system calls could quickly fill up the audit log and is not recommended. Recommendations on configuration options to track data export to media is beyond the scope of this document.

I01 - Implementation Example

Add the following line to the `/etc/audit/rules.d/audit.rules` file:

```
-a always,exit -F arch=b64 -S mount -F auid>=1000 -F auid!=4294967295 -k mounts
```

C01 - Example Check

Run the following commands:

```
# grep mounts /etc/audit/rules.d/audit.rules
# auditctl -l | grep mounts
```

Verify output of both matches:

```
-a always,exit -F arch=b64 -S mount -F auid>=1000 -F auid!=4294967295 -k mounts
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.12

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.14

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-2122

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure changes to system administration scope (sudoers) is collected

Rule

Ensure changes to system administration scope (sudoers) is collected.

Description

Monitor scope changes for system administrations. If the system has been properly configured to force system administrators to log in as themselves first and then use the `sudo` command to execute privileged commands, it is possible to monitor changes in scope. The file `/etc/sudoers` will be written to when the file or its attributes have changed. The audit records will be tagged with the identifier "scope."

Rationale

Changes in the `/etc/sudoers` file can indicate that an unauthorized change has been made to scope of system administrator activity.

I01 - Implementation Example

Add the following line to the `/etc/audit/rules.d/audit.rules` file:

```
-w /etc/sudoers -p wa -k scope  
-w /etc/sudoers.d -p wa -k scope
```

C01 - Example Check

Run the following commands:

```
# grep scope /etc/audit/rules.d/audit.rules  
# auditctl -l | grep scope
```

Verify output of both matches:

```
-w /etc/sudoers -p wa -k scope  
-w /etc/sudoers.d -p wa -k scope
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.16

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks. Fixed wrong value with slash in implementation and checks.

BL512-8216

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure system administrator actions (sudolog) are collected

Rule

Ensure system administrator actions (sudolog) are collected.

Description

Monitor the `sudo` log file. If the system has been properly configured to disable the use of the `su` command and force all administrators to have to log in first and then use `sudo` to execute privileged commands, then all administrator commands will be logged to `/var/log/sudo.log`. Any time a command is executed, an audit event will be triggered as the `/var/log/sudo.log` file will be opened for write and the executed administration command will be written to the log.

Rationale

Changes in `/var/log/sudo.log` indicate that an administrator has executed a command or the log file itself has been tampered with. Administrators will want to correlate the events written to the audit trail with the records written to `/var/log/sudo.log` to verify if unauthorized commands have been executed.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-w /var/log/sudo.log -p wa -k actions
```

C01 - Example Check

Run the following commands:

```
# grep actions /etc/audit/rules.d/audit.rules
# auditctl -l | grep actions
```

Verify output of both matches:

```
-w /var/log/sudo.log -p wa -k actions
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.16

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.17

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-3376

EVAL until 2020-12-31

Asset Manager

C	I	A
23	23	23

Ensure kernel module loading and unloading is collected

Rule

Ensure kernel module loading and unloading is collected.

Description

Monitor the loading and unloading of kernel modules. The programs `insmod` (install a kernel module), `rmmod` (remove a kernel module), and `modprobe` (a more sophisticated program to load and unload modules, as well as some other features) control loading and unloading of modules. The `init_module` (load a module) and `delete_module` (delete a module) system calls control loading and unloading of modules. Any execution of the loading and unloading module programs and system calls will trigger an audit record with an identifier of "modules".

Rationale

Monitoring the use of `insmod`, `rmmod` and `modprobe` could provide system administrators with evidence that an unauthorized user loaded or unloaded a kernel module, possibly compromising the security of the system. Monitoring of the `init_module` and `delete_module` system calls would reflect an unauthorized user attempting to use a different program to load and unload modules.

I01 - Implementation Example

Add the following lines to the `/etc/audit/rules.d/audit.rules` file:

```
-w /sbin/insmod -p x -k modules
-w /sbin/rmmod -p x -k modules
-w /sbin/modprobe -p x -k modules
-a always,exit -F arch=b64 -S init_module -S delete_module -k modules
```

C01 - Example Check

Run the following commands:

```
# grep modules /etc/audit/rules.d/audit.rules
# auditctl -l | grep modules
```

Verify output of both matches:

```
-w /sbin/insmod -p x -k modules
-w /sbin/rmmod -p x -k modules
-w /sbin/modprobe -p x -k modules
-a always,exit -F arch=b64 -S init_module -S delete_module -k modules
```

Note: The output of `auditctl` slightly differs in syntax: `-k <value>` vs `-F key=<value>`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.15

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.1.18

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed wrong path for implementation and checks.

BL512-0995

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure audit_backlog_limit is sufficient

Rule

Ensure audit_backlog_limit is sufficient for auditing the entire system boot process:

- Set audit_backlog_limit to a value of 8192 or larger.

Description

The backlog limit has a default setting of 64, which is rather limited for appropriate boot auditing.

Rationale

During boot if audit=1, then the backlog will hold 64 records. If more than 64 records are created during boot, auditd records will be lost and potential malicious activity could go undetected.

I01 - Implementation Example

Edit /etc/default/grub and add audit_backlog_limit=<BACKLOG SIZE> to GRUB_CMDLINE_LINUX:

Example:

```
GRUB_CMDLINE_LINUX="audit_backlog_limit=8192"
```

Run the following command to update the grub2 configuration:

```
# grub2-mkconfig -o /boot/grub2/grub.cfg
```

C01 - Example Check

Run the following command and verify the audit_backlog_limit= parameter is set to an appropriate size for your organization

```
# grep -E 'kernelopts=(\S+\s+)*audit_backlog_limit=\S+\b' /boot/grub2/grubenv
```

Validate that the line(s) returned contain a value for audit_backlog_limit= and the value is sufficient for your organization.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.1.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

Configure Logging

Logging services must be configured to prevent information leaks and to aggregate logs on a remote server so that they can be reviewed in the event of a system compromise and ease log analysis.

As the default logging system in Red Hat Enterprise system is `rsyslog`, the rules and configuration is focusing `rsyslog` here.

BL512-9045

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure logging system is installed

Rule

Ensure logging system, such as `rsyslog` or `syslog-ng`, is installed.

Description

The `rsyslog` software is a recommended replacement to the original `syslogd` daemon which provide improvements over `syslogd`, such as connection-oriented (i.e. TCP) transmission of logs, the option to log to database formats, and the encryption of log data en route to a central logging server.

Rationale

The security enhancements of `rsyslog` such as connection-oriented (i.e. TCP) transmission of logs, the option to log to database formats, and the encryption of log data en route to a central logging server) justify installing and configuring the package.

I01 - Implementation Example

Install `rsyslog` using the following command:

```
# dnf install rsyslog
```

C01 - Example Check

Run the following command and verify the `rsyslog` package is installed:

```
# rpm -q rsyslog
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.1.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Generalized to 'logging system' without forcing rsyslog.

BL512-4269

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on all logfiles are configured

Rule Ensure permissions on all log files are configured:

- Remove group write/execute permissions on all log files,
- Remove other read/write/execute permissions on all log files,
- The system log file `btmpt` must be set to permission level of 660,
- The system log file `wtmp` must be set to permission level of 664.
- The system log file `lastlog` can by default set to permission level of 664.

Description

Log files stored in `/var/log/` contain logged information from many services on the system, or on log hosts others as well.

Rationale

It is important to ensure that log files have the correct permissions to ensure that sensitive data is archived and protected.

I01 - Implementation Example

Run the following command to set permissions on all existing log files:

```
# find /var/log -type f -not -name "wtmp" -not -name "btmpt" -not -name "lastlog" -exec chmod g-wx,o-rwx {} +
```

C01 - Example Check

Run the following command and verify that `other` has no permissions on any files and `group` does not have write or execute permissions on any files:

```
# find /var/log -type f -ls
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed implementation to exclude btmp, wtmp, lastlog which have different permission level.

Configure rsyslog

The `rsyslog` software is recommended as a replacement for the `syslogd` daemon and provides improvements over `syslogd`, such as connection-oriented (i.e. TCP) transmission of logs, the option to log to database formats, and the encryption of log data en route to a central logging server.

BL512-5686

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure logging system is enabled

Rule

Ensure logging system, such as `rsyslog` or `syslog-ng`, is enabled.

Description

Once the `rsyslog` package is installed it needs to be activated.

Rationale

If the `rsyslog` service is not activated the system may default to the `syslogd` service or lack logging at all.

I01 - Implementation Example

Run the following command to enable `rsyslog` :

```
# systemctl enable rsyslog
```

C01 - Example Check

Run the following command and verify result is "enabled":

```
# systemctl is-enabled rsyslog
enabled
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Generalized to 'logging system' without forcing `rsyslog`.

BL512-9918

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure logging is configured

Rule

Ensure logging is configured according system and environment requirements.

Description

The `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files specifies rules for logging and which files are to be used to log certain classes of messages.

Rationale

A great deal of important security-related information is sent via `rsyslog` (e.g., successful and failed su attempts, failed login attempts, root login attempts, etc.).

I01 - Implementation Example

Edit the following lines in the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files as appropriate for your environment:

```
*.emerg :omusrmsg:*
mail.* -/var/log/mail
mail.info -/var/log/mail.info
mail.warning -/var/log/mail.warn
mail.err /var/log/mail.err
news.crit -/var/log/news/news.crit
news.err -/var/log/news/news.err
news.notice -/var/log/news/news.notice
*.=warning;*.=err -/var/log/warn
*.crit /var/log/warn
*.*;mail.none;news.none -/var/log/messages
local0,local1.* -/var/log/localmessages
local2,local3.* -/var/log/localmessages
local4,local5.* -/var/log/localmessages
local6,local7.* -/var/log/localmessages
```

Run the following command to reload the `rsyslogd` configuration:

```
# pkill -HUP rsyslogd
```

C01 - Example Check

Review the contents of the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files to ensure appropriate logging is set. In addition, run the following command and verify that the log files are logging information:

```
# ls -l /var/log/
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1878

Eval until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure log file default file permissions are configured

Rule

Ensure log file default file permissions are set to 0640 or more restrictive.

Description

rsyslog will create logfiles that do not already exist on the system. This setting controls what permissions will be applied to these newly created files.

Rationale

It is important to ensure that log files have the correct permissions to ensure that sensitive data is archived and protected.

I01 - Implementation Example

Edit the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files and set `$FileCreateMode` to 0640 or more restrictive:

```
$FileCreateMode 0640
```

C01 - Example Check

Run the following command and verify that `$FileCreateMode` is 0640 or more restrictive:

```
# grep ^\$FileCreateMode /etc/rsyslog.conf /etc/rsyslog.d/*.conf
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (Eval until 2020-12-31)

Generalized to 'logging system' without forcing rsyslog.

BL512-4792

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure remote logging messages are only accepted on designated log hosts

Rule

Ensure remote logging messages are only accepted on designated log hosts.

E01 - Exemption

This rule is not mandatory, if the system is **not** used as log aggregator/collector.

Description

By default, `rsyslog` does not listen for log messages coming in from remote systems. The `ModLoad` tells `rsyslog` to load the `imtcp.so` module so it can listen over a network via TCP. The `InputTCPServerRun` option instructs `rsyslogd` to listen on the specified TCP port.

Rationale

The guidance in the section ensures that remote log hosts are configured to only accept `rsyslog` data from hosts within the specified domain and that those systems that are not designed to be log hosts do not accept any remote `rsyslog` messages. This provides protection from spoofed log data and ensures that system administrators are reviewing reasonably complete syslog data in a central location.

I01 - Implementation Example

For hosts that are designated as log hosts, edit the `/etc/rsyslog.conf` file and un-comment or add the following lines:

```
$ModLoad imtcp
$InputTCPServerRun 514
```

For hosts that are not designated as log hosts, edit the `/etc/rsyslog.conf` file and comment or remove the following lines:

```
# $ModLoad imtcp
# $InputTCPServerRun 514
```

Run the following command to reload the `rsyslogd` configuration:

```
# pkill -HUP rsyslogd
```

C01 - Example Check

Run the following commands and verify the resulting lines are uncommented on designated log hosts and commented or removed on all others:

```
# grep '$ModLoad imtcp' /etc/rsyslog.conf /etc/rsyslog.d/*.conf
$ModLoad imtcp
# grep '$InputTCPServerRun' /etc/rsyslog.conf /etc/rsyslog.d/*.conf
$InputTCPServerRun 514
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.1.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.1.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Generalized to 'logging system' without forcing rsyslog.

Configure journald

systemd-journald is a system service that collects and stores logging data. It creates and maintains structured, indexed journals based on logging information that is received from a variety of sources: Kernel log messages, via `kmsg`. As the default logging system in Red Hat Enterprise system is `rsyslog`, logs from journald must be forwarded to `rsyslog` to ensure a central management of configuration options with respect to for instance persistence or forwarding to external logging system etc.

Any changes made to the systemd-journald configuration will require a re-start of systemd-journald.

BL512-5158

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure journald is configured to send logs to syslog logging service

Rule Ensure journald is configured to send logs to syslog logging service, such as `rsyslog` or `syslog-ng`.

Description

Data from journald may be stored in volatile memory or persisted locally on the server. Utilities exist to accept remote export of journald logs, however, use of the `rsyslog` service provides a consistent means of log collection and export.

Rationale

As the default logging system in Red Hat Enterprise system is `rsyslog`, logs from journald must be forwarded to `rsyslog` to ensure a central management of configuration options with respect to for instance persistence or forwarding to external logging system etc.

I01 - Implementation Example

Edit the `/etc/systemd/journald.conf` file and add the following line:

```
ForwardToSyslog=yes
```

Execute the following command to restart journald:

```
# systemctl restart systemd-journald
```

C01 - Example Check

Review `/etc/systemd/journald.conf` and verify that logs are forwarded to syslog

```
# grep -e ForwardToSyslog /etc/systemd/journald.conf
ForwardToSyslog=yes
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.2.2.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.2.2.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Generalized to 'logging system' without forcing rsyslog.

BL512-8372

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure logrotate is configured

Rule

Ensure logrotate is configured:

- Automatic execution once a day,
- All generated log files relevant for rotation must be included in logrotate configuration.

Description

The system includes the capability of rotating log files regularly to avoid filling up the system with logs or making the logs unmanageable large. The file `/etc/logrotate.d/syslog` is the configuration file used to rotate log files created by `syslog` or `rsyslog`.

Rationale

By keeping the log files smaller and more manageable, a system administrator can easily archive these files to another system and spend less time looking through inordinately large log files.

I01 - Implementation Example

Edit `/etc/logrotate.conf` and `/etc/logrotate.d/*` to ensure logs are rotated according to site policy.

C01 - Example Check

Review `/etc/logrotate.conf` and `/etc/logrotate.d/*` and verify logs are rotated according to site policy.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 4.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 4.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

Access, Authentication and Authorization

Configure cron

BL512-4700

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure cron daemon is enabled

Rule

Ensure cron daemon is enabled.

Description

The `cron` daemon is used to execute batch jobs on the system.

Rationale

While there may not be user jobs that need to be run on the system, the system does have maintenance jobs that may include security monitoring that have to run, and `cron` is used to execute them.

I01 - Implementation Example

Run the following command to enable `cron` :

```
# systemctl enable crond
```

C01 - Example Check

Run the following command and verify result is "enabled":

```
# systemctl is-enabled crond
enabled
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2788

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/crontab are configured

Rule Ensure permissions on /etc/crontab are configured:

- Owned by user and group root,
- Permissions set to 0644 or more restrictive.

Description

The /etc/crontab file is used by cron to control its own jobs. The commands in this item make sure that root is the user and group owner of the file and that only the owner can access the file.

Rationale

This file contains information on what system jobs are run by cron. Write access to these files could provide unprivileged users with the ability to elevate their privileges. Read access to these files could provide users with the ability to gain insight on system jobs that run on the system and could provide them a way to gain unauthorized privileged access.

I01 - Implementation Example

Run the following commands to set ownership and permissions on /etc/crontab :

```
# chown root:root /etc/crontab
# chmod og-wx /etc/crontab
```

C01 - Example Check

Run the following command and verify Uid and Gid are both 0/root and Access does not grant write or execute permissions to group or other :

```
# stat /etc/crontab
Access: (0644/-rw-r--r--)  Uid: (    0/    root)   Gid: (    0/    root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 644 to be vendor default compliant.

BL512-3881

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/cron.hourly are configured

Rule Ensure permissions on /etc/cron.hourly are configured:

- Owned by user and group root,
- Permissions set to 0755 or more restrictive.

Description

This directory contains system `cron` jobs that need to run on an hourly basis. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

I01 - Implementation Example

Run the following commands to set ownership and permissions on `/etc/cron.hourly`:

```
# chown root:root /etc/cron.hourly
# chmod og-w /etc/cron.hourly
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to group or other:

```
# stat /etc/cron.hourly
Access: (0755/drwxr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.3

Based on superseded measure M608700

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 755 to be vendor default compliant.

BL512-1566

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on `/etc/cron.daily` are configured

Rule Ensure permissions on `/etc/cron.daily` are configured:

- Owned by user and group root,
- Permissions set to 0755 or more restrictive.

Description

The `/etc/cron.daily` directory contains system cron jobs that need to run on a daily basis. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

I01 - Implementation Example

Run the following commands to set ownership and permissions on `/etc/cron.daily`:

```
# chown root:root /etc/cron.daily
# chmod og-w /etc/cron.daily
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to group or other:

```
# stat /etc/cron.daily
Access: (0755/drwxr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.4

Based on superseded measure M608700

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 755 to be vendor default compliant.

BL512-2883

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/cron.weekly are configured

Rule Ensure permissions on /etc/cron.weekly are configured:

- Owned by user and group root,
- Permissions set to 0755 or more restrictive.

Description

The `/etc/cron.weekly` directory contains system cron jobs that need to run on a weekly basis. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

I01 - Implementation Example

Run the following commands to set ownership and permissions on `/etc/cron.weekly`:

```
# chown root:root /etc/cron.weekly
# chmod og-w /etc/cron.weekly
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to group or other:

```
# stat /etc/cron.weekly
Access: (0755/drwxr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.5

Based on superseded measure M608700

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 755 to be vendor default compliant.

BL512-2025

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on `/etc/cron.monthly` are configured

Rule Ensure permissions on `/etc/cron.monthly` are configured:

- Owned by user and group root,
- Permissions set to 0755 or more restrictive.

Description

The `/etc/cron.monthly` directory contains system cron jobs that need to run on a monthly basis. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

I01 - Implementation Example

Run the following commands to set ownership and permissions on `/etc/cron.monthly`:

```
# chown root:root /etc/cron.monthly
# chmod og-w /etc/cron.monthly
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to group or other:

```
# stat /etc/cron.monthly
Access: (0755/drwxr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.6

Based on superseded measure M608700

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 755 to be vendor default compliant.

BL512-8787

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/cron.d are configured

Rule Ensure permissions on /etc/cron.d are configured:

- Owned by user and group root,
- Permissions set to 0755 or more restrictive.

Description

The `/etc/cron.d` directory contains system `cron` jobs that need to run in a similar manner to the hourly, daily weekly and monthly jobs from `/etc/crontab`, but require more granular control as to when they run. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

I01 - Implementation Example

Run the following commands to set ownership and permissions on `/etc/cron.d`:

```
# chown root:root /etc/cron.d
# chmod og-w /etc/cron.d
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to group or other :

```
# stat /etc/cron.d
Access: (0755/drwxr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.7

Based on superseded measure M608700

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 755 to be vendor default compliant.

BL512-8275

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure at/cron is restricted to authorized users

Rule Ensure at/cron is restricted to authorized users:

- Only dedicated users shall be able to use `at` or `cron`.

Note: With system updates of `at/cron`, default files for blacklist approach (`at.deny`, `cron.deny`) could be restored and obsolete desired settings. Therefore, this rule must be verified after every system update.

Description

Configure `/etc/cron.allow` and `/etc/at.allow` to allow specific users to use these services. If `/etc/cron.allow` or `/etc/at.allow` do not exist, then `/etc/at.deny` and `/etc/cron.deny` are checked. Any user not specifically defined in those files is allowed to use `at` and `cron`. By removing the files, only users in `/etc/cron.allow` and `/etc/at.allow` are allowed to use `at` and `cron`. Note that even though a given user is not listed in `cron.allow`, `cron` jobs can still be run as that user. The `cron.allow` file only controls administrative access to the `crontab` command for scheduling and modifying `cron` jobs.

Rationale

On many systems, only the system administrator is authorized to schedule `cron` jobs. Using the `cron.allow` file to control who can run `cron` jobs, enforces this policy. It is easier to manage an allow list than a deny list. In a deny list, you could potentially add a user ID to the system and forget to add it to the deny files.

I01 - Implementation Example

For implementing a whitelist approach of allowed users, run the following commands to remove `/etc/cron.deny` and `/etc/at.deny` and create and set permissions and ownership for `/etc/cron.allow` and `/etc/at.allow`:

```
# rm /etc/cron.deny
# rm /etc/at.deny
# touch /etc/cron.allow
# touch /etc/at.allow
# chmod og-wx /etc/cron.allow
# chmod og-wx /etc/at.allow
# chown root:root /etc/cron.allow
# chown root:root /etc/at.allow
```

Note: With system updates of `at/cron`, default files for blacklist approach (`at.deny`, `cron.deny`) could be restored and obsolete desired settings. Therefore, this rule must be verified after every system update.

C01 - Example Check

For checking a whitelist approach of allowed users, run the following commands and ensure `/etc/cron.deny` and `/etc/at.deny` do not exist:

```
# stat /etc/cron.deny
stat: cannot stat '/etc/cron.deny': No such file or directory
# stat /etc/at.deny
stat: cannot stat '/etc/at.deny': No such file or directory
```

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to group or other for both `/etc/cron.allow` and `/etc/at.allow`:

```
# stat /etc/cron.allow
Access: (0644/-rw-r--r--)  Uid: (   0/   root)   Gid: (   0/   root)
# stat /etc/at.allow
Access: (0644/-rw-r--r--)  Uid: (   0/   root)   Gid: (   0/   root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.1.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.1.8

Based on superseded measure M608700

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Permissions aligned to vendor default state; Note added.

SSH Server Configuration

SSH is a secure, encrypted replacement for common login services such as `telnet`, `ftp`, `rlogin`, `rsh`, and `rcp`. It is mandatory that sites abandon older clear-text login protocols and use SSH to prevent session hijacking and sniffing of sensitive data off the network.

Note: The recommendations in this section only apply if the SSH daemon is installed on the system, if remote access is not required the SSH daemon can be removed and this section skipped.

Note: Once all configuration changes have been made to `/etc/ssh/sshd_config`, the `sshd` configuration must be reloaded:

```
# systemctl reload sshd
```

BL512-9189

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on `/etc/ssh/sshd_config` are configured

Rule Ensure permissions on `/etc/ssh/sshd_config` are configured:

- Owned by user and group root,
- Permissions set to 0640 or more restrictive.

Description

The `/etc/ssh/sshd_config` file contains configuration specifications for `sshd`. The command below sets the owner and group of the file to root.

Rationale

The `/etc/ssh/sshd_config` file needs to be protected from unauthorized changes by non-privileged users.

I01 - Implementation Example

Run the following commands to set ownership and permissions on `/etc/ssh/sshd_config`:

```
# chown root:root /etc/ssh/sshd_config
# chmod o-rwx /etc/ssh/sshd_config
# chmod g-wx /etc/ssh/sshd_config
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions `other` and no write/execute permission to `group`:

```
# stat /etc/ssh/sshd_config  
Access: (0600/-rw-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.1

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Changed required permission to 640 to be vendor default compliant of RHEL-8.

BL512-8997

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH LogLevel is set to INFO

Rule

Ensure SSH LogLevel is set to INFO or higher.

Description

The `INFO` parameter specifies that login and logout activity will be logged.

Rationale

SSH provides several logging levels with varying amounts of verbosity. `DEBUG` is specifically *not* recommended other than strictly for debugging SSH communications since it provides so much data that it is difficult to identify important security information. `INFO` level is the basic level that only records login activity of SSH users. In many situations, such as Incident Response, it is important to determine when a particular user was active on a system. The logout record can eliminate those users who disconnected, which helps narrow the field.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
LogLevel INFO
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^LogLevel" /etc/ssh/sshd_config
LogLevel INFO
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-5115

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH X11 forwarding is disabled

Rule

Ensure SSH X11 forwarding is disabled.

E01 - Exemption

If SSH X11 forwarding is operationally required this rule can be omitted. However, the reason for this exemption must be documented.

Description

The X11Forwarding parameter provides the ability to tunnel X11 traffic through the connection to enable remote graphic connections.

Rationale

Disable X11 forwarding unless there is an operational requirement to use X11 applications directly. There is a small risk that the remote X11 servers of users who are logged in via SSH with X11 forwarding could be compromised by other users on the X11 server. Note that even if X11 forwarding is disabled, users can always install their own forwarders.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
X11Forwarding no
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^X11Forwarding" /etc/ssh/sshd_config
X11Forwarding no
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, Added feedback from EAGLE Data Center: Added an exemption.

BL512-6573

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH MaxAuthTries is set to 6 or less

Rule

Ensure SSH MaxAuthTries is set to 6 or less.

Description

The `MaxAuthTries` parameter specifies the maximum number of authentication attempts permitted per connection. When the login failure count reaches half the number, error messages will be written to the `syslog` file detailing the login failure.

Rationale

Setting the `MaxAuthTries` parameter to a low number will minimize the risk of successful brute force attacks to the SSH server. While the recommended setting is 6, set the number based on site policy.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
MaxAuthTries 6
```

C01 - Example Check

Run the following command and verify that output `MaxAuthTries` is 6 or less:

```
# grep "^MaxAuthTries" /etc/ssh/sshd_config
MaxAuthTries 6
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, Added feedback from EAGLE Data Center: Increased `MaxAuthTries` to 6 or less.

BL512-7248

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH IgnoreRhosts is enabled

Rule

Ensure SSH IgnoreRhosts is enabled.

Description

The `IgnoreRhosts` parameter specifies that `.rhosts` and `.shosts` files will not be used in `RhostsRSAAuthentication` or `HostbasedAuthentication`.

Rationale

Setting this parameter forces users to enter a password when authenticating with `ssh`.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
IgnoreRhosts yes
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^IgnoreRhosts" /etc/ssh/sshd_config
IgnoreRhosts yes
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.8

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3226

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH HostbasedAuthentication is disabled

Rule

Ensure SSH HostbasedAuthentication is disabled.

Description

The `HostbasedAuthentication` parameter specifies if authentication is allowed through trusted hosts via the user of `.rhosts`, or `/etc/hosts.equiv`, along with successful public key client host authentication. This option only applies to SSH Protocol Version 2.

Rationale

Even though the `.rhosts` files are ineffective if support is disabled in `/etc/pam.conf`, disabling the ability to use `.rhosts` files in SSH provides an additional layer of protection.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
HostbasedAuthentication no
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^HostbasedAuthentication" /etc/ssh/sshd_config
HostbasedAuthentication no
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.9

Based on superseded measure M505890

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3262

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH root login is disabled

Rule Ensure SSH root login is disabled:

- Root login via SSH must be disabled for clients connecting via public Internet.

Note: If required, alternative ways for logging in and elevating privileges needs to be in place before disabling root login via SSH.

Description

The `PermitRootLogin` parameter specifies if the root user can log in using `ssh(1)`. The default is `no`.

Rationale

Disallowing root logins over SSH requires system admins to authenticate using their own individual account, then escalating to root via `sudo` or `su`. This in turn limits opportunity for non-repudiation and provides a clear audit trail in the event of a security incident

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
PermitRootLogin no
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^PermitRootLogin" /etc/ssh/sshd_config
PermitRootLogin no
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.10

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.10

Based on superseded measure M505890

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for alternative privilege elevation before disabling root login via ssh.

BL512-9831

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH PermitEmptyPasswords is disabled

Rule

Ensure SSH PermitEmptyPasswords is disabled.

Description

The `PermitEmptyPasswords` parameter specifies if the SSH server allows login to accounts with empty password strings.

Rationale

Disallowing remote shell access to accounts that have an empty password reduces the probability of unauthorized access to the system

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
PermitEmptyPasswords no
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^PermitEmptyPasswords" /etc/ssh/sshd_config
PermitEmptyPasswords no
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.11

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.11

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9789

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH PermitUserEnvironment is disabled

Rule

Ensure SSH PermitUserEnvironment is disabled.

Description

The `PermitUserEnvironment` option allows users to present environment options to the `ssh` daemon.

Rationale

Permitting users the ability to set environment variables through the SSH daemon could potentially allow users to bypass security controls (e.g., setting an execution path that has `ssh` executing trojan'd programs)

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
PermitUserEnvironment no
```

C01 - Example Check

Run the following command and verify that output matches:

```
# grep PermitUserEnvironment /etc/ssh/sshd_config
PermitUserEnvironment no
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.12

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.12

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4854

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH Idle Timeout Interval is configured

Rule Ensure SSH Idle Timeout Interval is configured:

- ClientAliveInterval is set 1800 or less,
- ClientAliveCountMax must be adjusted, that in total inactive SSH sessions will be terminated after at most 1800s, i.e. 30 minutes.

Description

The two options `ClientAliveInterval` and `ClientAliveCountMax` control the timeout of ssh sessions. When the `ClientAliveInterval` variable is set, ssh sessions that have no activity for the specified length of time are terminated. When the `ClientAliveCountMax` variable is set, `sshd` will send client alive messages at every `ClientAliveInterval` interval. When the number of consecutive client alive messages are sent with no response from the client, the ssh session is terminated. For example, if the `ClientAliveInterval` is set to 15 seconds and the `ClientAliveCountMax` is set to 3, the client ssh session will be terminated after 45 seconds of idle time.

Rationale

Having no timeout value associated with a connection could allow an unauthorized user access to another user's ssh session (e.g., user walks away from their computer and doesn't lock the screen). Setting a timeout value at least reduces the risk of this happening..

While the recommended setting is 300 seconds (5 minutes), set this timeout value based on site policy. The recommended setting for `ClientAliveCountMax` is 0. In this case, the client session will be terminated after 5 minutes of idle time and no keepalive messages will be sent.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameters according to site policy:

```
ClientAliveInterval 1800
ClientAliveCountMax 0
```

C01 - Example Check

Run the following commands and verify `ClientAliveInterval` is between 1 and 1800 and `ClientAliveCountMax` is 0:

```
# grep "^ClientAliveInterval" /etc/ssh/sshd_config
ClientAliveInterval 1800
# grep "^ClientAliveCountMax" /etc/ssh/sshd_config
ClientAliveCountMax 0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.13

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.16

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, Added feedback from EAGLE Data Center: Restricted rule to idle timeout in total of 1800s

BL512-8070

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure SSH LoginGraceTime is set to one minute or less

Rule

Ensure SSH LoginGraceTime is set to one minute or less.

Description

The LoginGraceTime parameter specifies the time allowed for successful authentication to the SSH server. The longer the Grace period is the more open unauthenticated connections can exist. Like other session controls in this session the Grace Period should be limited to appropriate organizational limits to ensure the service is available for needed access.

Rationale

Setting the LoginGraceTime parameter to a low number will minimize the risk of successful brute force attacks to the SSH server. It will also limit the number of concurrent unauthenticated connections While the recommended setting is 60 seconds (1 Minute), set the number based on site policy.

I01 - Implementation Example

Edit the /etc/ssh/sshd_config file to set the parameter as follows:

```
LoginGraceTime 60
```

C01 - Example Check

Run the following command and verify that output LoginGraceTime is between 1 and 60:

```
# grep "^LoginGraceTime" /etc/ssh/sshd_config
LoginGraceTime 60
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.14

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.17

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1400

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on SSH public host key files are configured

Rule

Ensure permissions on SSH public host key files are configured:

- Owned by user and group root,
- Permissions set to 0644 or more restrictive.

Description

An SSH public key is one of two files used in SSH public key authentication. In this authentication method, a public key is a key that can be used for verifying digital signatures generated using a corresponding private key. Only a public key that corresponds to a private key will be able to authenticate successfully.

Rationale

If a public host key file is modified by an unauthorized user, the SSH service may be compromised.

I01 - Implementation Example

Run the following commands to set permissions and ownership on the SSH host public key files

```
# find /etc/ssh -xdev -type f -name 'ssh_host*_key.pub' -exec chmod 0644 {} \;  
# find /etc/ssh -xdev -type f -name 'ssh_host*_key.pub' -exec chown root:root {} \;
```

C01 - Example Check

Run the following command and verify Access does not grant write or execute permissions to group or other for all returned files

```
# find /etc/ssh -xdev -type f -name 'ssh_host*_key.pub' -exec stat {} \;

File: '/etc/ssh/ssh_host_rsa_key.pub'
Size: 382 Blocks: 8 IO Block: 4096 regular file
Device: ca01h/51713d Inode: 8631758 Links: 1
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
Access: 2018-10-22 18:24:56.861750616 +0000
Modify: 2018-10-22 18:24:56.861750616 +0000
Change: 2018-10-22 18:24:56.881750616 +0000
Birth: -
File: '/etc/ssh/ssh_host_ecdsa_key.pub'
Size: 162 Blocks: 8 IO Block: 4096 regular file
Device: ca01h/51713d Inode: 8631761 Links: 1
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
Access: 2018-10-22 18:24:56.897750616 +0000
Modify: 2018-10-22 18:24:56.897750616 +0000
Change: 2018-10-22 18:24:56.917750616 +0000
Birth: -
File: '/etc/ssh/ssh_host_ed25519_key.pub'
Size: 82 Blocks: 8 IO Block: 4096 regular file
Device: ca01h/51713d Inode: 8631763 Links: 1
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
Access: 2018-10-22 18:24:56.945750616 +0000
Modify: 2018-10-22 18:24:56.945750616 +0000
Change: 2018-10-22 18:24:56.961750616 +0000
Birth: -
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2792

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on SSH private host key files are configured

Rule

Ensure permissions on SSH private host key files are configured:

- Owned by user and group root,
- Permissions set to 0600 or more restrictive.

Description

An SSH private key is one of two files used in SSH public key authentication. In this authentication method, The possession of the private key is proof of identity. Only a private key that corresponds to a public key will be able to authenticate successfully. The private keys need to be stored and handled carefully, and no copies of the private key should be distributed.

Rationale

If an unauthorized user obtains the private SSH host key file, the host could be impersonated

I01 - Implementation Example

Run the following commands to set ownership and permissions on the private SSH host key files

```
# find /etc/ssh -xdev -type f -name 'ssh_host*_key' -exec chown root:root {} \;
```

```
# find /etc/ssh -xdev -type f -name 'ssh_host*_key' -exec chmod 0600 {} \;
```

C01 - Example Check

Run the following command and verify Uid is 0/root and Gid is 0/root. Ensure group and other do not have permissions

```
# find /etc/ssh -xdev -type f -name 'ssh_host*_key' -exec stat {} \;

File: '/etc/ssh/ssh_host_rsa_key'
Size: 1679 Blocks: 8 IO Block: 4096 regular file
Device: ca01h/51713d Inode: 8628138 Links: 1
Access: (0600/-rw-----) Uid: ( 0/ root) Gid: ( 0/root)
Access: 2018-10-22 18:24:56.861750616 +0000
Modify: 2018-10-22 18:24:56.861750616 +0000
Change: 2018-10-22 18:24:56.873750616 +0000
Birth: -
File: '/etc/ssh/ssh_host_ecdsa_key'
Size: 227 Blocks: 8 IO Block: 4096 regular file
Device: ca01h/51713d Inode: 8631760 Links: 1
Access: (0600/-rw-----) Uid: ( 0/ root) Gid: ( 0/root)
Access: 2018-10-22 18:24:56.897750616 +0000
Modify: 2018-10-22 18:24:56.897750616 +0000
Change: 2018-10-22 18:24:56.905750616 +0000
Birth: -
File: '/etc/ssh/ssh_host_ed25519_key'
Size: 387 Blocks: 8 IO Block: 4096 regular file
Device: ca01h/51713d Inode: 8631762 Links: 1
Access: (0600/-rw-----) Uid: ( 0/ root) Gid: ( 0/root)
Access: 2018-10-22 18:24:56.945750616 +0000
Modify: 2018-10-22 18:24:56.945750616 +0000
Change: 2018-10-22 18:24:56.957750616 +0000
Birth: -
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.2

Based on superseded measure M447580

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4319

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH PAM is enabled

Rule

Ensure SSH PAM is enabled.

Description

UsePAM Enables the Pluggable Authentication Module interface. If set to “yes” this will enable PAM authentication using ChallengeResponseAuthentication and PasswordAuthentication in addition to PAM account and session module processing for all authentication types

Rationale

When usePAM is set to yes, PAM runs through account and session types properly. This is important if you want to restrict access to services based off of IP, time or other factors of the account. Additionally, you can make sure users inherit certain environment variables on login or disallow access to the server

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
UsePAM yes
```

C01 - Example Check

Run the following command and verify that output matches:

```
# sshd -T | grep -i usepam  
usepam yes
```

Crossreferences

Based on CIS Benchmark ‘Red Hat Enterprise Linux 8’ (v1.0.0.1): 5.2.16

Based on CIS Benchmark ‘Distribution Independent Linux’ (v2.0.0): 5.2.20

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8127

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH AllowTcpForwarding is disabled

Rule Ensure SSH AllowTcpForwarding is disabled.

Description

SSH port forwarding is a mechanism in SSH for tunneling application ports from the client to the server, or servers to clients. It can be used for adding encryption to legacy applications, going through firewalls, and some system administrators and IT professionals use it for opening backdoors into the internal network from their home machines

Rationale

Leaving port forwarding enabled can expose the organization to security risks and back-doors.

SSH connections are protected with strong encryption. This makes their contents invisible to most deployed network monitoring and traffic filtering solutions. This invisibility carries considerable risk potential if it is used for malicious purposes such as data exfiltration. Cybercriminals or malware could exploit SSH to hide their unauthorized communications, or to exfiltrate stolen data from the target network

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
AllowTcpForwarding no
```

C01 - Example Check

Run the following command and verify that output matches:

```
# sshd -T | grep -i allowtcpforwarding
AllowTcpForwarding no
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.17

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.21

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-6295

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure SSH MaxStartups is configured

Rule Ensure SSH MaxStartups is configured reasonable:

- recommended is a value such as 10:30:60,
- the configured value must not be more relaxed than 50:100:50.

Description

The MaxStartups parameter specifies the maximum number of concurrent unauthenticated connections to the SSH daemon.

Rationale

To protect a system from denial of service due to a large number of pending authentication connection attempts, use the rate limiting function of MaxStartups to protect availability of sshd logins and prevent overwhelming the daemon.

I01 - Implementation Example

Edit the /etc/ssh/sshd_config file to set the parameter as follows:

```
maxstartups 10:30:60
```

C01 - Example Check

Run the following command and verify that output MaxStartups is 10:30:60 or matches site policy:

```
# sshd -T | grep -i maxstartups
# maxstartups 10:30:60
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.18

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.22

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, Added feedback from EAGLE Data Center: Restricted rule to at most 50:100:50

BL512-5539

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure SSH MaxSessions is set to 4 or less

Rule

Ensure SSH MaxSessions is set to 4 or less.

E01 - Exemption

For systems acting as a jump host a higher value is allowed.

However, the reason for this exemption must be documented.

Description

The `MaxSessions` parameter specifies the maximum number of open sessions permitted from a given connection.

Rationale

To protect a system from denial of service due to a large number of concurrent sessions, use the rate limiting function of `MaxSessions` to protect availability of `sshd` logins and prevent overwhelming the daemon.

I01 - Implementation Example

Edit the `/etc/ssh/sshd_config` file to set the parameter as follows:

```
MaxSessions 4
```

C01 - Example Check

Run the following command and verify that output `MaxSessions` is 4 or less, or matches site policy:

```
# sshd -T | grep -i maxsessions
# maxsessions 4
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.19

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.2.23

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs, updated to CIS-RHEL-8, Added feedback from EAGLE Data Center: Allowance of higher values especially for jump hosts added as exemption.

BL512-0801

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Secure SSH login

Rule

The following rules for SSH login must be implemented:

- Login with a SSH key is required, i.e. password login must be disabled.

E01 - Exemption

This rule is not mandatory, if the following requirements are satisfied:

- System has confidentiality level 1 or 2,
- System has no direct connection from public Internet,
- no local interactive users with enabled login opportunities (i.e., configured interactive login shell) are configured,
- but instead only domain users are used to log in to the system.

This exemption does **not** permit the password-based login for the root user. The root login via SSH is addressed in [BL512-3262 - Ensure SSH root login is disabled](#) .

Description

SSH is a software package comprising of a server and multiple clients which can be used as a full replacement for **telnet**, **rlogin**, **rcp** and **rsh**. Unlike **rlogin** or **rsh**, **SSH** does not perform authentication using IP addresses, but instead uses the RSA procedure, among others. Access is only given to computers possessing accepted secret RSA keys. In addition to RSA keys for computers, key pairs for users are also supported. Upon successful authentication, all data is encrypted for data transmission, eliminating the possibility of wiretapping. Links through the network from X11 programs to the X11 server can be forwarded via the secure **SSH** link, helping to prevent the wiretapping of *MIT-MAGIC-COOKIES*.

OpenSSH is the new, open source version of **SSH**.

Rationale

SSH login using public/private key authentication is more secure than using a password as the length of a SSH key is usually much longer than a password, which makes it harder for potential hackers to crack the password. Furthermore, in contrast to the symmetrical encryption used by password based login, public/private key authentication uses asymmetrical encryption algorithms where the secret, i.e., the private key, is never transferred over the wire and therefore cannot be eavesdropped.

Users must login with non-privilege user rights and change to the root user with the **su** or **sudo** command. This rule follows security best practices to deter unauthorized access as the root user.

I01 - Implementation

To disable password based authentication for all logins, add

PasswordAuthentication no

to the file `/etc/ssh/sshd_config` or change the existing entry.

C01 - Example Check

Run the following command and verify that output matches:

```
# grep "^PasswordAuthentication" /etc/ssh/sshd_config
PasswordAuthentication no
```

Crossreferences

Based on superseded measure M505890

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 for domain user accounts according feedback from the review.

BL512-0994

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure system-wide crypto policy is not over-written

Rule

Ensure system-wide crypto policy is not over-written by local SSH server configuration.

Description

The System-wide crypto policy can be over-written or opted out of for SSH server by local configuration files.

Rationale

Over-writing or opting out of the system-wide crypto policy could allow for the use of less secure Ciphers, MACs, KexAlgoritms and GSSAPIKexAlgorithm.

I01 - Implementation Example

Run the following commands:

```
# sed -ri "s/^\s*(CRYPTO_POLICY\s*=.*)$/# \1/" /etc/sysconfig/ssh  
# systemctl reload sshd
```

C01 - Example Check

Run the following command:

```
# grep '^/s*CRYPTO_POLICY=' /etc/sysconfig/sshd'
```

No output should be returned.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.2.20

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

Configure PAM

PAM (Pluggable Authentication Modules) is a service that implements modular authentication modules on UNIX/Linux systems. PAM is implemented as a set of shared objects that are loaded and executed when a program needs to authenticate a user. Files for PAM are typically located in the `/etc/pam.d` directory. PAM must be carefully configured to secure system authentication. While this section covers some of PAM, please consult other PAM resources to fully understand the configuration capabilities.

BL512-4831

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure password creation requirements are configured

Rule Ensure password creation requirements are configured, in compliance with the rules from *Specific Information Security Policy: Access Control* [4]. Especially, this includes the following rules:

*Rules for **all** passwords:*

- Accounts must not have blank passwords.
- Trivial passwords are not allowed, i.e. passwords must not contain any easy to guess keyboard pattern nor any trivial term like a person's name, a user account name, a product name, a company name (e.g. Siemens), nor any word that can be found in a dictionary.
- Always use passwords at least 12 character long.
- Maximum password age is 180 days.
- The same password must not be used on multiple systems or for multiple accounts. This is especially relevant for the local admin account when the service provider sets and keeps this password for a large number of managed clients. In this scenario a mechanism like a password data base must be used.

Additional (overwriting) rules for Administrator passwords:

- Always **use passwords at least 15 character long**.
- Maximum password age is 45 days, except for regular users with local admin rights on workstations, where the maximum password age is 180 days.

Additional (overwriting) rules for standard and privileged service accounts:

- Always **use passwords at least 20 character long**.
- Maximum password age is 365 days.

Note: Password aging rules do not apply to disabled accounts. In addition, for user accounts (incl. local workstation administrators), it is permissible to force password change at the next login upon password expiration without violating password aging rules.

Description

The `pam_pwquality.so` module checks the strength of passwords. It performs checks such as making sure a password is not a dictionary word, it is a certain length, contains a mix of characters (e.g., alphabet, numeric, other) and more. The following are definitions of the `pam_pwquality.so` options.

- `try_first_pass` - retrieve the password from a previous stacked PAM module. If not available, then prompt the user for a password.
- `retry=3` - Allow 3 tries before sending back a failure.

The following options are set in the `/etc/security/pwquality.conf` file:

- `minlen = 12` - password must be 12 characters or more
- `dcredit = -1` - provide at least one digit
- `ucredit = -1` - provide at least one uppercase character
- `ocredit = -1` - provide at least one special character
- `lcredit = -1` - provide at least one lowercase character

The settings shown above are one possible policy. Alter these values to conform to your own organization's password policies.

Rationale

Strong passwords protect systems from being hacked through brute force methods.

I01 - Implementation Example

Edit the `/etc/pam.d/password-auth` and `/etc/pam.d/system-auth` files to include the appropriate options for `pam_pwquality.so` and to conform to site policy:

```
password requisite pam_pwquality.so try_first_pass retry=3
```

Edit `/etc/security/pwquality.conf` to add or update the following settings to conform to site policy:

```
minlen = 12
dcredit = -1
ucredit = -1
ocredit = -1
lcredit = -1
```

C01 - Example Check

Run the following commands and verify all password requirements conform to organization policy and `minlen` is 12 or more:

```
# grep pam_pwquality.so /etc/pam.d/password-auth
password requisite pam_pwquality.so try_first_pass retry=3
# grep pam_pwquality.so /etc/pam.d/system-auth
password requisite pam_pwquality.so try_first_pass retry=3
# grep ^minlen /etc/security/pwquality.conf
minlen = 12
# grep ^dcredit /etc/security/pwquality.conf
dcredit = -1
# grep ^lcredit /etc/security/pwquality.conf
lcredit = -1
# grep ^ocredit /etc/security/pwquality.conf
ocredit = -1
# grep ^ucredit /etc/security/pwquality.conf
ucredit = -1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.4.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.3.1

Based on superseded measure M806039

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added values for service accounts.

BL512-8617

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure logout for failed password attempts is configured

Rule Ensure logout for failed password attempts is configured, in compliance with the rules from *Specific Information Security Policy: Access Control* [4]. Especially, this includes the following rules:

*Rules for **all** passwords:*

- Lockout for failed password attempts must be set to 10 or less invalid login attempts.
- Reset account lockout time must be set to 30 or more minutes.

Description

Lock out users after *n* unsuccessful consecutive login attempts.

- deny= - Number of attempts before the account is locked
- unlock_time= - Time in seconds before the account is unlocked

Set the lockout number and unlock time to follow local site policy.

Rationale

Locking out user IDs after *n* unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

I01 - Implementation Example

Set password lockouts and unlock times to conform to site policy

Run the following to update the `system-auth` and `password-auth` files. This script will update/add the `deny=10` and `unlock_time=1800` options.

This script should be modified as needed to follow local site policy.

```
CP=$(authselect current | awk 'NR == 1 {print $3}' | grep custom/)

for FN in system-auth password-auth; do

    [[ -n $CP ]] && PTF=/etc/authselect/$CP/$FN || PTF=/etc/authselect/$FN

    [[ -n $(grep -E '^s*auth\s+required\s+pam_faillock.so\s+.*deny=\S+\s*.*$' $PTF) ]] && sed -ri
'/pam_faillock.so/s/deny=\S+/deny=10/g' $PTF || sed -ri 's/^\s*(auth\s+required\s+pam_faillock\.\so\s+)
(.^[^{}]) (\{.*\})$/\1\2 deny=10 \3/' $PTF

    [[ -n $(grep -E '^s*auth\s+required\s+pam_faillock.so\s+.*unlock_time=\S+\s*.*$' $PTF) ]] && sed -
ri '/pam_faillock.so/s/unlock_time=\S+/unlock_time=1800/g' $PTF || sed -ri 's/^\s*
(auth\s+required\s+pam_faillock\.\so\s+) (.^[^{}]) (\{.*\})$/\1\2 unlock_time=1800 \3/' $PTF

done

authselect apply-changes
```

C01 - Example Check

Verify password lockouts are configured. These settings are commonly configured with the `pam_tally2.so` and `pam_faillock.so` modules found in `/etc/pam.d/common-auth` or `/etc/pam.d/system-auth` and `/etc/pam.d/password-auth`. Examples:

Run the following command and review the output to ensure that it follows local site policy. `deny` should be no greater than 10 and `unlock_time` should be no less than 1800 seconds

```
# grep -E '^s*auth\s+required\s+pam_faillock.so\s+' /etc/pam.d/password-auth /etc/pam.d/system-auth
```

Output should look similar to:

```
/etc/pam.d/password-auth:auth required pam_faillock.so preauth silent deny=10 unlock_time=1800
/etc/pam.d/password-auth:auth required pam_faillock.so authfail deny=10 unlock_time=1800
/etc/pam.d/system-auth:auth required pam_faillock.so preauth silent deny=10 unlock_time=1800
/etc/pam.d/system-auth:auth required pam_faillock.so authfail deny=10 unlock_time=1800
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.4.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.3.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1111

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure password reuse is limited

Rule

Ensure password reuse is limited, in compliance with the rules from *Specific Information Security Policy: Access Control* [4]:

- Password reuse must be prohibited for the last 24 passwords.

Description

The `/etc/security/opasswd` file stores the users' old passwords and can be checked to ensure that users are not recycling recent passwords.

- `remember=<24>` - Number of old passwords to remember

Rationale

Forcing users not to reuse their past 24 passwords make it less likely that an attacker will be able to guess the password.

Note that these change only apply to accounts configured on the local system.

I01 - Implementation Example

Run the following script to add or modify the `pam_pwquality.so` and `pam_unix.so` lines to include the `remember` option with a value of at least 24:

```
CP=$(authselect current | awk 'NR == 1 {print $3}' | grep custom/)

[[ -n $CP ]] && PTF=/etc/authselect/$CP/system-auth || PTF=/etc/authselect/system-auth

[[ -n $(grep -E '^s*password\s+(sufficient\s+pam_unix|requi(red|site)\s+pam_pwquality)\.so\s+([^\s]+\s+)*remember=\S+\s*.*$' $PTF) ]] && sed -ri 's/^\s*(password\s+(requisite|sufficient)\s+(pam_pwquality\.so|pam_unix\.so)\s+)(.*) (remember=\S+\s*)(.*)$/\1\4 remember=24 \6/' $PTF || sed -ri 's/^\s*(password\s+(requisite|sufficient)\s+(pam_pwquality\.so|pam_unix\.so)\s+)(.*)$/\1\4 remember=24/' $PTF

authselect apply-changes
```

Note: The described implementation script only works for custom authselect profiles, because Red Hat Enterprise Linux 8 prevents applying a predefined base authselect profile with manual changes in text files such as `/etc/authselect/system-auth`. A custom profile can be created and selected using the following commands, here using the predefined `sssd` profile as basis:

```
# authselect create-profile customprofile -b sssd
# authselect select custom/customprofile
```

C01 - Example Check

Run the following command:

```
# grep -E '^s*password\s+(requisite|sufficient)\s+(pam_pwquality\.so|pam_unix\.so)\s+.*remember=([5-9]|[1-4][0-9])[0-9]*\s*.*$' /etc/pam.d/system-auth
```

Verify the output contains `remember` values of at least 24 :

```
password requisite pam_pwquality.so try_first_pass local_users_only enforce-for-root retry=3 remember=24
password sufficient pam_unix.so sha512 shadow try_first_pass use_authtok remember=24
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.4.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.3.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8; adapted rule to the Siemens requirements. Fixed wrong implementation script value of `pam_pwhistory` and added note for custom profile.

BL512-2991

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure password hashing algorithm is SHA-512

Rule

Ensure password hashing algorithm is SHA-512.

Description

The commands below change password encryption from `md5` to `sha512` (a much stronger hashing algorithm). All existing accounts will need to perform a password change to upgrade the stored hashes to the new algorithm.

Rationale

The SHA-512 algorithm provides much stronger hashing than MD5, thus providing additional protection to the system by increasing the level of effort for an attacker to successfully determine passwords.

Note that these change only apply to accounts configured on the local system.

I01 - Implementation Example

Set password hashing algorithm to `sha512`.

Run the following script to add or modify the `pam_unix.so` lines in the `password-auth` and `system-auth` files to include the `sha512` option:

```
CP=$(authselect current | awk 'NR == 1 {print $3}' | grep custom/)

for FN in system-auth password-auth; do

    [[ -z $(grep -E '^s*password\s+sufficient\s+pam_unix.so\s+.*sha512\s*.*$' $PTF) ]] && sed -ri
    's/^s*(password\s+sufficient\s+pam_unix.so\s+)(.*)$/\1\2 sha512/' $PTF

done

authselect apply-changes
```

C01 - Example Check

Verify password hashing algorithm is `sha512`. This setting is configured with the `pam_unix.so sha512` option found in `/etc/pam.d/system-auth` and `/etc/pam.d/password-auth`

Run the following command:

```
# grep -E '^s*password\s+sufficient\s+pam_unix.so\s+.*sha512\s*.*$' /etc/pam.d/password-auth
/etc/pam.d/system-auth
```

The output should be similar to:

```
/etc/pam.d/password-auth:password sufficient pam_unix.so sha512 shadow try_first_pass use_authok
/etc/pam.d/system-auth:password sufficient pam_unix.so sha512 shadow try_first_pass use_authok
remember=24
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.4.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.3.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

User Accounts and Environment

This section provides guidance on setting up secure defaults for system and user accounts and their environment.

Set Shadow Password Suite Parameters

While a majority of the password control parameters have been moved to PAM, some parameters are still available through the shadow password suite. Any changes made to `/etc/login.defs` will only be applied if the `usermod` command is used.

BL512-1997

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure password expiration is 180 days or less

Rule

Ensure password expiration is configured, in compliance with the rules from *Specific Information Security Policy: Access Control* [4]. Especially, this includes the following rules:

*Rules for **all** passwords:*

- Maximum password age is 180 days.

Additional (overwriting) rules for Administrator passwords:

- Maximum password age is 45 days, except for regular users with local admin rights on workstations, where the maximum password age is 180 days.

Additional (overwriting) rules for standard and privileged service accounts:

- Maximum password age is 365 days.

Note: Password aging rules do not apply to disabled or locked accounts. In addition, for user accounts (incl. local workstation administrators), it is permissible to force password change at the next logon upon password expiration without violating password aging rules.

Description

The `PASS_MAX_DAYS` parameter in `/etc/login.defs` allows an administrator to force passwords to expire once they reach a defined age. It is mandatory that the `PASS_MAX_DAYS` parameter be set to less than or equal to 180 days.

Rationale

The window of opportunity for an attacker to leverage compromised credentials or successfully compromise credentials via an online brute force attack is limited by the age of the password. Therefore, reducing the maximum age of a password also reduces an attacker's window of opportunity.

I01 - Implementation Example

Set the `PASS_MAX_DAYS` parameter to conform to site policy in `/etc/login.defs` :

```
PASS_MAX_DAYS 180
```

Modify user parameters for all users with a password set to match:

```
# chage --maxdays 180 <user>
```

C01 - Example Check

Run the following command and verify `PASS_MAX_DAYS` conforms to site policy (no more than 365 days):

```
# grep PASS_MAX_DAYS /etc/login.defs
PASS_MAX_DAYS 180
```

Verify all users with a password maximum days between password change conforms to site policy (no more than 365 days):

```
# egrep ^[:]+:[^!]* /etc/shadow | cut -d: -f1
*
# chage --list
Maximum number of days between password change : 180
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.1.1

Based on superseded measure M806039

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added values for service accounts.

BL512-9681

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure minimum days between password changes is 1 or more

Rule Ensure minimum days between password changes is 1 or more.

Hint: This rule does not apply for the required password change of an INITIAL password.

Description

The `PASS_MIN_DAYS` parameter in `/etc/login.defs` allows an administrator to prevent users from changing their password until a minimum number of days have passed since the last time the user changed their password. It is recommended that `PASS_MIN_DAYS` parameter be set to 1 or more days.

Rationale

By restricting the frequency of password changes, an administrator can prevent users from repeatedly changing their password in an attempt to circumvent password reuse controls.

I01 - Implementation Example

Set the `PASS_MIN_DAYS` parameter to 1 in `/etc/login.defs` :

```
PASS_MIN_DAYS 1
```

Modify user parameters for all users with a password set to match:

```
# chage --mindays 1 <user>
```

C01 - Example Check

Run the following command and verify `PASS_MIN_DAYS` is 1 or more:

```
# grep PASS_MIN_DAYS /etc/login.defs
PASS_MIN_DAYS 1
```

Verify all users with a password have their minimum days between password change set to 1 or more:

```
# egrep ^[^:]+:[^!*] /etc/shadow | cut -d: -f1
*
# chage --list
Minimum number of days between password change : 1
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Relaxed to 1 day or more in alignment with Windows Server MP.

BL512-9200

Asset Manager

EVAL until 2020-12-31

C	I	A
123	123	123

Ensure password expiration warning days is 7 or more

Rule

Ensure password expiration warning days is 7 or more.

Description

The `PASS_WARN_AGE` parameter in `/etc/login.defs` allows an administrator to notify users that their password will expire in a defined number of days. It is recommended that the `PASS_WARN_AGE` parameter be set to 7 or more days.

Rationale

Providing an advance warning that a password will be expiring gives users time to think of a secure password. Users caught unaware may choose a simple password or write it down where it may be discovered.

I01 - Implementation Example

Set the `PASS_WARN_AGE` parameter to 7 in `/etc/login.defs`:

```
PASS_WARN_AGE 7
```

Modify user parameters for all users with a password set to match:

```
# chage --warndays 7 <user>
```

C01 - Example Check

Run the following command and verify `PASS_WARN_AGE` is 7 or more:

```
# grep PASS_WARN_AGE /etc/login.defs
PASS_WARN_AGE 7
```

Verify all users with a password have their number of days of warning before password expires set to 7 or more:

```
# egrep '^[^:]+:[^!]*' /etc/shadow | cut -d: -f1

# chage --list
Number of days of warning before password expires : 7
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1429

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure inactive password lock is 30 days or less

Rule

Ensure inactive password lock is 30 days or less.

Description

User accounts that have been inactive for over a given period of time can be automatically disabled. It is recommended that accounts that are inactive for 30 days after password expiration be disabled.

Rationale

Inactive accounts pose a threat to system security since the users are not logging in to notice failed login attempts or other anomalies.

I01 - Implementation Example

Run the following command to set the default password inactivity period to 30 days:

```
# useradd -D -f 30
```

Modify user parameters for all users with a password set to match:

```
# chage --inactive 30 <user>
```

C01 - Example Check

Run the following command and verify INACTIVE is 30 or less:

```
# useradd -D | grep INACTIVE  
INACTIVE=30
```

Verify all users with a password have Password inactive no more than 30 days after password expires:

```
# egrep ^[:]+:[^!]* /etc/shadow | cut -d: -f1  
  
*  
# chage --list  
Password inactive :
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3616

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure all users last password change date is in the past

Rule

Ensure all users last password change date is in the past.

Description

All users should have a password change date in the past.

Rationale

If a user's recorded password change date is in the future then they could bypass any set password expiration.

I01 - Implementation Example

Investigate any users with a password change date in the future and correct them. Locking the account, expiring the password, or resetting the password manually may be appropriate.

C01 - Example Check

Run the following command and verify nothing is returned:

```
# for usr in $(cut -d: -f1 /etc/shadow); do [[ $(chage --list $usr | grep '^Last password change' | cut -d: -f2) > $(date) ]] & done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.1.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4279

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure system user accounts are non-login

Rule Ensure system user accounts are non-login.

Note: Some system user accounts, such as sync, halt or shutdown are configured to use a dedicated application, such as /bin/sync or /sbin/shutdown, as login shell. Such a configuration is also compliant to this rule, if these applications are non-interactive.

Description

There are a number of accounts provided with Red Hat 8 that are used to manage applications and are not intended to provide an interactive shell.

Rationale

It is important to make sure that accounts that are not being used by regular users are prevented from being used to provide an interactive shell. By default Red Hat 8 sets the password field for these accounts to an invalid string, but it is also recommended that the shell field in the password file be set to /sbin/nologin. This prevents the account from potentially being used to run any commands.

I01 - Implementation Example

Execute the following commands to list all not compliant user accounts:

```
# awk -F: '($1!="root" && $1!="sync" && $1!="shutdown" && $1!="halt" && $1!~/^\/+ && $3<'"$(awk  
'/^s*UID_MIN/{print $2}' /etc/login.defs)'" && $7!="$(which nologin)'" && $7!="bin/false") {print}'  
/etc/passwd
```

```
# awk -F: '($1!="root" && $1!~/^\/+ && $3<'"$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs)'"') {print  
$1}' /etc/passwd | xargs -I '{}' passwd -S '{}' | awk '($2!="L" && $2!="LK") {print $1}'
```

Note: Depending on the PATH environment configuration of the executing user, the command part \$(which nologin) may return /usr/sbin/nologin, but the configured shell script in /etc/passwd is /sbin/nologin.

Set the shell for any accounts returned by the shown commands to /sbin/nologin, by replacing the placeholder <user> with the given username :

```
# usermod -s /sbin/nologin <user>
```

The following command will set all system accounts to a non-login shell:

```
# awk -F: '($1!="root" && $1!="sync" && $1!="shutdown" && $1!="halt" && $1~/^\/+ && $3<"$(awk  
'/^s*UID_MIN/{print $2}' /etc/login.defs)"' && $7!="$(which nologin)"' && $7!="bin/false") {print  
$1}' /etc/passwd | while read user do usermod -s $(which nologin) $user done
```

The following command will automatically lock not root system accounts:

```
# awk -F: '($1!="root" && $1~/^\/+ && $3<"$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs)"') {print  
$1}' /etc/passwd | xargs -I '{}' passwd -S '{}' | awk '($2!="L" && $2!="LK") {print $1}' | while read  
user do usermod -L $user done
```

C01 - Example Check

Run the following commands and verify no results are returned:

```
# awk -F: '($1!="root" && $1!="sync" && $1!="shutdown" && $1!="halt" && $1~/^\/+ && $3<"$(awk  
'/^s*UID_MIN/{print $2}' /etc/login.defs)"' && $7!="$(which nologin)"' && $7!="bin/false") {print}'  
/etc/passwd
```

```
# awk -F: '($1!="root" && $1~/^\/+ && $3<"$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs)"') {print  
$1}' /etc/passwd | xargs -I '{}' passwd -S '{}' | awk '($2!="L" && $2!="LK") {print $1}'
```

Note: Depending on the PATH environment configuration of the executing user, the command part `$(which nologin)` in the first command may return `/usr/sbin/nologin`, but the configured shell script in `/etc/passwd` is `/sbin/nologin`, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for dedicated applications as login shell. rephrased according system user definition.

BL512-4613

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure default group for the root account is GID 0

Rule

Ensure default group for the root account is GID 0.

Description

The `usermod` command can be used to specify which group the root user belongs to. This affects permissions of files that are created by the root user.

Rationale

Using GID 0 for the `root` account helps prevent `root` -owned files from accidentally becoming accessible to non-privileged users.

I01 - Implementation Example

Run the following command to set the `root` user default group to GID 0 :

```
# usermod -g 0 root
```

C01 - Example Check

Run the following command and verify the result is 0 :

```
# grep "^root:" /etc/passwd | cut -f4 -d:
0
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1755

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure default user umask is 027 or more restrictive

Rule

Ensure default user umask is 027 or more restrictive.

Description

The default `umask` determines the permissions of files created by users. The user creating the file has the discretion of making their files and directories readable by others via the `chmod` command. Users who wish to allow their files and directories to be readable by others by default may choose a different default `umask` by inserting the `umask` command into the standard shell configuration files (`.profile` , `.bashrc` , etc.) in their home directories.

Rationale

Setting a very secure default value for `umask` ensures that users make a conscious choice about their file permissions. A default `umask` setting of `077` causes files and directories created by users to not be readable by any other user on the system. A `umask` of `027` would make files and directories readable by users in the same Unix group, while a `umask` of `022` would make files readable by every user on the system.

I01 - Implementation Example

Edit the `/etc/bashrc`, `/etc/profile` and `/etc/profile.d/*.sh` files (and the appropriate files for any other shell supported on your system) and add or edit any `umask` parameters as follows:

```
umask 027
```

Note: The default user `umask` is initially defined in `/etc/login.defs`, but, by default, Red Hat Enterprise Linux 8 overwrites the configuration of this variable in `/etc/profile`. Depending on the system configuration, both locations must be adjusted.

C01 - Example Check

Run the following commands and verify all `umask` lines returned are `027` or more restrictive.

```
# grep "umask" /etc/bashrc
umask 027
# grep "umask" /etc/profile /etc/profile.d/*.sh
umask 027
```

Note: The default user `umask` is initially defined in `/etc/login.defs`, but, by default, Red Hat Enterprise Linux 8 overwrites the configuration of this variable in `/etc/profile`. Depending on the system configuration, both locations need to be verified.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.4

Based on superseded measure M730750

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for overwriting umask in `/etc/profile` instead of using `/etc/login.defs`.

BL512-6213

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure default user shell timeout is 900 seconds or less

Rule

Ensure default user shell timeout is 900 seconds or less.

Description

The default `TMOUT` determines the shell timeout for users. The `TMOUT` value is measured in seconds.

Rationale

Having no timeout value associated with a shell could allow an unauthorized user access to another user's shell session (e.g., user walks away from their computer and doesn't lock the screen). Setting a timeout value at least reduces the risk of this happening.

I01 - Implementation Example

Edit the `/etc/bashrc` and `/etc/profile` files (and the appropriate files for any other shell supported on your system) and add or edit any `umask` parameters as follows:

```
TMOUT=900
```

C01 - Example Check

Run the following commands and verify all `TMOUT` lines returned are 900 or less and at least one exists in each file.

```
# grep "^TMOUT" /etc/bashrc
TMOUT=900
# grep "^TMOUT" /etc/profile
TMOUT=900
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.5.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.4.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Corrected value in Implementation and Check section.

Configure authselect

Authselect is a utility that simplifies the configuration of user authentication on a Red Hat Enterprise Linux host. Authselect offers two ready-made profiles that can be universally used with all modern identity management systems

Authselect makes testing and troubleshooting easy because it only modifies files in these directories:

- /etc/nsswitch.conf
- /etc/pam.d/* files
- /etc/dconf/db/distro.d/* files

Notes:

- **Do not use authselect if your host is part of Red Hat Enterprise Linux Identity Management or Active Directory** . The ipa-client-install command, called when joining your host to a Red Hat Identity Management domain, takes full care of configuring authentication on your host. Similarly the realm join command, called when joining your host to an Active Directory domain, takes full care of configuring authentication on your host.
- You can create and deploy a custom profile by customizing one of the default profiles, the sssd, winbind, or the nis profile. This is particularly useful if Modifying a ready-made authselect profile is not enough for your needs. When you deploy a custom profile, the profile is applied to every user logging into the given host. This would be the recommended method, so that the existing profiles can remain unmodified.

Example of creating a custom authselect profile called custom-profile

```
# authselect create-profile custom-profile -b sssd --symlink-meta
```

BL512-0993

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Create custom authselect profile

Rule Create custom authselect profile.

Description

A custom profile can be created by copying and customizing one of the default profiles. The default profiles include: sssd, winbind, or the nis.

Rationale

A custom profile is required to customize many of the system PAM options.

I01 - Implementation Example

Run the following command to create a custom authselect profile:

```
# authselect create-profile <custom-profile name> -b <default profile to copy>
```

Example:

```
# authselect create-profile custom-profile -b sssd --symlink-meta
```

C01 - Example Check

Run the following command:

```
# authselect current | grep Profile ID: custom/  
  
Profile ID: custom/
```

Verify that the custom profile follows local site policy.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.3.1

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

BL512-0992

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Select default authselect profile for user log in

Rule

Select authselect profile used for every user logging in.

Description

You can select a profile for the authselect utility for a specific host. The profile will be applied to every user logging into the host.

You can create and deploy a custom profile by customizing one of the default profiles, the sssd, winbind, or the nis profile.

Rationale

When you deploy a profile, the profile is applied to every user logging into the given host.

I01 - Implementation Example

Run the following command to select a custom authselect profile

```
# authselect select custom/<CUSTOM PROFILE NAME> {with-<OPTIONS>}
```

Example:

```
# authselect select custom/custom-profile with-sudo with-faillock without-nullok
```

C01 - Example Check

Run the following command and verify that the current custom authselect profile follows local site policy:

```
# authselect current
```

Output should be similar to:

```
Profile ID:
Enabled features:
- with-sudo
- with-faillock
- without-nullok
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.3.2

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

BL512-0991

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure authselect includes with-faillock

Rule

Ensure used authselect profile includes with-faillock.

Description

The `pam_faillock.so` module maintains a list of failed authentication attempts per user during a specified interval and locks the account in case there were more than deny consecutive failed authentications. It stores the failure records into per-user files in the tally directory

Rationale

Locking out user IDs after `n` unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

I01 - Implementation Example

Run the following command to include the `with-faillock` option

```
# authselect select <PROFILE NAME> with-faillock
```

Example:

```
# authselect select custom/custom-profile with-sudo with-faillock without-nullok
```

C01 - Example Check

Run the following commands to verify that authselect includes the `with-faillock` feature

```
# authselect current | grep with-faillock  
- with-faillock
```

```
# grep with-faillock /etc/authselect/authselect.conf  
with-faillock
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.3.3

Version History (Latest Entry)

v1.0 (2020-08-07): created (EVAL until 2020-12-31)

Imported from CIS-RHEL-8 benchmark.

BL512-8910

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure root login is restricted to system console

Rule Ensure root login is restricted to system console.

Description

The file `/etc/securetty` contains a list of valid terminals that may be logged in directly as root. In Red Hat Enterprise Linux 8, the `securetty` PAM module is disabled by default and the configuration file `/etc/securetty` is not present.

Rationale

Since the system console has special properties to handle emergency situations, it is important to ensure that the console is in a physically secure location and that unauthorized consoles have not been defined.

I01 - Implementation Example

Remove entries for any consoles that are not in a physically secure location.

C01 - Example Check

```
# cat /etc/securetty
```

Note: In Red Hat Enterprise Linux 8, the `securetty` PAM module is disabled by default and the configuration file `/etc/securetty` is not present, also meaning compliance to this rule.

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for default disabled state of `securetty` in RHEL8.

BL512-8911

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure access to the su command is restricted

Rule Ensure access to the su command is restricted:

- Usage of `su` command must be restricted to dedicated system group.

Description

The `su` command allows a user to run a command or shell as another user. The program has been superseded by `sudo`, which allows for more granular control over privileged access. Normally, the `su` command can be executed by any user. By uncommenting the `pam_wheel.so` statement in `/etc/pam.d/su`, the `su` command will only allow users in the wheel group to execute `su`.

Rationale

Restricting the use of `su`, and using `sudo` in its place, provides system administrators better control of the escalation of user privileges to execute privileged commands. The `sudo` utility also provides a better logging and audit mechanism, as it can log each command executed via `sudo`, whereas `su` can only record that a user executed the `su` program.

I01 - Implementation Example

Add the following line to the `/etc/pam.d/su` file:

```
auth required pam_wheel.so use_uid
```

Create a comma separated list of users in the wheel statement in the `/etc/group` file:

```
wheel:x:10:root,<user list>
```

C01 - Example Check

Run the following command and verify output includes matching line:

```
# grep pam_wheel.so /etc/pam.d/su
auth required pam_wheel.so use_uid
```

Run the following command and verify users in `wheel` group match site policy:

```
# grep wheel /etc/group
wheel:x:10:root,
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 5.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 5.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2718

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Restrict sudo to dedicated users

Rule

Restrictions to the `sudo` command includes the following rules:

1. Avoid configurations allowing users to gain higher than standard privileges without authentication, e.g., the NOPASSWD option should not be used in `/etc/sudoers`.

Note:

This applies only to `interactive` user accounts according the user category definition. Accounts used for automatic, remote system maintenance must be restricted in the commands which are allowed to run with elevated privileges.

2. Remove any user or group from the sudo configuration file, which are not mandatory for executing privileged commands.
3. If a group is assigned sudo privileges, remove any users from this group, which are not mandatory for executing privileged commands.

Description

The `sudo` command requires the calling user to enter their password. This is an important distinction, because it means it is possible to delegate administrative responsibility to users without having to supply everyone with the root password.

Rationale

Restricting users, which are allowed to use the `sudo` command to a minimum and forcing invoking users to enter their password by not using the NOPASSWD option provides better control of the escalation of user privileges to execute privileged commands.

I01 - Implementation

`sudo` is configured in the `/etc/sudoers` file. One should use the `visudo` tool to edit the file, as it will check the configuration for correctness. The manual page for `sudo` and `sudoers` should be consulted before implementation.

A whitelist approach should be chosen to implement the concept of least privileges, i.e. assemble a list of users and/or user groups with the corresponding commands they need to execute. Be as restrictive as possible.

Remove any users and groups, which are not intended to run privileged commands.

Generic configuration rules:

- Avoid usage of the NOPASSWD option, as it allows execution of commands without entering a password.
- Limit the password caching to the minimum needed duration or disable it completely (the default is 5 minutes).
- Avoid usage of wildcards in the `/etc/sudoers` file as they can confuse the concept of privilege limitation.
- Do not use the token ALL for the commandlist field in the `/etc/sudoers` file.
- Provide complete paths for commands, as a user could gain root access through malicious code execution, if only an executable name is given.
- Check the rights for scripts called by **sudo**. The files must belong to root, and no-one apart from root is allowed to have write permissions. This also applies to other files that should be executed by root and the surrounding directory trees.
- Do not allow sudo for well-known applications which allow an escape to the shell (e.g., **vi**, **vim**, **emacs**, etc.) or use it in combination with the parameter **NOEXEC**
- Do not allow sudo for applications which might be able to access confidential files such as `/etc/shadow` e.g., **less**.

Note:

Some Linux/Unix distributions have a default configuration in `/etc/sudoers` allowing root to use **sudo** to run any command as any user:

```
root ALL = (ALL) ALL
```

This does not violate this rule, because it only affects calls to **sudo** from contexts already having unlimited privileges.

Note:

Access to **vim** or **vi** using **sudo** can be a security risk. Unprivileged users can drop to a privileged shell using **sudo vim**.

The **sudoedit** command should be used instead.

Example to enable access to **sudo** edit by specifying the command and the file that may be edited:

```
user1 ALL= sudoedit /etc/httpd/conf.d/ssl.conf #no absolute path for sudoedit  
binary#
```

user sudo command

```
sudoedit /etc/httpd/conf.d/ssl.conf #no need for prefixing 'sudo' while  
executing the sudo command#
```

Note:

Do not use the full path for **sudoedit** `/usr/bin/sudoedit` as a rule, as it allows to run `sudo sudoedit`, instead the user should run only **sudoedit**.

Additional information for the previous two Red Hat notes: <https://access.redhat.com/solutions/57331>
(Red Hat login required)

Crossreferences

Based on superseded measure M910080

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Rephrased note for interactive user accounts according definition.

BL512-5593

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Automatic logon must not be enabled

Rule

Automatic logon must not be enabled.

Description

Some UNIX and Linux systems can be configured to login to a console or a windows manager with a pre-configured user account automatically without entering a password. This option must be disabled to prevent unauthorized access.

Rationale

If a system is configured for auto logon, anyone who has physical access to the computer host can gain full access, including any network or networks it is connected to.

I01 - Implementation

During system installation, ensure any settings for automatic logons are disabled.

Do not enable automatic logons.

Crossreferences

Based on superseded measure M150034

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs.

BL512-8083

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Password-protected screensavers

Rule

When using a desktop environment or graphical user interface, configure a screensaver with the password option and set the timeout lock parameter to not more than 15 minutes.

E01 - Exemption

This rule is not mandatory, if rule [BL512-5500 - Ensure X Window System is not installed](#) is applied.

Description

An attacker could gain local access to a host while a user is logged into the desktop environment and the user physically leaves without logging out. Screensavers help protect the OS in such scenarios by automatically blocking the screen and requiring a new successful login to proceed on the desktop.

To prevent users from overwriting the required settings in their user configuration, appropriate messages can be integrated into login messages and/or login windows.

Rationale

Unauthorized access to the host can lead to modifications and exposure of sensitive information of the operating system as well as modification of network resources.

No third-party screensavers (e.g., from the Internet) may be used to prevent the danger of introducing Trojan horses.

I01 - Implementation

Enforce password-protected screensavers according to the desktop environment.

Crossreferences

Based on superseded measure M300991

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added exemption 01 according feedback from review meetings.

System Maintenance

Recommendations in this section are intended as maintenance and are intended to be checked on a frequent basis to ensure system stability. Many recommendations do not have quick remediations and require investigation into the cause and best fix available and may indicate an attempted breach of system security.

System File Permissions

This section provides guidance on securing aspects of system files and directories.

BL512-6200

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Audit system file permissions

Rule

Audit system file permissions and verify according to origination package.

Description

The RPM package manager has a number of useful options. One of these, the `-v` for RPM option, can be used to verify that system packages are correctly installed. The `-v` option can be used to verify a particular package or to verify all system packages. If no output is returned, the package is installed correctly. The following table describes the meaning of output from the verify option:

Code	Meaning
S	File size differs
M	File mode differs (includes permissions and file type)
5	The MD5 checksum differs
D	The major and minor version numbers differ on a device file
L	A mismatch occurs in a link
U	The file ownership differs
G	The file group owner differs
T	The file time (mtime) differs

The `rpm -qf` command can be used to determine which package a particular file belongs to. For example the following commands determines which package the `/bin/bash` file belongs to:

```
# rpm -qf /bin/bash
```

```
bash-4.1.2-29.el6.x86_64
```

To verify the settings for the package that controls the `/bin/bash` file, run the following:

```
# rpm -V bash-4.1.2-29.el6.x86_64
```

```
.M..... /bin/bash
```

Note that you can feed the output of the `rpm -qf` command to the `rpm -V` command:

```
# rpm -V `rpm -qf /etc/passwd`
```

```
.M..... c /etc/passwd  
S.5....T c /etc/printcap
```

Rationale

It is important to confirm that packaged system files and directories are maintained with the permissions they were intended to have from the OS vendor.

I01 - Implementation Example

Execute the following command to find discrepancies or changes on system files:

```
# rpm -Va --nomtime --nosize --nomd5 --nolinkto
```

Correct any discrepancies shown as result from the executed command until no output is returned or risk for given changes is mitigated or accepted.

C01 - Example Check

Run the following command to review all installed packages. Note that this may be very time consuming and may be best scheduled via the `cron` utility.

```
# rpm -Va --nomtime --nosize --nomd5 --nolinkto
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.1

Based on superseded measure M802906

Based on superseded measure M447647

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Removed irrelevant 'dpkg' explanation in description.

BL512-2492

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/passwd are configured

Rule Ensure permissions on /etc/passwd are configured:

- Owned by user and group root
- Permissions set to 0644 or more restrictive

Description

The /etc/passwd file contains user account information that is used by many system utilities and therefore must be readable for these utilities to operate.

Rationale

It is critical to ensure that the /etc/passwd file is protected from unauthorized write access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

I01 - Implementation Example

Run the following command to set permissions on /etc/passwd :

```
# chown root:root /etc/passwd
# chmod 644 /etc/passwd
```

C01 - Example Check

Run the following command and verify Uid and Gid are both 0/root and Access is 644 :

```
# stat /etc/passwd
Access: (0644/-rw-r--r--)  Uid: ( 0/ root)  Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1728

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/shadow are configured

Rule Ensure permissions on /etc/shadow are configured:

- Owned by user and group root,
- Permissions set to 000.

Description

The `/etc/shadow` file is used to store the information about user accounts that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale

If attackers can gain read access to the `/etc/shadow` file, they can easily run a password cracking program against the hashed password to break it. Other security information that is stored in the `/etc/shadow` file (such as expiration) could also be useful to subvert the user accounts.

I01 - Implementation Example

Run the following commands to set permissions on `/etc/shadow` :

```
# chown root:root /etc/shadow
# chmod 000 /etc/shadow
```

C01 - Example Check

Run the following command and verify `Uid` and `Gid` are `0/root` , and `Access` is `000` :

```
# stat /etc/shadow
Access: (0000/-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4776

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/group are configured

Rule Ensure permissions on /etc/group are configured:

- Owned by user and group root,
- Permissions set to 0644 or more restrictive.

Description

The /etc/group file contains a list of all the valid groups defined in the system. The command below allows read/write access for root and read access for everyone else.

Rationale

The /etc/group file needs to be protected from unauthorized changes by non-privileged users, but needs to be readable as this information is used with many non-privileged programs.

I01 - Implementation Example

Run the following command to set permissions on /etc/group :

```
# chown root:root /etc/group
# chmod 644 /etc/group
```

C01 - Example Check

Run the following command and verify Uid and Gid are both 0/root and Access is 644 :

```
# stat /etc/group
Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3770

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/gshadow are configured

Rule

Ensure permissions on /etc/gshadow are configured:

- Owned by user and group root,
- Permissions set to 000.

Description

The /etc/gshadow file is used to store the information about groups that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale

If attackers can gain read access to the /etc/gshadow file, they can easily run a password cracking program against the hashed password to break it. Other security information that is stored in the /etc/gshadow file (such as group administrators) could also be useful to subvert the group.

I01 - Implementation Example

Run the following chown to set permissions on /etc/gshadow :

```
# chown root:root /etc/gshadow
# chmod 000 /etc/gshadow
```

C01 - Example Check

Run the following command and verify Uid and Gid are 0/root , and Access is 000 :

```
# stat /etc/gshadow
Access: (0000/-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2600

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/passwd- are configured

Rule Ensure permissions on /etc/passwd- are configured:

- Owned by user and group root,
- Permissions set to 0644 or more restrictive.

Description

The /etc/passwd- file contains backup user account information.

Rationale

It is critical to ensure that the /etc/passwd- file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

I01 - Implementation Example

Run the following command to set permissions on /etc/passwd- :

```
# chown root:root /etc/passwd-  
# chmod u-x,go-wx /etc/passwd-
```

C01 - Example Check

Run the following command and verify Uid and Gid are both 0/root and Access is 644 or more restrictive:

```
# stat /etc/passwd-  
Access: (0644/-rw-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4016

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/shadow- are configured

Rule Ensure permissions on /etc/shadow- are configured:

- Owned by user and group root,
- Permissions set to 000.

Description

The /etc/shadow- file is used to store backup information about user accounts that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale

It is critical to ensure that the /etc/shadow- file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

I01 - Implementation Example

Run the following commands to set permissions on /etc/shadow-:

```
# chown root:root /etc/shadow-  
# chmod 000 /etc/shadow-
```

C01 - Example Check

Run the following command and verify Uid and Gid is 0/root, and Access is 000:

```
# stat /etc/shadow-  
Access: (0000/-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2070

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/group- are configured

Rule Ensure permissions on /etc/group- are configured:

- Owned by user and group root,
- Permissions set to 0644 or more restrictive.

Description

The /etc/group- file contains a backup list of all the valid groups defined in the system.

Rationale

It is critical to ensure that the /etc/group- file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

I01 - Implementation Example

Run the following command to set permissions on /etc/group- :

```
# chown root:root /etc/group-  
# chmod u-x,go-wx /etc/group-
```

C01 - Example Check

Run the following command and verify Uid and Gid are both 0/root and Access is 644 or more restrictive:

```
# stat /etc/group-  
Access: (0644/-rw-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.8

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1476

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure permissions on /etc/gshadow- are configured

Rule

Ensure permissions on /etc/gshadow- are configured:

- Owned by user and group root,
- Permissions set to 000.

Description

The /etc/gshadow- file is used to store backup information about groups that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale

It is critical to ensure that the /etc/gshadow- file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

I01 - Implementation Example

Run the following commands to set permissions on /etc/gshadow- :

```
# chown root:root /etc/gshadow-  
# chmod 000 /etc/gshadow-
```

C01 - Example Check

Run the following command and verify Uid and Gid are 0/root, and Access is 000:

```
# stat /etc/gshadow-  
Access: (0000/-----) Uid: ( 0/ root) Gid: ( 0/ root)
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.9

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9732

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no world writable files exist

Rule

Ensure no world-writable files exist.

Description

Unix-based systems support variable settings to control access to files. World writable files are the least secure. See the `chmod(2)` man page for more information.

Rationale

Data in world-writable files can be modified and compromised by any user on the system. World writable files may also indicate an incorrectly written script or program that could potentially be the cause of a larger compromise to the system's integrity.

I01 - Implementation Example

Removing write access for the "other" category (`chmod o-w <filename>`) is advisable, but always consult relevant vendor documentation to avoid breaking any application dependencies on a given file.

C01 - Example Check

Run the following command and verify no files are returned:

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -type f -perm -0002
```

The command above only searches local filesystems, there may still be compromised items on network mounted partitions. If needed, the following command can be run manually for individual partitions by replacing the placeholder `<partition>` with the requested partition:

```
# find <partition> -xdev -type f -perm -0002
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.10

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.10

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-7749

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no unowned files or directories exist

Rule Ensure no unowned files or directories exist for local filesystems.

Note: Local filesystems does not apply to “container-local” system filesystems, such as used by Docker or OpenShift, as they are considered “remote” to the system to be hardened.

Description

Sometimes when administrators delete users from the password file, they neglect to remove all files owned by those users from the system.

Rationale

A new user who is assigned the deleted user’s user ID may then end up “owning” these files, and thus have more access on the system than intended.

I01 - Implementation Example

Locate files that are owned by users not listed in the system configuration files, and reset the ownership of these files to some active user on the system as appropriate.

C01 - Example Check

Run the following command and verify no files are returned:

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -nouser
```

The command above only searches local filesystems, there may still be compromised items on network mounted partitions. The following command can be run manually for individual partitions if needed:

```
# find / -xdev -nouser
```

Crossreferences

Based on CIS Benchmark ‘Red Hat Enterprise Linux 8’ (v1.0.0.1): 6.1.11

Based on CIS Benchmark ‘Distribution Independent Linux’ (v2.0.0): 6.1.11

Based on superseded measure M509730

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Text in rationale, description adjusted to not talk about groups.

BL512-4346

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no ungrouped files or directories exist

Rule Ensure no ungrouped files or directories exist.

Note: Local filesystems does not apply to "container-local" system filesystems, such as used by Docker or OpenShift, as they are considered "remote" to the system to be hardened.

Description

Sometimes when administrators delete groups from the system, they neglect to remove all files owned by those groups.

Rationale

A new user who is assigned the deleted group's group ID may then end up "owning" these files, and thus have more access on the system than intended.

I01 - Implementation Example

Locate files that are owned by groups not listed in the system configuration files, and reset the ownership of these files to some active group on the system as appropriate.

C01 - Example Check

Run the following command and verify no files are returned:

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -nogroup
```

The command above only searches local filesystems, there may still be compromised items on network mounted partitions. The following command can be run manually for individual partitions if needed:

```
# find / -xdev -nogroup
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.12

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.12

Based on superseded measure M509730

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Text in rationale, description adjusted to not talk about users.

BL512-3093

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Audit SUID executables

Rule

Audit SUID executables and verify their integrity and necessity.

Description

The owner of a file can set the file's permissions to run with the owner's permissions, even if the user running the program is not the owner. The most common reason for a SUID program is to enable users to perform functions (such as changing their password) that require root privileges.

Rationale

There are valid reasons for SUID programs, but it is important to identify and review such programs to ensure they are legitimate.

I01 - Implementation Example

Execute the following command to list all SUID executables and ensure no rogue SUID programs have been introduced into the system.

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -type f -perm -4000
```

Review the files returned and confirm the integrity and necessity of these binaries.

C01 - Example Check

Run the following command to list SUID files:

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -type f -perm -4000
```

The command above only searches local filesystems, there may still be compromised items on network mounted partitions. The following command can be run manually for individual partitions if needed:

```
# find / -xdev -type f -perm -4000
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.13

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.13

Based on superseded measure M812040

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Text in description adjusted to not talk about SGID.

BL512-2294

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Audit SGID executables

Rule

Audit SGID executables and verify their integrity and necessity.

Description

The owner of a file can set the file's permissions to run with group's permissions, even if the user running the program is not a member of the group. The most common reason for a SGID program is to enable users to perform functions (such as changing their password) that require root privileges.

Rationale

There are valid reasons for SGID programs, but it is important to identify and review such programs to ensure they are legitimate. Review the files returned by the action in the audit section and check to see if system binaries have a different checksum than what from the package. This is an indication that the binary may have been replaced.

I01 - Implementation Example

Execute the following command to list all SGID executables and ensure no rogue SGID programs have been introduced into the system.

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -type f -perm -2000
```

Review the files returned by the action in the Audit section and confirm the integrity and necessity of these binaries.

C01 - Example Check

Run the following command to list SGID files:

```
# df --local -P | awk {'if (NR!=1) print $6'} | xargs -I '{}' find '{}' -xdev -type f -perm -2000
```

The command above only searches local filesystems, there may still be compromised items on network mounted partitions. The following command can be run manually for individual partitions if needed:

```
# find / -xdev -type f -perm -2000
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.1.14

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.1.14

Based on superseded measure M812040

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Text in description adjusted to not talk about SUID.

User and Group Settings

This section provides guidance on securing aspects of the users and groups.

Note: The recommendations in this section check local users and groups. Any users or groups from other sources such as LDAP will not be audited. In a domain environment similar checks should be performed against domain users and groups.

BL512-4722

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure password fields are not empty

Rule

Ensure password fields in /etc/shadow are not empty.

Description

An account with an empty password field means that anybody may log in as that user without providing a password.

Rationale

All accounts must have passwords or be locked to prevent the account from being used by an unauthorized user.

I01 - Implementation Example

Execute the following command to list all accounts without a password:

```
# cat /etc/shadow | awk -F: '($2 == "" ) { print $1 " does not have a password "}'
```

If any results are shown, run the following command to lock the account until it can be determined why it does not have a password:

```
# passwd -l <username>
```

Also, check to see if the account is logged in and investigate what it is being used for to determine if it needs to be forced off.

C01 - Example Check

Run the following command and verify that no output is returned:

```
# cat /etc/shadow | awk -F: '($2 == "" ) { print $1 " does not have a password "}'
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.1

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.1

Based on superseded measure M391200

Based on superseded measure M905901

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-5671

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no legacy "+" entries exist in /etc/passwd

Rule

Ensure no legacy "+" entries exist in /etc/passwd.

Description

The character + in various files used to be markers for systems to insert data from NIS maps at a certain point in a system configuration file. These entries are no longer required on most systems, but may exist in files that have been imported from other platforms.

Rationale

These entries may provide an avenue for attackers to gain privileged access on the system.

I01 - Implementation Example

Remove any legacy '+' entries from /etc/passwd if they exist.

C01 - Example Check

Run the following command and verify that no output is returned:

```
# grep '^+: ' /etc/passwd
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.2

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.2

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2810

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no legacy "+" entries exist in /etc/shadow

Rule

Ensure no legacy "+" entries exist in /etc/shadow.

Description

The character + in various files used to be markers for systems to insert data from NIS maps at a certain point in a system configuration file. These entries are no longer required on most systems, but may exist in files that have been imported from other platforms.

Rationale

These entries may provide an avenue for attackers to gain privileged access on the system.

I01 - Implementation Example

Remove any legacy '+' entries from /etc/shadow if they exist.

C01 - Example Check

Run the following command and verify that no output is returned:

```
# grep '^+: ' /etc/shadow
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.4

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.3

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-2361

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no legacy "+" entries exist in /etc/group

Rule Ensure no legacy "+" entries exist in /etc/group.

Description

The character + in various files used to be markers for systems to insert data from NIS maps at a certain point in a system configuration file. These entries are no longer required on most systems, but may exist in files that have been imported from other platforms.

Rationale

These entries may provide an avenue for attackers to gain privileged access on the system.

I01 - Implementation Example

Remove any legacy '+' entries from /etc/group if they exist.

C01 - Example Check

Run the following command and verify that no output is returned:

```
# grep '^\+: ' /etc/group
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.5

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.4

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3582

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure root is the only UID 0 account

Rule

Ensure root is the only UID 0 account.

Description

Any account with UID 0 has superuser privileges on the system.

Rationale

This access must be limited to only the default `root` account and only from the system console. Administrative access must be through an unprivileged account using an approved mechanism as noted in rule [BL512-8911 Ensure access to the su command is restricted](#).

I01 - Implementation Example

Remove any users other than `root` with UID 0 or assign them a new UID if appropriate.

C01 - Example Check

Run the following command and verify that only "root" is returned:

```
# cat /etc/passwd | awk -F: '($3 == 0) { print $1 }'  
root
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.6

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.5

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3597

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure root PATH Integrity

Rule

Ensure integrity of root environment PATH variable.

Description

The `root` user can execute any command on the system and could be fooled into executing programs unintentionally if the `PATH` is not set correctly.

Rationale

Including the current working directory (`.`) or other writable directory in `root`'s executable path makes it likely that an attacker can gain superuser access by forcing an administrator operating as `root` to execute a Trojan horse program.

I01 - Implementation Example

Run the following script and correct or justify any items shown as result:

```
for x in $(echo $PATH | tr ":" " "); do
  if [ -d "$x" ] ; then
    ls -ldH "$x" | awk '
$9 == "." {print "PATH contains current working directory (.)" }
$3 != "root" {print $9, "is not owned by root"}
substr($1,6,1) != "-" {print $9, "is group writable"}
substr($1,9,1) != "-" {print $9, "is world writable"}
    else
      echo "$x is not a directory"
    fi
  fi
done
```

C01 - Example Check

Run the following script and verify no results are returned:

```
for x in $(echo $PATH | tr ":" " "); do
  if [ -d "$x" ] ; then
    ls -ldH "$x" | awk '
$9 == "." {print "PATH contains current working directory (.)" }
$3 != "root" {print $9, "is not owned by root"}
substr($1,6,1) != "-" {print $9, "is group writable"}
substr($1,9,1) != "-" {print $9, "is world writable"}
    else
      echo "$x is not a directory"
    fi
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.3

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.6

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-9227

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure all users' home directories exist

Rule Ensure all users' home directories exist.

Note: Users in this rule refer only to `interactive` users according the definition in the scope section.

Description

Users can be defined in `/etc/passwd` without a home directory or with a home directory that does not actually exist.

Rationale

If the user's home directory does not exist or is unassigned, the user will be placed in `/` and will not be able to write any files or have local environment variables set.

I01 - Implementation Example

Execute the following script to list users without an existing home directory:

```
#!/bin/bash
grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""$(which nologin)"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read -r user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    fi
done
```

If any users' home directories do not exist, create them and make sure the respective user owns the directory. Users without an assigned home directory should be removed or assigned a home directory as appropriate.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash
grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""$(which nologin)"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read -r user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.20

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.7

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for limiting rule to interactive users.

BL512-3452

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure users' home directories permissions are 750 or more restrictive

Rule Ensure users' home directories permissions are 750 or more restrictive.

Note: Users in this rule refer only to `interactive` users according the definition in the scope section.

Description

While the system administrator can establish secure permissions for users' home directories, the users can easily override these.

Rationale

Group or world-writable user home directories may enable malicious users to steal or modify other users' data or to gain another user's system privileges.

I01 - Implementation Example

Run the following script to list inappropriately configured home directories and adjust the directory permissions to be 750 or more restrictive:

```
#!/bin/bash
grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    dirperm=$(ls -ld $dir | cut -f1 -d" ")
    if [ $(echo $dirperm | cut -c6) != "-" ]; then
      echo "Group Write permission set on the home directory ($dir) of user $user"
    fi
    if [ $(echo $dirperm | cut -c8) != "-" ]; then
      echo "Other Read permission set on the home directory ($dir) of user $user"
    fi
    if [ $(echo $dirperm | cut -c9) != "-" ]; then
      echo "Other Write permission set on the home directory ($dir) of user $user"
    fi
    if [ $(echo $dirperm | cut -c10) != "-" ]; then
      echo "Other Execute permission set on the home directory ($dir) of user $user"
    fi
  fi
done
```

Making global modifications to user home directories without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user file permissions and determine the action to be taken in accordance with site policy.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash
grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    dirperm=$(ls -ld $dir | cut -f1 -d" ")
    if [ $(echo $dirperm | cut -c6) != "-" ]; then
      echo "Group Write permission set on the home directory ($dir) of user $user"
    fi
    if [ $(echo $dirperm | cut -c8) != "-" ]; then
      echo "Other Read permission set on the home directory ($dir) of user $user"
    fi
    if [ $(echo $dirperm | cut -c9) != "-" ]; then
      echo "Other Write permission set on the home directory ($dir) of user $user"
    fi
    if [ $(echo $dirperm | cut -c10) != "-" ]; then
      echo "Other Execute permission set on the home directory ($dir) of user $user"
    fi
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.7

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.8

Based on superseded measure M406350

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for limiting rule to interactive users.

BL512-4388

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure users own their home directories

Rule Ensure users own their home directories.

Note: Users in this rule refer only to `interactive` users according the definition in the scope section.

Description

The user home directory is space defined for the particular user to set local environment variables and to store personal files.

Rationale

Since the user is accountable for files stored in the user home directory, the user must be the owner of the directory.

I01 - Implementation Example

Run the following script to list inappropriately configured user home directories:

```
#!/bin/bash

grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 != "/bin/false") { print $1 " " $6 }' | while read user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    else
        owner=$(stat -L -c "%U" "$dir")
        if [ "$owner" != "$user" ]; then
            echo "The home directory ($dir) of user $user is owned by $owner."
        fi
    fi
done
```

Change the ownership of any home directories that are not owned by the defined user to the correct user.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    owner=$(stat -L -c "%U" "$dir")
    if [ "$owner" != "$user" ]; then
      echo "The home directory ($dir) of user $user is owned by $owner."
    fi
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.8

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.9

Based on superseded measure M406350

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for limiting rule to interactive users.

BL512-9700

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure users' dot files are not group or world writable

Rule Ensure users' dot files are not group or world writable.

Note: Users in this rule refer only to `interactive` users according the definition in the scope section.

Description

While the system administrator can establish secure permissions for users' "dot" files, the users can easily override these.

Rationale

Group or world-writable user configuration files may enable malicious users to steal or modify other users' data or to gain another user's system privileges.

I01 - Implementation Example

Run the following script and adjust the permissions of the returned users' dot files:

```
#!/bin/bash

grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    else
        for file in $dir/.[A-Za-z0-9]*; do
            if [ ! -h "$file" -a -f "$file" ]; then
                fileperm=$(ls -ld $file | cut -f1 -d" ")

                if [ $(echo $fileperm | cut -c6) != "-" ]; then
                    echo "Group Write permission set on file $file"
                fi
                if [ $(echo $fileperm | cut -c9) != "-" ]; then
                    echo "Other Write permission set on file $file"
                fi
            fi
        done
    fi
done
```

Making global modifications to users' files without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user dot file permissions and determine the action to be taken in accordance with site policy.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

grep -E -v '^(halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    for file in $dir/[A-Za-z0-9]*; do
      if [ ! -h "$file" -a -f "$file" ]; then
        fileperm=$(ls -ld $file | cut -f1 -d" ")

        if [ $(echo $fileperm | cut -c6) != "-" ]; then
          echo "Group Write permission set on file $file"
        fi
        if [ $(echo $fileperm | cut -c9) != "-" ]; then
          echo "Other Write permission set on file $file"
        fi
      fi
    done
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.9

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.10

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Added note for limiting rule to interactive users.

BL512-4619

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no users have .forward files

Rule

Ensure no users have .forward files.

Description

The `.forward` file specifies an email address to forward the user's mail to.

Rationale

Use of the `.forward` file poses a security risk in that sensitive data may be inadvertently transferred outside the organization. The `.forward` file also poses a risk as it can be used to execute commands that may perform unintended actions.

I01 - Implementation Example

Run the following script and remove listed `.forward` files in agreement with the owning user:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 != "/bin/false") { print $1 " " $6 }' | while read user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    else
        if [ ! -h "$dir/.forward" -a -f "$dir/.forward" ]; then
            echo ".forward file $dir/.forward exists"
        fi
    fi
done
```

Making global modifications to users' files without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user `.forward` files and determine the action to be taken in accordance with site policy.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    if [ ! -h "$dir/.forward" -a -f "$dir/.forward" ]; then
      echo ".forward file $dir/.forward exists"
    fi
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.10

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.11

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-5819

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no users have .netrc files

Rule

Ensure no users have .netrc files.

Description

The `.netrc` file contains data for logging into a remote host for file transfers via FTP.

Rationale

The `.netrc` file presents a significant security risk since it stores passwords in unencrypted form. Even if FTP is disabled, user accounts may have brought over `.netrc` files from other systems which could pose a risk to those systems.

I01 - Implementation Example

Run the following script and remove listed `.netrc` files in agreement with the owning user:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 != "/bin/false") { print $1 " " $6 }' | while read user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    else
        if [ ! -h "$dir/.netrc" -a -f "$dir/.netrc" ]; then
            echo ".netrc file $dir/.netrc exists"
        fi
    fi
done
```

Making global modifications to users' files without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user `.netrc` files and determine the action to be taken in accordance with site policy.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    if [ ! -h "$dir/.netrc" -a -f "$dir/.netrc" ]; then
      echo ".netrc file $dir/.netrc exists"
    fi
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.11

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.12

Based on superseded measure M406350

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1498

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure users' .netrc Files are not group or world accessible

Rule

Ensure users' .netrc Files are not group or world accessible.

Description

While the system administrator can establish secure permissions for users' .netrc files, the users can easily override these.

Rationale

.netrc files may contain unencrypted passwords that may be used to attack other systems.

I01 - Implementation Example

Run the following script and adjust permissions on listed .netrc files in agreement with the owning user:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 != "/bin/false") { print $1 " " $6 }' | while read user dir; do
    if [ ! -d "$dir" ]; then
        echo "The home directory ($dir) of user $user does not exist."
    else
        for file in $dir/.netrc; do
            if [ ! -h "$file" -a -f "$file" ]; then
                fileperm=$(ls -ld $file | cut -f1 -d" ")
                if [ $(echo $fileperm | cut -c5) != "-" ]; then
                    echo "Group Read set on $file"
                fi
                if [ $(echo $fileperm | cut -c6) != "-" ]; then
                    echo "Group Write set on $file"
                fi
                if [ $(echo $fileperm | cut -c7) != "-" ]; then
                    echo "Group Execute set on $file"
                fi
                if [ $(echo $fileperm | cut -c8) != "-" ]; then
                    echo "Other Read set on $file"
                fi
                if [ $(echo $fileperm | cut -c9) != "-" ]; then
                    echo "Other Write set on $file"
                fi
                if [ $(echo $fileperm | cut -c10) != "-" ]; then
                    echo "Other Execute set on $file"
                fi
            fi
        done
    fi
done
```

Making global modifications to users' files without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user `.netrc` file permissions and determine the action to be taken in accordance with site policy.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    for file in $dir/.netrc; do
      if [ ! -h "$file" -a -f "$file" ]; then
        fileperm=$(ls -ld $file | cut -f1 -d" ")
        if [ $(echo $fileperm | cut -c5) != "-" ]; then
          echo "Group Read set on $file"
        fi
        if [ $(echo $fileperm | cut -c6) != "-" ]; then
          echo "Group Write set on $file"
        fi
        if [ $(echo $fileperm | cut -c7) != "-" ]; then
          echo "Group Execute set on $file"
        fi
        if [ $(echo $fileperm | cut -c8) != "-" ]; then
          echo "Other Read set on $file"
        fi
        if [ $(echo $fileperm | cut -c9) != "-" ]; then
          echo "Other Write set on $file"
        fi
        if [ $(echo $fileperm | cut -c10) != "-" ]; then
          echo "Other Execute set on $file"
        fi
      fi
    done
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.12

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.13

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4051

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no users have .rhosts files

Rule Ensure no users have .rhosts files.

Description

While no `.rhosts` files are shipped by default, users can easily create them.

Rationale

This action is only meaningful if `.rhosts` support is permitted in the file `/etc/pam.conf`. Even though the `.rhosts` files are ineffective if support is disabled in `/etc/pam.conf`, they may have been brought over from other systems and could contain information useful to an attacker for those other systems.

I01 - Implementation Example

Run the following script and remove listed `.rhosts` files in agreement with the owning user:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 != "/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    for file in $dir/.rhosts; do
      if [ ! -h "$file" -a -f "$file" ]; then
        echo ".rhosts file in $dir"
      fi
    done
  fi
done
```

Making global modifications to users' files without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user `.rhosts` files and determine the action to be taken in accordance with site policy.

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

grep -E -v '^(root|halt|sync|shutdown)' /etc/passwd | awk -F: '($7 != ""/sbin/nologin"" && $7 !=
"/bin/false") { print $1 " " $6 }' | while read user dir; do
  if [ ! -d "$dir" ]; then
    echo "The home directory ($dir) of user $user does not exist."
  else
    for file in $dir/.rhosts; do
      if [ ! -h "$file" -a -f "$file" ]; then
        echo ".rhosts file in $dir"
      fi
    done
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.13

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.14

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-8019

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure all groups in /etc/passwd exist in /etc/group

Rule

Ensure all groups in /etc/passwd exist in /etc/group.

Description

Over time, system administration errors and changes can lead to groups being defined in /etc/passwd but not in /etc/group.

Rationale

Groups defined in the /etc/passwd file but not in the /etc/group file pose a threat to system security since group permissions are not properly managed.

I01 - Implementation Example

Run the following command to list groups in /etc/passwd without entry in /etc/group and perform the appropriate action to correct any discrepancies found:

```
#!/bin/bash

for i in $(cut -s -d: -f4 /etc/passwd | sort -u ); do
  grep -q -P "^.*?:[^:]*:$i:" /etc/group
  if [ $? -ne 0 ]; then
    echo "Group $i is referenced by /etc/passwd but does not exist in /etc/group"
  fi
done
```

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

for i in $(cut -s -d: -f4 /etc/passwd | sort -u ); do
  grep -q -P "^.*?:[^:]*:$i:" /etc/group
  if [ $? -ne 0 ]; then
    echo "Group $i is referenced by /etc/passwd but does not exist in /etc/group"
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.14

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.15

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3100

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no duplicate UIDs exist

Rule

Ensure no duplicate UIDs exist.

Description

Although the `useradd` program will not let you create a duplicate User ID (UID), it is possible for an administrator to manually edit the `/etc/passwd` file and change the UID field.

Rationale

Users must be assigned unique UIDs for accountability and to ensure appropriate access protections.

I01 - Implementation Example

Run the following command to list duplicate UIDs. Establish unique UIDs and review all files owned by the shared UIDs to determine which UID they are supposed to belong to:

```
#!/bin/bash

cut -f3 -d":" /etc/passwd | sort -n | uniq -c | while read x ; do
[ -z "$x" ] && break
set - $x
if [ $1 -gt 1 ]; then
    users=$(awk -F: '($3 == n) { print $1 }' n=$2 /etc/passwd | xargs)
    echo "Duplicate UID ($2): $users"
fi
done
```

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

cut -f3 -d":" /etc/passwd | sort -n | uniq -c | while read x ; do
[ -z "$x" ] && break
set - $x
if [ $1 -gt 1 ]; then
    users=$(awk -F: '($3 == n) { print $1 }' n=$2 /etc/passwd | xargs)
    echo "Duplicate UID ($2): $users"
fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.15

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.16

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-1741

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no duplicate GIDs exist

Rule

Ensure no duplicate GIDs exist.

Description

Although the `groupadd` program will not let you create a duplicate Group ID (GID), it is possible for an administrator to manually edit the `/etc/group` file and change the GID field.

Rationale

User groups must be assigned unique GIDs for accountability and to ensure appropriate access protections.

I01 - Implementation Example

Run the following command to list duplicate GIDs. Establish unique GIDs and review all files owned by the shared GID to determine which group they are supposed to belong to:

```
#!/bin/bash

cut -f3 -d":" /etc/passwd | sort -n | uniq -c | while read x ; do
[ -z "$x" ] && break
set - $x
if [ $1 -gt 1 ]; then
    users=$(awk -F: '($3 == n) { print $1 }' n=$2 /etc/passwd | xargs)
    echo "Duplicate UID ($2): $users"
fi
done
```

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

cut -f3 -d":" /etc/group | sort -n | uniq -c | while read x ; do
[ -z "$x" ] && break
set - $x
if [ $1 -gt 1 ]; then
    groups=$(awk -F: '($3 == n) { print $1 }' n=$2 /etc/group | xargs)
    echo "Duplicate GID ($2): $groups"
fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.16

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.17

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-3259

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no duplicate user names exist

Rule

Ensure no duplicate user names exist.

Description

Although the `useradd` program will not let you create a duplicate user name, it is possible for an administrator to manually edit the `/etc/passwd` file and change the user name.

Rationale

If a user is assigned a duplicate user name, it will create and have access to files with the first UID for that username in `/etc/passwd`. For example, if "test4" has a UID of 1000 and a subsequent "test4" entry has a UID of 2000, logging in as "test4" will use UID 1000. Effectively, the UID is shared, which is a security problem.

I01 - Implementation Example

Run the following command to list duplicate usernames. Establish unique user names for the users. File ownerships will automatically reflect the change as long as the users have unique UIDs:

```
#!/bin/bash

cut -f1 -d":" /etc/passwd | sort -n | uniq -c | while read x ; do
  [ -z "$x" ] && break
  set - $x
  if [ $1 -gt 1 ]; then
    uids=$(awk -F: '($1 == n) { print $3 }' n=$2 /etc/passwd | xargs)
    echo "Duplicate User Name ($2): $uids"
  fi
done
```

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

cut -f1 -d":" /etc/passwd | sort -n | uniq -c | while read x ; do
  [ -z "$x" ] && break
  set - $x
  if [ $1 -gt 1 ]; then
    uids=$(awk -F: '($1 == n) { print $3 }' n=$2 /etc/passwd | xargs)
    echo "Duplicate User Name ($2): $uids"
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.17

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.18

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

BL512-4027

EVAL until 2020-12-31

Asset Manager

C	I	A
123	123	123

Ensure no duplicate group names exist

Rule

Ensure no duplicate group names exist.

Description

Although the `groupadd` program will not let you create a duplicate group name, it is possible for an administrator to manually edit the `/etc/group` file and change the group name.

Rationale

If a group is assigned a duplicate group name, it will create and have access to files with the first GID for that group in `/etc/group`. Effectively, the GID is shared, which is a security problem.

I01 - Implementation Example

Run the following command to list duplicate group names. Establish unique names for the user groups. File group ownerships will automatically reflect the change as long as the groups have unique GIDs:

```
#!/bin/bash

cut -f1 -d":" /etc/group | sort -n | uniq -c | while read x ; do
  [ -z "$x" ] && break
  set - $x
  if [ $1 -gt 1 ]; then
    gids=$(gawk -F: '($1 == n) { print $3 }' n=$2 /etc/group | xargs)
    echo "Duplicate Group Name ($2): $gids"
  fi
done
```

C01 - Example Check

Run the following script and verify no results are returned:

```
#!/bin/bash

cut -f1 -d":" /etc/group | sort -n | uniq -c | while read x ; do
  [ -z "$x" ] && break
  set - $x
  if [ $1 -gt 1 ]; then
    gids=$(gawk -F: '($1 == n) { print $3 }' n=$2 /etc/group | xargs)
    echo "Duplicate Group Name ($2): $gids"
  fi
done
```

Crossreferences

Based on CIS Benchmark 'Red Hat Enterprise Linux 8' (v1.0.0.1): 6.2.18

Based on CIS Benchmark 'Distribution Independent Linux' (v2.0.0): 6.2.19

Version History (Latest Entry)

v1.0 (2020-08-07): modified (EVAL until 2020-12-31)

Fixed crossrefs and updated to CIS-RHEL-8.

Definitions

Asset Manager (AM)

Asset Managers are individuals who hold the overall technical responsibility for IT Assets (e.g., IT systems, applications, IT services, networks). They serve as the primary technical point of contacts for their IT Assets and are accountable for, among others, their installation, maintenance, and implementation of all security technical requirements.

All IT Assets shall have an Asset Manager assigned.

Asset Managers can delegate, for example to a Support Organization, the responsibility of the actions associated with the role but the accountability always remains with the Asset Managers, even when the asset is operated by third-parties.

Depending on the type of IT asset, other names may be used, such as *IT System Manager*, *Application Manager*, *IT Service Manager*, *Cloud Asset Manager*, *Network Manager*, or *IT Operations Manager*.

Glossary

ACP

Abbreviation of Asset Classification and Protection.

Siemens' process to systematically identify critical assets and ensure the development and implementation of adequate protection concepts. More information can be found at <https://intranet.for.siemens.com/cms/056/en/processes/security/Pages/acp.aspx> and at <https://wiki.siemens.com/display/en/ACP>.

References

- [1] Siemens CT CYS GOV POL *Siemens Information Security Policy Framework*.
<https://sfera.siemens.com/policies>
- [2] Siemens ST TO (2019). *Siemens Circular No. 105 "Implementation of Siemens-Internal Regulations in Affiliated Companies"*. <https://srs.siemens.cloud/#/c/ng233c>
- [3] Siemens CT CYS *Siemens Endpoint Detection and Response (EDR)* .
<https://intranet.for.siemens.com/wll/0132/en/isec/sol/Pages/endpoint-detection-and-response.aspx>
- [4] Siemens CT CYS GOV POL *Specific Information Security Policy: Access Control*.
https://webapps.siemens.com/sfera/current/com.siemens.seg.policy_framework.document.group.specific_is_policies:access-control